# Gestione delle Vulnerabilità

***Release 3.4.4***

**Link.it**

**22 ott 2026**

# Contents


**1 Introduzione** **1**

**2 Avvisi di Sicurezza** **3**
- 2.1 Avvisi di Sicurezza 2026 . . . 4
- 2.2 Avvisi di Sicurezza 2025 . . . 85
- 2.3 Avvisi di Sicurezza 2024 . . . 100
- 2.4 Avvisi di Sicurezza 2023 . . . 112
- 2.5 Avvisi di Sicurezza 2022 . . . 122
- 2.6 Avvisi di Sicurezza 2021 . . . 126

**3 Falsi Positivi** **129**
- 3.1 Falsi Positivi v3.4.x . . . 129
- 3.2 Falsi Positivi v3.3.x . . . 136

CHAPTER 1

# Introduzione

Le potenziali vulnerabilità sono gestite nel progetto GovWay in accordo a processi rigorosi e documentati. La segnalazione di una potenziale vulnerabilità può avvenire tramite diverse fonti:

- l'analisi delle librerie terza parte, descritta nella sezione releaseProcessGovWay_thirdPartyDynamicAnalysis_ci, rileva una vulnerabilità tramite il tool OWASP Dependency-Check;
- i test di sicurezza, descritti nella sezione releaseProcessGovWay_dynamicAnalysis_security, rilevano un nuovo problema o una regressione;
- dagli utenti di GovWay tramite l'apertura di un GovWay Issue.

Qualunque sia la provenienza, la segnalazione viene immediatamente analizzata al fine di verificare:

- se si tratta di un falso positivo e in tal case registrarlo come tale: *Falsi Positivi*;
- se si tratta di una vulnerabilità con un effettivo impatto sul software GovWay; in tal caso viene registrato un nuovo avviso di sicurezza ed avviato il processo di risoluzione, così come descritto nella sezione *Avvisi di Sicurezza*.

# CHAPTER 2

# Avvisi di Sicurezza

Le vulnerabilità sono classificate per severità rispetto al CVSS scoring system sintetizzato dalla tabella riportata nella figura Fig. 2.1.

| Severity | Base Score Range |
|---|---|
| None | 0.0 |
| Low | 0.1-3.9 |
| Medium | 4.0-6.9 |
| High | 7.0-8.9 |
| Critical | 9.0-10.0 |

Figure2.1: CVSS scoring system

**Tempi di Risoluzione**

Le tempistiche di risoluzione delle vulnerabilità sono classificate rispetto alla loro severità e garantite per le versioni Enterprise del prodotto. Per la versione community saranno rilasciati i sorgenti dei fix, che saranno poi inclusi nella prima versione rilasciata. In caso di vulnerabilità molto impattanti saranno prodotte patch version immediate anche per le versioni community.

I tempi sono calcolati rispetto alla data di identificazione dell'impatto della vulnerabilità sul prodotto (true positive).

Table2.1: Avvisi di Sicurezza: tempi di risoluzione

| Severità (CSSS Score) | Tempistica | Fix Version |
|---|---|---|
| Critical (9.0-10.0) | 10 giorni | Patch version |
| High (7.0-8.9) | 20 giorni | Patch version |
| Medium (4.0 - 6.9) | 45 giorni | Patch o Minor version |

continues on next page

Table 2.1 – continua dalla pagina precedente

| Severità (CSSS Score) | Tempistica | Fix Version |
|---|---|---|
| Low (3.9 or below) | n.d. | A discrezione del progetto |

**Elenco degli Avvisi**

Gli avvisi vengono classificati per anno di registrazione:

- *Avvisi di Sicurezza 2022*
- *Avvisi di Sicurezza 2021*

## 2.1 Avvisi di Sicurezza 2026

- *CVE-2026-107938, CVE-2026-71575, CVE-2026-100227*
- *CVE-2026-107937, CVE-2026-108039*
- *CVE-2026-107726, CVE-2026-107725*
- *CVE-2026-75140*
- *CVE-2026-102495, CVE-2026-102496, CVE-2026-102497*
- *CVE-2026-88920, CVE-2026-85532, CVE-2026-92899*
- *CVE-2026-91863, CVE-2026-91864, CVE-2026-91865, CVE-2026-91866, CVE-2026-91867*
- *CVE-2026-68497, CVE-2026-83557, CVE-2026-19032*
- *CVE-2026-8763, CVE-2026-13506*
- *CVE-2026-84939*
- *CVE-2026-89044*
- *CVE-2026-78254*
- *CVE-2026-59270, CVE-2026-47841, CVE-2026-47877*
- *CVE-2026-47842*
- *CVE-2026-59276*
- *CVE-2026-59277*
- *CVE-2026-47890, CVE-2026-59313*
- *CVE-2026-47891, CVE-2026-47892, CVE-2026-47893*
- *CVE-2026-59283*
- *CVE-2026-59282, CVE-2026-59281*
- *CVE-2026-59280*
- *CVE-2026-59314*
- *CVE-2026-62380*
- *CVE-2026-64607*
- *CVE-2026-71497*
- *CVE-2026-66909*

- *CVE-2026-68079, CVE-2026-61466, CVE-2026-63687, CVE-2026-65583, CVE-2026-57817, CVE-2026-57818, CVE-2026-68481*
- *CVE-2026-54225, CVE-2026-64958*
- *CVE-2026-65432*
- *CVE-2026-57819*
- *CVE-2026-66142, CVE-2026-66143, CVE-2026-66144*
- *CVE-2026-41720*
- *CVE-2026-44891, CVE-2026-55831, CVE-2026-55833*
- *CVE-2026-49844*
- *CVE-2026-54399, CVE-2026-54428*
- *CVE-2026-54515*
- *CVE-2026-54512, CVE-2026-54513, CVE-2026-54514, CVE-2026-54515, CVE-2026-54516, CVE-2026-54517, CVE-2026-54518*
- *CVE-2026-50631, CVE-2026-50623, CVE-2026-50630, CVE-2026-50629*
- *CVE-2026-50632, CVE-2026-50633*
- *CVE-2026-50634*
- *CVE-2026-50645*
- *CVE-2026-40988, CVE-2026-41003, CVE-2026-41694*
- *CVE-2026-41842, CVE-2026-41841, CVE-2026-41843*
- *CVE-2026-41845, CVE-2026-41846*
- *CVE-2026-41844*
- *CVE-2026-41840*
- *CVE-2026-41838*
- *CVE-2026-41850, CVE-2026-41851, CVE-2026-41852*
- *CVE-2026-41848*
- *CVE-2026-47691, CVE-2026-45674, CVE-2026-44249, CVE-2026-45416, CVE-2026-45673*
- *CVE-2026-44417, CVE-2026-44618, CVE-2026-44930*
- *CVE-2026-42579*
- *CVE-2026-42583*
- *CVE-2026-42402, CVE-2026-42403, CVE-2026-42404*
- *CVE-2026-0636*
- *CVE-2026-5588*
- *GHSA-h8r8-wccr-v5f2, GHSA-cjmm-f4jc-qw8r, GHSA-cj63-jhhr-wcxv*
- *CVE-2026-34481*
- *CVE-2026-34479*
- *CVE-2026-34480*
- *CVE-2026-34478*

- *CVE-2026-34477*
- *CVE-2026-33871*
- *CVE-2026-33870*
- *CVE-2026-22732*
- *GHSA-72hv-8253-57qq*
- *CVE-2025-67735*

### 2.1.1 CVE-2026-107938, CVE-2026-71575, CVE-2026-100227

Data: 2026-10-17

Severity: Critical

CVSS Score:

- CVE-2026-107938: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
- CVE-2026-71575: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
- CVE-2026-100227: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché risiedono nei moduli `cxf-rt-transports-http-netty-client` (trasporto HTTP client basato su Netty), `cxf-rt-rs-security-sso-oidc` (relying party OpenID Connect) e `cxf-rt-rs-security-xml` (XML Security per JAX-RS) di Apache CXF, non distribuiti da GovWay.

Riferimenti:

- CVE-2026-107938:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-107938
  - https://cxf.apache.org/security-advisories.data/CVE-2026-107938.txt
- CVE-2026-71575:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-71575
  - https://cxf.apache.org/security-advisories.data/CVE-2026-71575.txt
- CVE-2026-100227:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-100227
  - https://cxf.apache.org/security-advisories.data/CVE-2026-100227.txt

Libreria: org.apache.cxf:cxf-rt-transports-http-netty-client, org.apache.cxf:cxf-rt-rs-security-sso-oidc, org.apache.cxf:cxf-rt-rs-security-xml (versioni affette: < 3.6.13, 4.0.0 - 4.1.8 e 4.2.0 - 4.2.3)

**Descrizione**

Le tre vulnerabilità riguardano moduli opzionali di Apache CXF: il trasporto HTTP client basato su Netty, il relying party OpenID Connect e il modulo XML Security per i servizi JAX-RS.

1. [CVE-2026-107938] CWE-297: Improper Validation of Certificate with Host Mismatch

In Apache CXF, the Netty-based HTTP client transport (cxf-rt-transports-http-netty-client) did not verify that the hostname in the server's TLS certificate matched the host being called. This applied over both HTTP/1.1 and HTTP/2, even when disableCNCheck was left at its default value of false. The certificate chain was validated against the configured trust store, but the endpoint's identity was not. A network attacker able to intercept traffic could present any certificate trusted by the client, such as a publicly issued certificate for a domain they control, and impersonate the target service. They could then read or modify the exchanged messages, including credentials. Users are recommended to upgrade to versions 4.2.4 or 4.1.9 or 3.6.13, which fix this issue.

2. [CVE-2026-71575] CWE-613: Insufficient Session Expiration

The max_age authentication-freshness check in OidcClientCodeRequestFilter was inoperative due to a milliseconds/seconds unit mismatch and an inverted comparison polarity. Any relying party using setMaxAgeOffset to enforce re-authentication would silently accept sessions of any age, bypassing step-up authentication policies. Users are recommended to upgrade to versions 4.2.4 or 4.1.9 or 3.6.13, which fix this issue.

3. [CVE-2026-100227] CWE-362: Concurrent Execution using Shared Resource with Improper Synchronization ("Race Condition")

Improper Verification of Cryptographic Signature vulnerability in Apache CXF's JAX-RS XML Security module. The JAX-RS XML Signature interceptors (XmlSigInHandler, XmlSigInInterceptor and the streaming XmlSecInInterceptor) did not ensure that the XML passed to the application was covered by the signature. An attacker with any document signed by a trusted key could wrap it in unsigned content, which the application would then treat as signed. Users are recommended to upgrade to versions 4.2.4 or 4.1.9 or 3.6.13, which fix this issue.

**GovWay**

Le tre vulnerabilità risiedono in moduli di Apache CXF che **non fanno parte della distribuzione di GovWay**:

- **CVE-2026-107938** riguarda il trasporto HTTP client basato su Netty (modulo `cxf-rt-transports-http-netty-client`). Le invocazioni verso i backend e gli altri domini effettuate dal gateway sono realizzate tramite i connettori propri del prodotto, che non utilizzano i trasporti client di Apache CXF; gli stub client CXF forniti con GovWay (es. IntegrationManager) utilizzano invece il trasporto HTTP standard di CXF (`cxf-rt-transports-http`), non interessato dalla vulnerabilità;
- **CVE-2026-71575** riguarda il filtro `OidcClientCodeRequestFilter` del relying party OpenID Connect di CXF (modulo `cxf-rt-rs-security-sso-oidc`). L'autenticazione degli utenti delle console e la gestione dei token in GovWay (validazione JWT, introspection e userinfo verso Identity Provider esterni, negoziazione dei token, PDND) sono realizzate con logica propria, indipendente dai moduli OAuth2/OIDC di CXF (cfr. *CVE-2026-68079, CVE-2026-61466, CVE-2026-63687, CVE-2026-65583, CVE-2026-57817, CVE-2026-57818, CVE-2026-68481*);
- **CVE-2026-100227** riguarda gli interceptor di firma XML per JAX-RS (`XmlSigInHandler`, `XmlSigInInterceptor`, `XmlSecInInterceptor`) del modulo `cxf-rt-rs-security-xml`. Le API REST esposte da GovWay tramite CXF (API di configurazione e monitoraggio) non utilizzano firme XML, mentre la verifica delle firme XML sui messaggi gestiti dal gateway (WS-Security, ModI) è effettuata tramite WSS4J e logica propria del prodotto, senza transitare per gli interceptor JAX-RS di CXF.

Per questi motivi le vulnerabilità non si manifestano nel prodotto.

La libreria viene comunque aggiornata alla prima versione in rilascio.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico degli artefatti `cxf-core` e `cxf-rt-transports-http-jetty`, in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nei moduli `cxf-rt-transports-http-netty-client` (CVE-2026-107938),

`cxf-rt-rs-security-sso-oidc` (CVE-2026-71575) e `cxf-rt-rs-security-xml` (CVE-2026-100227), non distribuiti da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.2 CVE-2026-107937, CVE-2026-108039

Data: 2026-10-17

Severity: High

CVSS Score:

- CVE-2026-107937: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-108039: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- CVE-2026-107937:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-107937
  - https://cxf.apache.org/security-advisories.data/CVE-2026-107937.txt
- CVE-2026-108039:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-108039
  - https://cxf.apache.org/security-advisories.data/CVE-2026-108039.txt

Libreria: org.apache.cxf:cxf-core (versioni affette: < 3.6.13, 4.0.0 - 4.1.8 e 4.2.0 - 4.2.3)

**Descrizione**

1. [CVE-2026-107937] CWE-770: Allocation of Resources Without Limits or Throttling

In Apache CXF, the parser for multipart/MTOM attachment part headers did not fully enforce the configured attachment-max-header-size (default 300 characters) and attachment-headers-max-count (default 500) limits. The size limit was applied only to each physical line, not to a header value built from continuation lines or to the combined values of a repeated header. The count limit was checked against the number of distinct header names, not the total number of header lines. A remote, unauthenticated attacker could send a multipart request with very large folded or repeated part headers. The server would then allocate memory without bound, causing a denial of service. Users are recommended to upgrade to versions 4.2.4 or 4.1.9 or 3.6.13, which fix this issue.

2. [CVE-2026-108039] CWE-776: Improper Restriction of Recursive Entity References in DTDs ("XML Entity Expansion")

By default, StaxUtils placed no limit on the total number of elements or the total number of characters in an XML document. A very large request could therefore use a lot of memory and CPU during parsing, especially where CXF builds a DOM from the input (for example SAAJ or WS-Security), and could cause a denial of service when no request size limit was configured. Both limits now have defaults: the maximum element count is 100 × maxChildElements (5,000,000 by default), and the maximum document size is 256M characters. Applications that process larger documents can raise the limits with the org.apache.cxf.stax.maxElementCount and

org.apache.cxf.stax.maxXMLCharacters properties. Users are recommended to upgrade to versions 4.2.4 or 4.1.9 or 3.6.13, which fix this issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.3 CVE-2026-107726, CVE-2026-107725

Data: 2026-10-08

Severity: Critical

CVSS Score:

- CVE-2026-107726: 9.3 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N)
- CVE-2026-107725: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, le vulnerabilità sono sfruttabili solamente da chi è in grado di raggiungere le porte del cluster Hazelcast avviato dai nodi GovWay, e solamente nelle installazioni che utilizzano policy di rate limiting con sincronizzazione distribuita tramite Hazelcast.

Riferimenti:

- CVE-2026-107726 (GHSA-6v25-8wq6-xq4j):
  - https://github.com/advisories/GHSA-6v25-8wq6-xq4j
  - https://github.com/hazelcast/hazelcast/security/advisories/GHSA-6v25-8wq6-xq4j
  - https://github.com/hazelcast/hazelcast/commit/361979da12f18950c24719db832ca6c5e7c0534f
  - https://support.hazelcast.com/s/article/Security-Advisory-GHSA-6v25-8wq6-xq4j
- CVE-2026-107725 (GHSA-w294-6q5q-53p8):
  - https://github.com/advisories/GHSA-w294-6q5q-53p8
  - https://github.com/hazelcast/hazelcast/security/advisories/GHSA-w294-6q5q-53p8
  - https://github.com/hazelcast/hazelcast/commit/5d68f4828e2a914398a39f12fe11cafd335cefe0
- https://docs.hazelcast.com/hazelcast/5.7/release-notes/community

Libreria: com.hazelcast:hazelcast

- GovWay 3.3.x: <= 5.3.8
- GovWay 3.4.x: <= 5.3.8

**Descrizione**

1. [CVE-2026-107726] CWE-20: Improper Input Validation

Hazelcast allows arbitrary member memory access by low-privileged client.

A flaw has been found in Hazelcast Enterprise Edition and Community Edition, which would allow a low-privileged malicious client to read arbitrary data in memory from any cluster member (including Java heap memory, off-heap data, and JVM process address space). Additionally, such a client may be able to cause one or more cluster members to crash, or in some Enterprise Edition configurations also corrupt memory contents, potentially leading to remote code execution. Both slim and full distributions are affected.

Enterprise customers should upgrade to a fixed version of Hazelcast Enterprise Edition: 5.7.0, 5.6.1, 5.5.10, 5.4.5. Community Edition users should upgrade to version 5.7.0.

Workarounds: if you cannot update to a fixed version immediately, restrict cluster access to trusted clients only and ensure clients are hardened against compromise.

2. [CVE-2026-107725] CWE-862: Missing Authorization

Hazelcast has an authorization bypass in IMap Predicates API.

Missing authorization checks in the Predicates API may allow a malicious client to execute arbitrary code on a Hazelcast member.

Enterprise customers should upgrade to a fixed version of Hazelcast Enterprise Edition: 5.7.0, 5.6.1, 5.5.10, 5.4.5. Community Edition users should upgrade to version 5.7.0.

Workarounds: none - customers are advised to upgrade to a fixed version as soon as possible.

**GovWay**

GovWay utilizza Hazelcast (Community Edition) per la sincronizzazione distribuita dei contatori del rate limiting: per ogni modalità di conteggio utilizzata (es. “atomic-long-counters”, “pn-counters”, “near-cache”) ciascun nodo avvia al proprio interno un member Hazelcast, in ascolto su una porta dedicata (per default nell’intervallo 5701-5709), che forma un cluster con i member degli altri nodi.

I member vengono avviati solamente per le modalità di conteggio utilizzate da almeno una policy di rate limiting configurata con sincronizzazione “Distribuita” tramite Hazelcast. Le installazioni che non utilizzano tale sincronizzazione (per default il conteggio è gestito localmente in ogni nodo) non avviano alcun member e non sono interessate dalle vulnerabilità.

Nella Community Edition di Hazelcast non sono previste l’autenticazione dei member e dei client né la cifratura delle comunicazioni: un soggetto in grado di raggiungere le porte del cluster può collegarsi come client e sfruttare le vulnerabilità. Le vulnerabilità non sono invece sfruttabili tramite le interfacce esposte dal gateway (erogazioni, fruizioni, console e API di configurazione e monitoraggio).

Nella versione 3.4.4 la libreria viene aggiornata alla versione 5.7.0. Poiché a partire dalla versione 5.5 il CP Subsystem di Hazelcast è disponibile solamente nella Enterprise Edition, i contatori delle modalità “atomic-long-counters” sono stati reimplementati su una mappa distribuita, con le stesse garanzie di conteggio delle versioni precedenti; la configurazione delle policy non subisce modifiche.

Nella versione 3.3.x l’aggiornamento non è possibile, poiché le versioni di Hazelcast contenenti il fix richiedono Java 17. In attesa dell’aggiornamento, e nelle installazioni 3.3.x, si raccomanda di applicare le seguenti mitigazioni:

- consentire l’accesso alle porte del cluster Hazelcast esclusivamente ai nodi GovWay che ne fanno parte (es. tramite regole firewall o security group);
- nel file “govway_local.hazelcast.yaml” disabilitare i meccanismi di discovery “multicast” e “auto-detection”, configurando il join “tcp-ip” con l’elenco esplicito dei nodi del cluster;
- limitare tramite l’elemento “interfaces” le interfacce di rete su cui i member sono in ascolto alla sola rete del cluster.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.4 CVE-2026-75140

Data: 2026-10-06

Severity: High

CVSS Score: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché GovWay non utilizza il parser XML di jsoup (`XmlTreeBuilder`).

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-75140
- https://github.com/advisories/GHSA-65r4-943x-97jj
- https://github.com/jhy/jsoup/releases/tag/jsoup-1.23.2

Libreria: org.jsoup:jsoup (versioni affette: < 1.23.2)

**Descrizione**

CWE-770: Allocation of Resources Without Limits or Throttling

[GHSA-65r4-943x-97jj] jsoup XmlTreeBuilder vulnerable to memory exhaustion through deeply nested namespace declarations

jsoup through 1.23.2, fixed in commit 862ba2f, contains an uncontrolled resource consumption vulnerability in XmlTreeBuilder that allows remote attackers to exhaust JVM heap memory by supplying a deeply nested XML document with uniquely-namespaced elements. The builder copies the entire inherited namespace map on every start element, causing quadratic time and memory complexity, which attackers can exploit to trigger an OutOfMemoryError and terminate the application.

**GovWay**

La libreria `jsoup` è utilizzata dalle console di gestione e monitoraggio e dalle API di configurazione e monitoraggio per sanificare i parametri ricevuti, tramite `Jsoup.clean()` e `Jsoup.parse()`, che utilizzano il parser HTML (`HtmlTreeBuilder`).

Il codice vulnerabile risiede nel parser XML `XmlTreeBuilder`, attivato solamente tramite `Parser.xmlParser()`, che GovWay non utilizza. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

La libreria viene comunque aggiornata alla prima versione in rilascio.

Versione affette:

- 3.3.x: non affetta
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.5 CVE-2026-102495, CVE-2026-102496, CVE-2026-102497

Data: 2026-10-06

Severity: High

CVSS Score:

- CVE-2026-102495: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-102496: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-102497: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, le vulnerabilità non sono sfruttabili dai client del gateway, poiché la libreria elabora unicamente schemi interni al prodotto o forniti da sistemi configurati dall'amministratore.

Riferimenti:

- CVE-2026-102495:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-102495
  - https://lists.apache.org/thread/l339q3oldm0cd2lph4b6f93fd07x9g6s
  - https://www.openwall.com/lists/oss-security/2026/09/29/15
- CVE-2026-102496:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-102496
  - https://lists.apache.org/thread/9z1vg8wmvwpfw748fb2nb55w4hgbnxol
  - https://www.openwall.com/lists/oss-security/2026/09/29/16
- CVE-2026-102497:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-102497
  - https://lists.apache.org/thread/1cj02tobjyhjqq723bvg78yxkqt1lk7k
  - https://www.openwall.com/lists/oss-security/2026/09/29/17

Libreria: org.apache.ws.xmlschema:xmlschema-core

- GovWay 3.3.x: <= 2.3.2
- GovWay 3.4.x: <= 2.3.2

**Descrizione**

1. [CVE-2026-102495] CWE-674: Uncontrolled Recursion

Apache XmlSchema doesn't limit how deeply schema imports and includes can be nested, so a malicious schema can make parsing recurse until the stack overflows. This causes a denial of service.

Users are recommended to upgrade to version 2.3.3, which fixes this issue.

2. [CVE-2026-102496] CWE-674: Uncontrolled Recursion

Apache XmlSchema doesn't limit how deeply schema structures can be nested when it builds its schema model, so a malicious schema can make parsing recurse until the stack overflows. This causes a denial of service.

Users are recommended to upgrade to version 2.3.3, which fixes this issue.

3. [CVE-2026-102497] CWE-674: Uncontrolled Recursion

The Apache XmlSchema walker (xmlschema-walker) doesn't detect cycles in type derivation, substitution groups, model groups or attribute groups. A malicious schema with such a cycle can make the walker recurse until the stack overflows, causing a denial of service.

Users are recommended to upgrade to version 2.3.3, which fixes this issue.

**GovWay**

La libreria `xmlschema-core` è inclusa nella distribuzione di GovWay come dipendenza di Apache CXF e non è utilizzata direttamente dal codice del prodotto: tra i jar distribuiti la referenziano esclusivamente i moduli di CXF.

Per sfruttare le vulnerabilità un attaccante deve far elaborare alla libreria uno schema XML malevolo; in GovWay tale condizione non si verifica per i client del gateway:

- gli endpoint SOAP dell'IntegrationManager esposti tramite CXF costruiscono il proprio modello di servizio a partire dagli schemi generati dalle classi JAXB di GovWay;
- il profilo AS4 elabora il WSDL esposto dal backend Domibus, il cui indirizzo è configurato dall'amministratore;
- la validazione dei contenuti dei messaggi gestiti dal gateway e il caricamento di WSDL e XSD tramite la console non utilizzano Apache XmlSchema.

La vulnerabilità CVE-2026-102497 risiede inoltre nel modulo `xmlschema-walker`, non distribuito da GovWay.

La libreria viene comunque aggiornata alla prima versione in rilascio.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.6 CVE-2026-88920, CVE-2026-85532, CVE-2026-92899

Data: 2026-10-03

Severity: Critical

CVSS Score:

- CVE-2026-88920: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-85532: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-92899: 4.8 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N)

Riferimenti:

- CVE-2026-88920:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-88920
  - https://lists.apache.org/thread/grt43m3bgbzz0mk0cnho3rcybb1j01z9
  - https://www.openwall.com/lists/oss-security/2026/09/30/10

- CVE-2026-85532:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-85532
  - https://lists.apache.org/thread/7jllcpbf4nbzhdp2vchz5yplnl5w6vd6
  - https://www.openwall.com/lists/oss-security/2026/09/30/8
- CVE-2026-92899:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-92899
  - https://lists.apache.org/thread/nrzngsz1xm2lztq3t873663xx9wnrwm7
  - https://www.openwall.com/lists/oss-security/2026/09/30/13

Libreria: org.apache.wss4j:*

- GovWay 3.3.x: <= 2.4.3
- GovWay 3.4.x: <= 4.0.1

**Descrizione**

1. [CVE-2026-88920] CWE-287: Improper Authentication

An authentication bypass in the DOM security processor in Apache WSS4J allows unauthenticated remote attackers to forge authenticated SOAP messages via a crafted unsigned SAML sender-vouches assertion containing an attacker-controlled key.

Users are recommended to upgrade to versions 4.0.2 or 3.0.6 or 2.4.4, which fix this issue.

2. [CVE-2026-85532] CWE-20: Improper Input Validation

Apache WSS4J accepted attacker-controlled derived-key lengths and offsets without adequate bounds. This could permit cryptographically weak keys or excessive CPU and memory consumption when processing crafted WS-Security messages. The fixes enforce a minimum key length of 16 bytes, a maximum length of 512 bytes, and a maximum offset of 4096 bytes. Users are recommended to upgrade to versions 4.0.2 or 3.0.6 or 2.4.4, which fix this issue.

3. [CVE-2026-92899] CWE-290: Authentication Bypass by Spoofing

Apache WSS4J remembers the Nonce of each UsernameToken it accepts, so a captured token cannot be reused. It stored the Nonce as raw base64 text, but authentication decodes that text and uses the bytes.The same bytes can be written as base64 in several ways. An attacker who captured an authenticated request could re-send it with a space added to the Nonce: the password digest still verified, but the token no longer matched the remembered one, so the replay was accepted. Since a UsernameToken does not cover the message body, the captured token could then be reused on requests of the attacker's choosing until it expired. Affects deployments with a nonce replay cache configured, as Apache CXF has by default, and only tokens using a password digest. The cache is now keyed on the decoded Nonce. Users are recommended to upgrade to versions 4.0.2 or 3.0.6 or 2.4.4, which fix this issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.7 CVE-2026-91863, CVE-2026-91864, CVE-2026-91865, CVE-2026-91866, CVE-2026-91867

Data: 2026-09-28

Severity: High

CVSS Score:

- CVE-2026-91863: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-91864: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-91865: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-91866: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-91867: 4.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:L)

Riferimenti:

- CVE-2026-91863:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-91863
  - https://lists.apache.org/thread/72kxj71lvrqqx90xxqqctvpbw0t8mpxw
  - https://www.openwall.com/lists/oss-security/2026/09/18/10
- CVE-2026-91864:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-91864
  - https://lists.apache.org/thread/400kbynbyhqhsjkv1yz251jm9wdz8z69
  - https://www.openwall.com/lists/oss-security/2026/09/18/11
- CVE-2026-91865:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-91865
  - https://lists.apache.org/thread/l48btqh02rlpsgf5p6r5ltqk1cb69dtc
  - https://www.openwall.com/lists/oss-security/2026/09/18/12
- CVE-2026-91866:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-91866
  - https://lists.apache.org/thread/zbfxnomgvbmqchqjgc6lk5h0z76k3gh4
  - https://www.openwall.com/lists/oss-security/2026/09/18/13
- CVE-2026-91867:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-91867
  - https://lists.apache.org/thread/dsr2ktf199mqhw2jtlbklyz7tzd86ycd
  - https://www.openwall.com/lists/oss-security/2026/09/18/14

Libreria: org.apache.neethi:neethi <= 3.2.3

**Descrizione**

Tutte le vulnerabilità riguardano l'elaborazione dei documenti WS-Policy da parte di Apache Neethi e sono corrette nella medesima release 3.2.4.

1. [CVE-2026-91863] CWE-674: Uncontrolled Recursion

A specially crafted WS-Policy document with deeply nested policy elements can bypass Neethi's nesting-depth limit and exhaust the thread stack, crashing the parser (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.

2. [CVE-2026-91864] CWE-770: Allocation of Resources Without Limits or Throttling

A specially crafted WS-Policy document can pack unlimited content inside a policy assertion, which Neethi copies into memory without counting it against its size limits, exhausting the heap (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.

3. [CVE-2026-91865] CWE-770: Allocation of Resources Without Limits or Throttling

A small WS-Policy document using repeated policy references can force Neethi to re-expand the same references exponentially during normalization, consuming huge amounts of CPU and memory (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.

4. [CVE-2026-91866] CWE-770: Allocation of Resources Without Limits or Throttling

A specially crafted pair of WS-Policy documents can force Neethi's policy-intersection to do exponential amounts of work, pinning the CPU for a long time (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.

5. [CVE-2026-91867] CWE-400: Uncontrolled Resource Consumption

When Neethi fetches a remote policy reference, it only limits the time per read, not the whole transfer, so a server that trickles bytes slowly can keep the fetch alive indefinitely and tie up the calling thread (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.8 CVE-2026-68497, CVE-2026-83557, CVE-2026-19032

Data: 2026-09-28

Severity: High

CVSS Score:

- CVE-2026-68497: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-83557: 5.6 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L)
- CVE-2026-19032: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)

Riferimenti:

- CVE-2026-68497:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-68497
  - https://github.com/advisories/GHSA-q4xh-88c3-wmh7
- CVE-2026-83557:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-83557

  - https://github.com/advisories/GHSA-gx83-3vf8-gh7j
- CVE-2026-19032:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-19032
  - https://github.com/advisories/GHSA-wjgm-6hv5-3cvf

Libreria: com.fasterxml.jackson.core:jackson-databind

- GovWay 3.4.x: <= 2.22.1
- GovWay 3.3.x: <= 2.18.9

**Descrizione**

Three vulnerabilities in the jackson-databind library, reported by GitHub Dependabot. The following are the official NVD descriptions.

[CVE-2026-68497] (GHSA-q4xh-88c3-wmh7) - CVSS 7.5 (High)

jackson-databind binds a JSON string to a javax.xml.datatype.Duration or javax.xml.datatype.XMLGregorianCalendar field by passing the raw string verbatim to DatatypeFactory.newDuration(value) or newXMLGregorianCalendar(value) in CoreXMLDeserializers.Std._deserialize. These deserializers are registered by default with no opt-in, so a plain ObjectMapper or JsonMapper with no polymorphic typing and no special configuration reaches this path. The XML Schema lexical grammar permits numeric components of arbitrary length, which the JDK materializes through the native BigInteger(String) and BigDecimal(String) constructors, both quadratic in digit count. Because the digits sit inside a JSON string token rather than a JSON number token, jackson-core's StreamReadConstraints.maxNumberLength guard never applies; jackson's own NumberDeserializers call validateIntegerLength or validateFPLength before parsing a stringified number, but the XML datatype deserializer omits that pre-check. An unauthenticated attacker can therefore submit a single request of a few megabytes, such as a Duration value consisting of the letter P followed by several million digits and the letter Y, and force tens of seconds to several minutes of single-threaded CPU work; a handful of concurrent requests can saturate a server's worker threads. This affects com.fasterxml.jackson.core:jackson-databind from 2.0.0 before 2.18.10, from 2.19.0 before 2.21.6, and from 2.22.0 before 2.22.2, and tools.jackson.core:jackson-databind from 3.0.0 before 3.1.6 and from 3.2.0 before 3.2.2. Users should upgrade to 2.18.10, 2.21.6, 2.22.2, 3.1.6, or 3.2.2.

[CVE-2026-83557] (GHSA-gx83-3vf8-gh7j) - CVSS 5.6 (Medium)

DefaultBaseTypeLimitingValidator is the PolymorphicTypeValidator applied automatically whenever @JsonTypeInfo is used without an explicitly configured custom validator. It denies polymorphic resolution only for a fixed set of «unsafe base types», and its isSafeSubType method returns true unconditionally for every base type outside that set. java.lang.Comparable was absent from the list despite being implemented by a very large fraction of JDK and application classes, comparable in breadth to java.io.Serializable, which is on the list for that reason. An application declaring an @JsonTypeInfo-annotated property or class with Comparable as its base type, and no custom PolymorphicTypeValidator, will accept a type identifier for essentially any class implementing Comparable. This yields an attacker-controlled object instantiation primitive; a demonstrated case constructs a java.io.File for an arbitrary attacker-chosen path, which becomes path-traversal-adjacent if the application subsequently calls path-sensitive methods on the value. No class implementing Comparable has been identified that yields code execution through deserialization alone. Global Default Typing via activateDefaultTyping is not affected, because that method structurally requires an explicit PolymorphicTypeValidator argument. This affects com.fasterxml.jackson.core:jackson-databind from 2.11.0 before 2.18.10, from 2.19.0 before 2.21.6, and from 2.22.0 before 2.22.2, and tools.jackson.core:jackson-databind from 3.0.0 before 3.1.6 and from 3.2.0 before 3.2.2. Users should upgrade to 2.18.10, 2.21.6, 2.22.2, 3.1.6, or 3.2.2.

[CVE-2026-19032] (GHSA-wjgm-6hv5-3cvf) - CVSS 5.3 (Medium)

jackson-databind's deserializer for java.nio.file.Path resolves an attacker-supplied URI without restricting the URI scheme. In JDKFromStringDeserializer.NioPathHelper.deserialize, a string bound from untrusted JSON is passed to new URI(value) and then to Path.of(uri). When that throws FileSystemNotFoundException, the code enumerates ServiceLoader<FileSystemProvider> and calls provider.getPath(uri) on the first provider whose scheme matches the

attacker-chosen scheme. Untrusted JSON can therefore select and drive an arbitrary registered FileSystemProvider during readValue under a default JsonMapper, and forces provider class loading at the same time. With only the JDK built-in providers (file, jar/zipfs) present, the resolved path is inert and no mount or network I/O occurs; further impact requires a side-effecting third-party FileSystemProvider on the classpath. This affects com.fasterxml.jackson.core:jackson-databind from 2.8.0 before 2.18.10, from 2.19.0 before 2.21.6, and from 2.22.0 before 2.22.2, and tools.jackson.core:jackson-databind from 3.0.0 before 3.1.6 and from 3.2.0 before 3.2.2. Users should upgrade to 2.18.10, 2.21.6, 2.22.2, 3.1.6, or 3.2.2. Binding java.nio.file.Path from untrusted JSON should be avoided regardless of version.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.9 CVE-2026-8763, CVE-2026-13506

Data: 2026-09-18

Severity: Critical

CVSS Score:

- CVE-2026-8763:
  - CVSS v3.1: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
  - CVSS v4.0: 9.3 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N)
- CVE-2026-13506:
  - CVSS v3.1: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
  - CVSS v4.0: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N)

Riferimenti:

- CVE-2026-8763 (GHSA-9pwp-9qqc-pr26):
  - https://nvd.nist.gov/vuln/detail/CVE-2026-8763
  - https://github.com/advisories/GHSA-9pwp-9qqc-pr26
  - https://github.com/bcgit/bc-java/wiki/CVE-2026-8763
  - https://github.com/bcgit/bc-java/commit/2c28b253a44681fbbc562561eab6ad383d2ae558
- CVE-2026-13506 (GHSA-qp49-qgx5-5m26):
  - https://nvd.nist.gov/vuln/detail/CVE-2026-13506
  - https://github.com/advisories/GHSA-qp49-qgx5-5m26
  - https://github.com/bcgit/bc-java/wiki/CVE-2026-13506
  - https://github.com/bcgit/bc-java/commit/77454da9b3dcaaa2991412d1c3c1a6e1a338ff84

Libreria: org.bouncycastle:bcprov-jdk18on (versioni affette: < 1.85)

**Descrizione**

Entrambe le vulnerabilità riguardano l'elaborazione delle strutture ASN.1 e dei certificati X.509 operata da BouncyCastle, e sono corrette nella medesima release 1.85.

1. [CVE-2026-8763] CWE-295: Improper Certificate Validation

In Bouncy Castle for Java before 1.85, Name Constraints bypass via trailing dot in rfc822Name and URI. This issue also affects Bouncy Castle for Java LTS before 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) before bc-fips 1.0.2.7 (1.0.X series), 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series).

2. [CVE-2026-13506] CWE-674: Uncontrolled Recursion

In Bouncy Castle for Java before 1.85, Lazy ASN.1 sequence forcing resets nesting-depth guard. This issue also affects Bouncy Castle for Java LTS before 2.73.12, and Bouncy Castle for Java FIPS (BC-FJA) before bc-fips 1.0.2.7 (1.0.X series), 2.0.2 (2.0.X series) and 2.1.3 (2.1.X series).

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.10 CVE-2026-84939

Data: 2026-09-17

Severity: Critical

CVSS Score: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché il locale utilizzato per la risoluzione dei template non è mai ricavato dai dati in transito e i *template loader* impiegati non consentono l'accesso al di fuori delle risorse distribuite dal prodotto.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-84939
- https://lists.apache.org/thread/hrd7o2ylwkkswdyhyzllgqt0f80kyd5y
- https://www.openwall.com/lists/oss-security/2026/09/08/2

Libreria: org.freemarker:freemarker (versioni affette: 2.2.0 - 2.3.34)

**Descrizione**

CWE-23: Relative Path Traversal

Path traversal vulnerability in Apache FreeMarker template loading mechanism, if the attacker can specify an arbitrary malformed locale identifier to FreeMarker, and the localized lookup configuration setting is enabled (it's by default enabled).

This issue affects Apache FreeMarker from 2.2.0 through 2.3.34.

Users are recommended to upgrade to version 2.3.35. Disabling localized lookup in previous versions also mitigates this.

Note that even in versions affected by this vulnerability, the files that can be loaded remain restricted by the TemplateLoader that FreeMarker is configured to use. In particular, FileTemplateLoader prevents attempts to traverse outside the baseDir specified in its constructor. Other TemplateLoader implementations may allow access outside their designated base directory, but they are still constrained by the underlying storage mechanism - for example, a loader wrapping a Java class loader can only access resources that the class loader can load, while one wrapping a web application context can only access resources available through that context.

**GovWay**

La libreria è inclusa nella distribuzione di GovWay ed è utilizzata sia dai template interni del prodotto, sia dai template FreeMarker che l'amministratore può definire in configurazione (trasformazioni di richiesta e risposta, template dinamici, generazione di claims e di messaggi di errore).

Lo sfruttamento richiede che a FreeMarker venga fornito un identificativo di locale arbitrario e malformato: tale identificativo viene concatenato al nome del template *senza essere normalizzato*, producendo un nome candidato che il *template loader* può risolvere al di fuori della directory di base. L'analisi del prodotto, unitamente ad una verifica sperimentale condotta sulla versione 2.3.34 della libreria, ha evidenziato quanto segue.

1. **Il locale non è mai ricavato dai dati in transito.** L'unica configurazione della libreria è costruita in `org.openspcoop2.utils.resources.TemplateUtils.newTemplateEngine(..)`, dove non viene invocato il metodo `Configuration.setLocale(..)`; i template vengono inoltre sempre risolti tramite l'overload `Configuration.getTemplate(String)`, che utilizza il locale di default della configurazione, e mai tramite gli overload che accettano un locale. Il locale effettivamente impiegato è quindi quello di default della JVM, non influenzabile dal contenuto delle richieste gestite dal gateway.
2. **I template definiti in configurazione non transitano dal meccanismo di template loading.** Essi vengono compilati direttamente dal loro contenuto binario, tramite `TemplateUtils.buildTemplate(..)` che istanzia `new freemarker.template.Template(name, reader, configuration)`: in questo percorso non viene effettuata alcuna ricerca del template e, di conseguenza, nessun *localized lookup*. Gli eventuali template inclusi da un template principale sono risolti dalla classe `org.openspcoop2.utils.resources.FreemarkerTemplateLoader`, un *template loader* che opera su una mappa in memoria e restituisce esclusivamente i nomi esplicitamente registrati in configurazione, senza alcun accesso al filesystem.
3. **Dove il lookup avviene, il loader ne delimita l'esito.** I soli template risolti tramite *template loading* sono quelli interni del prodotto, identificati da nomi costanti definiti nel codice (ad esempio `pmode-template.ftl`) e caricati tramite `Configuration.setClassForTemplateLoading(..)`, ossia attraverso un `ClassTemplateLoader`. Come indicato dalla stessa descrizione della vulnerabilità, un loader basato sul class loader può accedere unicamente alle risorse che il class loader è in grado di caricare. La verifica sperimentale ha confermato che il nome candidato prodotto da un locale malformato viene ricercato letteralmente fra le *entry* degli archivi distribuiti e non risolve ad alcuna risorsa esterna al *package* di base; si aggiunge che `java.util.Locale` riporta in minuscolo l'identificativo, alterando ulteriormente il nome ricercato.

Resta il caso di un template che imposti autonomamente un locale arbitrario tramite la direttiva `<#setting locale="..">`, che la verifica sperimentale ha confermato essere in grado di raggiungere il *template loader* con un nome non normalizzato. Tale caso presuppone tuttavia l'alterazione di un template di configurazione e non costituisce un innalzamento dei privilegi: la definizione dei template FreeMarker è riservata agli amministratori del prodotto ed è, per progettazione, una funzionalità dotata di capacità equivalenti all'esecuzione di codice, in quanto rende disponibili al template l'accesso ai metodi statici e l'istanziazione di classi arbitrarie, come documentato nelle console di gestione. L'esito resta inoltre delimitato dai *template loader* descritti al punto 3.

Per questi motivi la vulnerabilità non si manifesta nel prodotto.

La libreria viene comunque aggiornata alla prima versione in rilascio.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.11 CVE-2026-89044

Data: 2026-09-17

Severity: Medium

CVSS Score:

- CVSS v3.1: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)
- CVSS v4.0: 6.9 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N)

**Nota**

La severity e i CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché risiede nel modulo `netty-codec-http` non distribuito da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-89044
- https://github.com/netty/netty/security/advisories/GHSA-hcvj-94mj-jp5c
- https://github.com/netty/netty/releases/tag/netty-4.1.138.Final
- https://github.com/netty/netty/releases/tag/netty-4.2.18.Final

Libreria: io.netty:netty-codec-http (versioni affette: 4.1.133.Final - 4.1.137.Final, 4.2.13.Final - 4.2.17.Final)

**Descrizione**

CWE-444: Inconsistent Interpretation of HTTP Requests ("HTTP Request/Response Smuggling")

Netty versions 4.1.133.Final through 4.1.137.Final and 4.2.13.Final through 4.2.17.Final fail to properly validate the final transfer coding in the Transfer-Encoding header, allowing attackers to smuggle requests by using malformed encoding declarations. Attackers can split Transfer-Encoding headers across multiple lines or use values like "chunked, xchunked" to bypass validation and decode messages as chunked when the final coding is not chunked, enabling request smuggling attacks.

**GovWay**

La vulnerabilità risiede nel modulo `netty-codec-http` di Netty, nello specifico nella validazione dell'header `Transfer-Encoding` effettuata dal decoder dei messaggi HTTP (`HttpObjectDecoder`).

Tale modulo **non fa parte della distribuzione di GovWay**: il prodotto include Netty unicamente come dipendenza del client Redis (Redisson) impiegato dalle funzionalità distribuite basate su Redis (contatori distribuiti del controllo del traffico, cache distribuita, protezione anti-replay), limitatamente ai moduli richiesti da tale client:

- linea 3.3.x (`lib/redis`, Netty 4.1.137.Final): `netty-buffer`, `netty-codec`, `netty-codec-dns`, `netty-common`, `netty-handler`, `netty-resolver`, `netty-resolver-dns`, `netty-transport`, `netty-transport-native-unix-common`;
- linea 3.4.x (`lib/redis`, Netty 4.2.17.Final): i medesimi moduli, con l'aggiunta di `netty-codec-base`.

Fra questi non figura `netty-codec-http`, ottenuto escludendo nel POM tutte le dipendenze transitive di Redisson (`exclusion *:*`) e dichiarando esplicitamente i soli moduli necessari.

Netty opera inoltre nel prodotto unicamente come *client* verso il server Redis: GovWay non espone alcun servizio HTTP basato su Netty, essendo il gateway erogato come applicazione web sull'application server, e non utilizza Netty per le connessioni verso i servizi esterni, realizzate dai connettori HTTP/HTTPS del gateway. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

Le librerie di Netty vengono comunque aggiornate alla prima versione in rilascio.

**Nota**

La vulnerabilità è segnalata dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `netty-transport`, in quanto l'NVD associa le vulnerabilità di Netty alla CPE di prodotto `cpe:2.3:a:netty:netty` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `netty-codec-http`, non distribuito da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.12 CVE-2026-78254

Data: 2026-09-17

Severity: High

CVSS Score: 7.4 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché le classi dei task `ftp` e `scp`, che contengono il codice vulnerabile, risiedono in artefatti opzionali di Apache Ant non distribuiti da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-78254
- https://lists.apache.org/thread/05s46qrlbhd06c6rsgvxh8zo0l4p9scz
- https://www.openwall.com/lists/oss-security/2026/09/06/2

Libreria: org.apache.ant:ant (versioni affette: < 1.10.18)

**Descrizione**

CWE-23: Relative Path Traversal

The ftp and scp tasks of Apache Ant can download files from a remote server. A malicious server can provide relative paths that allow it to write outside of the dedicated target directory for the download, making it possible to overwrite files of the attacker's choice using the permissions of the user running Ant in versions prior to Ant 1.10.18.

In order to exploit this vulnerability, the server would either have to be malicious or be subject to a machine-in-the-middle attack. Additionally in the case of scp or the ftp task using ftps the server must pass the server identity checks performed by the tasks.

For ftp tasks not using ftps a malicious server could act as a machine-in-the-middle to provide malicious files.

Starting with Ant 1.10.18 both tasks will prevent writing outside of the destination directory by default. An option is available to disable this behavior in the unlikely case that the old behavior is required by existing build files.

Mitigations:

Users of scp and ftp (when using ftps) in any version of Ant should not bypass server identity checks. Users of ftp not using ftps should switch to ftps where possible.

All users are recommended to upgrade to Apache Ant 1.10.18, which fixes this issue.

**GovWay**

La libreria non fa parte del runtime del gateway: Apache Ant viene distribuito unicamente nella directory `lib/antinstaller` dell'archivio di installazione, dove costituisce il motore di esecuzione dell'installer del prodotto (AntInstaller), utilizzato per eseguire i task di setup descritti in `ant/setup/build.xml`. Nessun componente eseguito a runtime dal gateway, dalle console o dai servizi di gestione utilizza la libreria.

Il codice vulnerabile risiede inoltre nelle classi che implementano i task `ftp` e `scp`, ossia `org.apache.tools.ant.taskdefs.optional.net.FTP` e `org.apache.tools.ant.taskdefs.optional.ssh.Scp`, distribuite da Apache Ant negli artefatti opzionali `ant-commons-net` e `ant-jsch`. Tali artefatti **non fanno parte della distribuzione di GovWay**, che include i soli `ant`, `ant-launcher` e `ant-apache-regexp`: la verifica del contenuto degli archivi effettivamente distribuiti ha confermato l'assenza delle classi sopra indicate, delle quali il file `defaults.properties` presente in `ant.jar` riporta unicamente la dichiarazione del nome del task.

L'installazione del prodotto non prevede infine alcun trasferimento di file da server remoti: i task di setup operano esclusivamente sul filesystem locale e sulla base dati indicata dall'amministratore, e nessun file di build utilizza i task `ftp`, `scp` o `sshexec`. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

La libreria viene comunque aggiornata alla prima versione in rilascio.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.13 CVE-2026-59270, CVE-2026-47841, CVE-2026-47877

Data: 2026-09-03

Severity: Critical

CVSS Score:

- CVE-2026-59270: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
- CVE-2026-47841: 7.4 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)

- CVE-2026-47877: 6.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché risiedono in moduli di Spring Security (`spring-security-ldap`, `spring-security-webauthn` e `spring-security-oauth2-authorization-server`) non distribuiti da GovWay.

Riferimenti:

- CVE-2026-59270:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-59270
  - https://spring.io/security/cve-2026-59270
- CVE-2026-47841:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-47841
  - https://spring.io/security/cve-2026-47841
- CVE-2026-47877:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-47877
  - https://spring.io/security/cve-2026-47877

Libreria: org.springframework.security Spring Security (versioni affette: 5.7.0 - 5.7.25, 5.8.0 - 5.8.27, 6.4.0 - 6.4.18, 6.5.0 - 6.5.11, 7.0.0 - 7.0.6, 7.1.0)

**Descrizione**

Le tre vulnerabilità riguardano moduli funzionali di Spring Security distinti dal nucleo di autenticazione e autorizzazione: il server LDAP embedded (`spring-security-ldap`), il supporto WebAuthn (`spring-security-webauthn`) e l'Authorization Server OAuth2 (`spring-security-oauth2-authorization-server`).

1. [CVE-2026-59270] CWE-863: Incorrect Authorization

Spring Security's embedded UnboundID LDAP server (UnboundIdContainer) unconditionally registers an administrative credential and binds its listener to all available network interfaces. Affected versions: Spring Security 7.1.0; 7.0.0 through 7.0.6; 6.5.0 through 6.5.11; 6.4.0 through 6.4.18; 5.8.0 through 5.8.27; 5.7.0 through 5.7.25.

2. [CVE-2026-47841] CWE-863: Incorrect Authorization

An application using Spring Security's WebAuthn support may be vulnerable to user verification bypass when using a distributed HTTP session store. Affected versions: Spring Security 7.1.0; 7.0.0 through 7.0.6; 6.5.0 through 6.5.11; 6.4.0 through 6.4.18.

3. [CVE-2026-47877] CWE-79: Improper Neutralization of Input During Web Page Generation ("Cross-site Scripting")

Spring Security Authorization Server's default consent page renders user-controlled values without HTML entity encoding. Affected versions: Spring Security 7.1.0; 7.0.0 through 7.0.6.

**GovWay**

Le tre vulnerabilità risiedono in moduli di Spring Security che **non fanno parte della distribuzione di GovWay**: il prodotto include unicamente i moduli `spring-security-core`, `spring-security-config`, `spring-security-web` e `spring-security-crypto`; le funzionalità LDAP si basano sul progetto Spring LDAP

(`org.springframework.ldap:spring-ldap-core`), distinto da `spring-security-ldap`. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

Le librerie di Spring Security vengono comunque aggiornate alla prima versione in rilascio.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `spring-security-core`, in quanto l'NVD associa le vulnerabilità di Spring Security alla CPE di prodotto `cpe:2.3:a:vmware:spring_security` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nei moduli `spring-security-ldap`, `spring-security-webauthn` e `spring-security-oauth2-authorization-server`, non distribuiti da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20 (limitatamente a CVE-2026-59270)
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.14 CVE-2026-47842

Data: 2026-09-03

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché la classe `AesBytesEncryptor` non è utilizzata da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-47842
- https://spring.io/security/cve-2026-47842

Libreria: org.springframework.security:spring-security-crypto (versioni affette: 5.7.0 - 5.7.25, 5.8.0 - 5.8.27, 6.4.0 - 6.4.18, 6.5.0 - 6.5.11, 7.0.0 - 7.0.6, 7.1.0)

**Descrizione**

CWE-326: Inadequate Encryption Strength

Applications using AesBytesEncryptor with the two-argument constructor or when passing a null IV generator and CBC as the encryption mode encrypt data with AES/CBC using a null (all-zero) initialization vector. Affected versions: Spring Security 7.1.0; 7.0.0 through 7.0.6; 6.5.0 through 6.5.11; 6.4.0 through 6.4.18; 5.8.0 through 5.8.27; 5.7.0 through 5.7.25.

**GovWay**

La classe vulnerabile `org.springframework.security.crypto.encrypt.AesBytesEncryptor` (e la factory `Encryptors` che la utilizza) appartiene al modulo `spring-security-crypto`, incluso nella distribuzione di GovWay,

ma **non è utilizzata dal prodotto**: di tale modulo GovWay impiega unicamente `SCryptPasswordEncoder`, per la codifica delle password degli utenti delle console.

Le funzionalità di cifratura di GovWay - protezione delle informazioni riservate in configurazione, BYOK, sicurezza messaggio - sono realizzate con implementazioni proprie basate direttamente sulle API JCE, indipendenti da Spring Security. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

Le librerie di Spring Security vengono comunque aggiornate alla prima versione in rilascio.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.15 CVE-2026-59276

Data: 2026-09-03

Severity: Medium

CVSS Score: 5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché i componenti interessati non sono utilizzati da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-59276
- https://spring.io/security/cve-2026-59276

Libreria: org.springframework.security Spring Security (versioni affette: 5.7.0 - 5.7.25, 5.8.0 - 5.8.27, 6.4.0 - 6.4.18, 6.5.0 - 6.5.11, 7.0.0 - 7.0.6, 7.1.0)

**Descrizione**

CWE-208: Observable Timing Discrepancy

Several components in Spring Security compare security-sensitive values using standard string equality (String.equals()) rather than a constant-time comparison. Because String.equals() returns as soon as it finds a differing character, the time taken to reject an incorrect value is proportional to the number of leading characters that match the expected value. Affected versions: Spring Security 7.1.0; 7.0.0 through 7.0.6; 6.5.0 through 6.5.11; 6.4.0 through 6.4.18; 5.8.0 through 5.8.27; 5.7.0 through 5.7.25.

**GovWay**

I componenti interessati dalla vulnerabilità sono `DigestAuthenticationFilter` (modulo `spring-security-web`), `KeyBasedPersistenceTokenService` (`spring-security-core`), `BalloonHashingPassword4jPasswordEncoder` e `Pbkdf2Password4jPasswordEncoder` (`spring-security-crypto`) e `InMemoryOAuth2AuthorizationService` (`spring-security-oauth2-authorization-server`, modulo non distribuito).

Nessuno di tali componenti è utilizzato da GovWay: l'autenticazione delle console si basa su `AuthenticationProvider` e `UserDetailsService` propri e la verifica delle password sul solo

`SCryptPasswordEncoder`; il prodotto non utilizza l'autenticazione HTTP Digest di Spring Security, i servizi di token basati su chiave, gli encoder Password4j né l'Authorization Server OAuth2. Le verifiche di credenziali effettuate dal gateway sul traffico applicativo sono realizzate con logica propria, indipendente da Spring Security. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

Le librerie di Spring Security vengono comunque aggiornate alla prima versione in rilascio.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.16 CVE-2026-59277

Data: 2026-09-03

Severity: Medium

CVSS Score: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché la classe `InetAddressMatchers` non è utilizzata da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-59277
- https://spring.io/security/cve-2026-59277

Libreria: org.springframework.security:spring-security-core (versioni affette: 7.1.0)

**Descrizione**

CWE-693: Protection Mechanism Failure

Spring Security's InetAddressMatchers utility provides matchInternal() and matchExternal() builders for constructing an InetAddressMatcher that classifies a given IP address as belonging to an internal (private) or external (public) network. Affected versions: Spring Security 7.1.0.

The internal address classification did not recognize the IPv4 and IPv6 «any local» addresses (0.0.0.0 and ::) as internal. As a result, matchExternal() incorrectly classified these addresses as external, and matchInternal() failed to classify them as internal.

An address of 0.0.0.0 or ::, which is typically routed to the local host, could bypass a network-based access control check intended to restrict or block internal network access.

**GovWay**

La classe vulnerabile `org.springframework.security.util.matcher.InetAddressMatchers`, introdotta in Spring Security 7.1.0, appartiene al modulo `spring-security-core`, incluso nella distribuzione di GovWay, ma **non è utilizzata dal prodotto**.

I controlli di GovWay basati sull'indirizzo IP del chiamante - autenticazione e autorizzazione per indirizzo, filtri sugli indirizzi ammessi, gestione dei *forwarded header* - sono realizzati con logica propria (es. `org.openspcoop2.utils.transport.http.HttpClientAddressSanitizer` per la normalizzazione degli indirizzi ricavati dagli header di *forwarding*), indipendente da Spring Security. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

Le librerie di Spring Security vengono comunque aggiornate alla prima versione in rilascio.

Versione affette:

- 3.3.x: non affetta (utilizza Spring Security 5.8.x)
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.17 CVE-2026-47890, CVE-2026-59313

Data: 2026-09-03

Severity: Critical

CVSS Score:

- CVE-2026-47890: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-59313: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità delle librerie. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché risiedono in moduli di Spring Framework (`spring-webmvc` / `spring-webflux`) non distribuiti da GovWay.

Riferimenti:

- CVE-2026-47890:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-47890
  - https://spring.io/security/cve-2026-47890
- CVE-2026-59313:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-59313
  - https://spring.io/security/cve-2026-59313

Libreria: org.springframework Spring Framework (versioni affette: 5.3.0 - 5.3.49, 6.0.0 - 6.0.30, 6.1.0 - 6.1.28, 6.2.0 - 6.2.19, 7.0.0 - 7.0.8)

**Descrizione**

Entrambe le vulnerabilità riguardano la generazione di flussi *Server-Sent Events* (SSE) da parte dello stack web di Spring.

1. [CVE-2026-47890] CWE-93: Improper Neutralization of CRLF Sequences ("CRLF Injection")

Spring MVC and WebFlux applications are vulnerable to stream corruption when using Server-Sent Events (SSE) with view fragments. Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19.

2. [CVE-2026-59313] CWE-93: Improper Neutralization of CRLF Sequences ("CRLF Injection")

Spring MVC applications using the functional web framework are vulnerable to stream corruption when using Server-Sent Events (SSE). Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19; 6.1.0 through 6.1.28; 6.0.0 through 6.0.30; 5.3.0 through 5.3.49.

**GovWay**

Le due vulnerabilità risiedono nei moduli `spring-webmvc` e `spring-webflux` di Spring Framework, nello specifico nella scrittura degli eventi SSE prodotti dal *rendering* dei *view fragment* (CVE-2026-47890) e dal *functional web framework* di Spring MVC (CVE-2026-59313).

Tali moduli **non fanno parte della distribuzione di GovWay**: il prodotto utilizza Spring esclusivamente come container di *dependency injection* (moduli `spring-core`, `spring-beans`, `spring-context`, `spring-context-support`, `spring-expression`), insieme a `spring-aop`/`spring-aspects`, `spring-tx`/`spring-jdbc`/`spring-orm` e `spring-web`; non integra Spring MVC né Spring WebFlux, non definisce `RouterFunction` e non espone endpoint Server-Sent Events basati su Spring: i propri servizi sono esposti tramite uno stack servlet/JAX-RS proprio. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

Le librerie di Spring Framework vengono comunque aggiornate alla prima versione in rilascio.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `spring-core`, in quanto l'NVD associa le vulnerabilità di Spring Framework alla CPE di prodotto `cpe:2.3:a:vmware:spring_framework` (con gli alias `pivotal_software` e `springsource`), senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nei moduli `spring-webmvc` / `spring-webflux`, non distribuiti da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20 (limitatamente a CVE-2026-59313)
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.18 CVE-2026-47891, CVE-2026-47892, CVE-2026-47893

Data: 2026-09-03

Severity: Critical

CVSS Score:

- CVE-2026-47891: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-47892: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-47893: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità delle librerie. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché risiedono nel modulo Spring WebFlux (`spring-webflux`) non distribuito da GovWay.

Riferimenti:

- CVE-2026-47891:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-47891
  - https://spring.io/security/cve-2026-47891
- CVE-2026-47892:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-47892
  - https://spring.io/security/cve-2026-47892
- CVE-2026-47893:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-47893
  - https://spring.io/security/cve-2026-47893

Libreria: org.springframework Spring Framework (versioni affette: 5.2.25.RELEASE e precedenti, 5.3.0 - 5.3.49, 6.0.0 - 6.0.30, 6.1.0 - 6.1.28, 6.2.0 - 6.2.19, 7.0.0 - 7.0.8)

**Descrizione**

Le tre vulnerabilità riguardano il modulo `spring-webflux` di Spring Framework, ovvero lo stack web reattivo.

1. [CVE-2026-47891] CWE-770: Allocation of Resources Without Limits or Throttling

A Spring WebFlux application that relies on the Aalto XML processor to parse XML input does not correctly enforce the maxInMemorySize limit. Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19; 6.1.0 through 6.1.28; 6.0.0 through 6.0.30; 5.3.0 through 5.3.49; 5.2.25.RELEASE and earlier.

2. [CVE-2026-47892] CWE-863: Incorrect Authorization

A WebFlux application using functional endpoints and deployed with DispatcherServlet may be vulnerable to a header predicate bypass in a pre-flight request. Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19; 6.1.0 through 6.1.28; 6.0.0 through 6.0.30; 5.3.0 through 5.3.49; 5.2.5.RELEASE through 5.2.25.RELEASE.

3. [CVE-2026-47893] CWE-209: Generation of Error Message Containing Sensitive Information

A Spring WebFlux application that supports WebSocket connections may expose indirectly sensitive user information by including request headers in an exception reason. Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19; 6.1.0 through 6.1.28; 6.0.0 through 6.0.30; 5.3.0 through 5.3.49; 5.2.25.RELEASE and earlier.

**GovWay**

Le tre vulnerabilità risiedono nel modulo `spring-webflux` di Spring Framework: nella decodifica XML reattiva basata sul processore Aalto (CVE-2026-47891), nella valutazione dei *predicate* sugli header degli endpoint funzionali durante le richieste di *pre-flight* CORS (CVE-2026-47892) e nella gestione dell"*handshake* WebSocket (CVE-2026-47893).

Tale modulo **non fa parte della distribuzione di GovWay**: il prodotto non integra Spring WebFlux e non utilizza lo stack web reattivo di Spring per la ricezione delle richieste; la gestione delle richieste, la decodifica dei messaggi XML, il supporto CORS e gli eventuali endpoint WebSocket sono realizzati tramite uno stack servlet/JAX-RS proprio, indipendente da Spring. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

Le librerie di Spring Framework vengono comunque aggiornate alla prima versione in rilascio.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `spring-core`, in quanto l'NVD associa le vulnerabilità di Spring Framework alla CPE di prodotto `cpe:2.3:a:vmware:spring_framework` (con gli alias `pivotal_software` e `springsource`), senza

distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `spring-webflux`, non distribuito da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.19 CVE-2026-59283

Data: 2026-09-03

Severity: Critical

CVSS Score: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, le condizioni necessarie allo sfruttamento (valutazione di espressioni SpEL fornite da input non fidato, in un `SimpleEvaluationContext`, con compilatore SpEL attivo) non sono presenti nel prodotto.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-59283
- https://spring.io/security/cve-2026-59283

Libreria: org.springframework:spring-expression (versioni affette: 5.2.25.RELEASE e precedenti, 5.3.0 - 5.3.49, 6.0.0 - 6.0.30, 6.1.0 - 6.1.28, 6.2.0 - 6.2.19, 7.0.0 - 7.0.8)

**Descrizione**

CWE-913: Improper Control of Dynamically-Managed Code Resources

Applications that evaluate Spring Expression Language (SpEL) expressions using SimpleEvaluationContext may be vulnerable to a safety guard bypass when the SpEL expression compiler is active. Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19; 6.1.0 through 6.1.28; 6.0.0 through 6.0.30; 5.3.0 through 5.3.49; 5.2.25.RELEASE and earlier.

**GovWay**

Il modulo `spring-expression` è incluso nella distribuzione di GovWay in quanto dipendenza del container di *dependency injection* di Spring. SpEL viene utilizzato da Spring per la risoluzione delle espressioni `#{...}` presenti nei file di configurazione dei bean: si tratta di espressioni statiche, definite a tempo di sviluppo/configurazione e **non influenzabili da input di runtime**.

GovWay **non valuta espressioni SpEL fornite da utenti o derivanti dal traffico applicativo** (header, payload, parametri di richiesta o valori configurabili a runtime). Le funzionalità di valutazione di espressioni esposte dal prodotto si basano su motori distinti e indipendenti da SpEL (XPath, XQuery, JSONPath ed espressioni regolari).

Lo sfruttamento della vulnerabilità richiede inoltre due ulteriori condizioni, entrambe assenti nel prodotto: l'utilizzo della classe `SimpleEvaluationContext`, non impiegata da GovWay, e l'attivazione esplicita del

compilatore SpEL (property `spring.expression.compiler.mode` impostata a `IMMEDIATE` o `MIXED`, oppure `SpelParserConfiguration` con il corrispondente `SpelCompilerMode`), che GovWay non abilita in alcuna configurazione. La vulnerabilità non si manifesta pertanto nel prodotto.

Le librerie di Spring Framework vengono comunque aggiornate alla prima versione in rilascio.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.20 CVE-2026-59282, CVE-2026-59281

Data: 2026-09-03

Severity: High

CVSS Score:

- CVE-2026-59282: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-59281: 6.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità delle librerie. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché GovWay non utilizza l'infrastruttura di *data binding* di Spring.

Riferimenti:

- CVE-2026-59282:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-59282
  - https://spring.io/security/cve-2026-59282
- CVE-2026-59281:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-59281
  - https://spring.io/security/cve-2026-59281

Libreria: org.springframework Spring Framework (versioni affette: 5.2.25.RELEASE e precedenti, 5.3.0 - 5.3.49, 6.0.0 - 6.0.30, 6.1.0 - 6.1.28, 6.2.0 - 6.2.19, 7.0.0 - 7.0.8)

**Descrizione**

Entrambe le vulnerabilità riguardano l'infrastruttura di *data binding* di Spring: la navigazione dei *property path* annidati (CVE-2026-59282) e il rendering degli errori di binding (CVE-2026-59281).

1. [CVE-2026-59282] CWE-400: Uncontrolled Resource Consumption

Spring Framework applications that use Spring's data binding infrastructure to apply user-supplied property paths onto a target object may be vulnerable to a Denial of Service (DoS) attack. Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19; 6.1.0 through 6.1.28; 6.0.0 through 6.0.30; 5.3.0 through 5.3.49; 5.2.25.RELEASE and earlier.

2. [CVE-2026-59281] CWE-79: Improper Neutralization of Input During Web Page Generation ("Cross-site Scripting")

Spring MVC and WebFlux applications that obtain a data-binding Errors instance with HTML escaping enabled and then render field errors using the no-argument Errors.getFieldErrors() or Errors.getFieldError() accessors are vulnerable to arbitrary HTML/JavaScript code injection, potentially resulting in a reflected cross-site scripting (XSS) vulnerability. Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19; 6.1.0 through 6.1.28; 6.0.0 through 6.0.30; 5.3.0 through 5.3.49; 5.2.25.RELEASE and earlier.

**GovWay**

Le classi coinvolte appartengono a moduli inclusi nella distribuzione di GovWay: `DataBinder` e `Errors` (`spring-context`), `BeanWrapperImpl/AbstractNestablePropertyAccessor` e `DirectFieldAccessor` (`spring-beans`), `EscapedErrors` (`spring-web`).

GovWay **non utilizza il data binding di Spring**: il prodotto non applica *property path* forniti dall'esterno su oggetti di destinazione, non istanzia `DataBinder` né accede alle proprietà tramite `BeanWrapper`, e non utilizza le API di validazione `Errors/BindingResult`. La deserializzazione dei messaggi in transito e dei parametri delle console è realizzata con stack propri (JAX-RS/Jackson), indipendenti dal data binding di Spring, che nel prodotto viene esercitato dal solo container di *dependency injection* su valori di configurazione statici.

La CVE-2026-59281 richiede inoltre il rendering degli errori di binding da parte delle view di Spring MVC/WebFlux, moduli non distribuiti da GovWay. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

Le librerie di Spring Framework vengono comunque aggiornate alla prima versione in rilascio.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.21 CVE-2026-59280

Data: 2026-09-03

Severity: Medium

CVSS Score: 4.3 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché GovWay non utilizza l'integrazione FreeMarker di Spring.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-59280
- https://spring.io/security/cve-2026-59280

Libreria: org.springframework:spring-context-support (versioni affette: 5.2.25.RELEASE e precedenti, 5.3.0 - 5.3.49, 6.0.0 - 6.0.30, 6.1.0 - 6.1.28, 6.2.0 - 6.2.19, 7.0.0 - 7.0.8)

**Descrizione**

CWE-22: Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal")

Applications using Spring Framework's FreeMarker integration may be vulnerable to a path traversal attack when a controller returns a view name derived from untrusted input and FreeMarker is configured to resolve templates through SpringTemplateLoader. Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19; 6.1.0 through 6.1.28; 6.0.0 through 6.0.30; 5.3.0 through 5.3.49; 5.2.25.RELEASE and earlier.

**GovWay**

La classe vulnerabile `org.springframework.ui.freemarker.SpringTemplateLoader` appartiene al modulo `spring-context-support`, incluso nella distribuzione di GovWay.

GovWay utilizza FreeMarker come motore di *template* per le trasformazioni dei messaggi e per la generazione di contenuti dinamici, ma **non utilizza l'integrazione FreeMarker di Spring**: la configurazione del motore è realizzata con codice proprio (`org.openspcoop2.utils.resources.FreemarkerTemplateUtils`) e i template vengono risolti da un `TemplateLoader` proprio (`org.openspcoop2.utils.resources.FreemarkerTemplateLoader`) che accede unicamente ai template registrati nella configurazione del prodotto, senza risoluzione su filesystem. Le classi `SpringTemplateLoader` e `FreeMarkerConfigurationFactory` non sono utilizzate.

Non è inoltre presente la condizione necessaria allo sfruttamento, ovvero la restituzione da parte di un controller di un *view name* derivato da input non fidato: GovWay non integra Spring MVC e non utilizza le view di Spring. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

Le librerie di Spring Framework vengono comunque aggiornate alla prima versione in rilascio.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.22 CVE-2026-59314

Data: 2026-09-03

Severity: Low

CVSS Score: 3.7 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché GovWay non utilizza la classe `ContentDisposition` di Spring.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-59314
- https://spring.io/security/cve-2026-59314

Libreria: org.springframework:spring-web (versioni affette: 5.2.25.RELEASE e precedenti, 5.3.0 - 5.3.49, 6.0.0 - 6.0.30, 6.1.0 - 6.1.28, 6.2.0 - 6.2.19, 7.0.0 - 7.0.8)

**Descrizione**

CWE-113: Improper Neutralization of CRLF Sequences in HTTP Headers ("HTTP Request/Response Splitting")

Applications that build a Content-Disposition header value from untrusted input may be vulnerable to HTTP response splitting when the input is a malicious file name. Affected versions: Spring Framework 7.0.0 through 7.0.8; 6.2.0 through 6.2.19; 6.1.0 through 6.1.28; 6.0.0 through 6.0.30; 5.3.0 through 5.3.49; 5.2.25.RELEASE and earlier.

**GovWay**

La classe vulnerabile `org.springframework.http.ContentDisposition` appartiene al modulo `spring-web`, incluso nella distribuzione di GovWay, ma **non è utilizzata dal prodotto**. Di `spring-web` GovWay impiega unicamente l'utility di decodifica URI `UriUtils`, l'accesso al contesto applicativo dai servlet delle console (`WebApplicationContextUtils`) e le costanti di `HttpStatus`, `HttpHeaders` e `MediaType`.

Gli header `Content-Disposition` gestiti da GovWay - nelle parti dei messaggi MIME/multipart in transito e nei download offerti dalle console - sono costruiti e interpretati con codice proprio e con le API `jakarta.mail`, indipendenti da Spring. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

Le librerie di Spring Framework vengono comunque aggiornate alla prima versione in rilascio.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.23 CVE-2026-62380

Data: 2026-09-03

Severity: High

CVSS Score:

- CVSS v3.1: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)
- CVSS v4.0: 6.3 (CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N)

**Nota**

La severity e i CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché risiede nel modulo `netty-codec-socks` non distribuito da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-62380
- https://github.com/netty/netty/security/advisories/GHSA-cc6x-ffm5-83wf
- https://www.vulncheck.com/advisories/netty-before-final-socks-proxy-null-byte-injection

Libreria: io.netty:netty-codec-socks (versioni affette: <= 4.1.136.Final, 4.2.0.Final - 4.2.16.Final)

**Descrizione**

CWE-626: Null Byte Interaction Error (Poison Null Byte)

Netty (io.netty:netty-codec-socks) versions 4.2.0.Final through 4.2.16.Final and 4.1.x through 4.1.136.Final contain null byte, CRLF, and credential injection vulnerabilities in the SOCKS4 (Socks4ClientEncoder) and SOCKS5 (Socks5ClientEncoder) client encoders, which fail to validate domain address and authentication (username/password)

fields. An attacker able to control these fields can inject null bytes or CRLF characters to truncate or alter values, potentially enabling domain spoofing, SOCKS4 userid truncation, authentication data injection, and protocol confusion. Fixed in 4.2.17.Final and 4.1.137.Final.

**GovWay**

La vulnerabilità risiede nel modulo `netty-codec-socks` di Netty, nello specifico negli encoder client dei protocolli SOCKS4 e SOCKS5 (`Socks4ClientEncoder` e `Socks5ClientEncoder`) utilizzati per instradare le connessioni attraverso un proxy SOCKS.

Tale modulo **non fa parte della distribuzione di GovWay**: il prodotto include Netty unicamente come dipendenza del client Redis (Redisson) impiegato dalla gestione distribuita delle policy di controllo del traffico, limitatamente ai moduli richiesti da tale client (`netty-common`, `netty-buffer`, `netty-transport`, `netty-handler`, `netty-codec`, `netty-resolver` e i relativi moduli per la risoluzione DNS e per il trasporto nativo), fra i quali non figura `netty-codec-socks`. GovWay non utilizza proxy SOCKS e non istanzia alcun encoder SOCKS: le connessioni verso i servizi esterni sono realizzate dai connettori HTTP/HTTPS del gateway, indipendenti da Netty. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

Le librerie di Netty vengono comunque aggiornate alla prima versione in rilascio.

**Nota**

La vulnerabilità è segnalata dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `netty-transport`, in quanto l'NVD associa le vulnerabilità di Netty alla CPE di prodotto `cpe:2.3:a:netty:netty` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `netty-codec-socks`, non distribuito da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.24 CVE-2026-64607

Data: 2026-08-15

Severity: Medium

CVSS Score: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché la decompressione automatica del `Content-Encoding` operata da Apache HttpClient è disabilitata sui connettori del gateway.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-64607
- https://lists.apache.org/thread/qqfzo3fqcdk4l5496vz95ppvl4ty511q

- https://www.openwall.com/lists/oss-security/2026/08/13/5

Libreria: org.apache.httpcomponents.client5:httpclient5 (versioni affette: 5.0-alpha1 - 5.6.2)

**Descrizione**

[CVE-2026-64607] CWE-772: Missing Release of Resource after Effective Lifetime

Apache HttpComponents Client: Connection Leak on Content-Encoding Decode Error Leads to Pool Exhaustion DoS

HttpClient based on the classic i/o model fails to correctly release the underlying connection back to the connection manager if it encounters an invalid or unsupported *Content-Encoding* header value in the response message. Please note this defect does not affect HttpClient based on the async i/o model.

This issue affects Apache HttpComponents Client: from 5.0-alpha1 through 5.6.2.

Users are recommended to upgrade to version 5.6.3, which fixes the issue.

**GovWay**

GovWay utilizza la libreria nei connettori HTTP/HTTPS del gateway, basati sull'i/o classico ed appoggiati ad un pool di connessioni condiviso, ma la vulnerabilità non si manifesta nel prodotto: il client viene costruito invocando `disableContentCompression()` e l'interceptor vulnerabile `ContentCompressionExec` non entra nella catena di esecuzione in alcuna configurazione. Anche abilitando la decompressione automatica tramite le property `contentEncoding.decompress`, questa è infatti realizzata da GovWay con logica propria, esternamente alla libreria.

La libreria viene comunque aggiornata alla prima versione in rilascio.

Versione affette:

- 3.3.x: non affetta (utilizza la libreria `org.apache.httpcomponents:httpclient` 4.x)
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.25 CVE-2026-71497

Data: 2026-08-07

Severity: Medium

CVSS Score: 4.7 (CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:L/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-71497
- https://github.com/advisories/GHSA-pmhh-3w7g-xqp8
- https://github.com/jhy/jsoup/security/advisories/GHSA-pmhh-3w7g-xqp8
- https://github.com/jhy/jsoup/issues/2538
- https://github.com/jhy/jsoup/releases/tag/jsoup-1.23.1

Libreria: org.jsoup:jsoup (versioni affette: 1.14.3 - 1.22.2)

**Descrizione**

CWE-79: Improper Neutralization of Input During Web Page Generation ("Cross-site Scripting")

[GHSA-pmhh-3w7g-xqp8] jsoup: Cleaner may expose markup with custom raw-text elements

When a custom *Safelist* permits certain raw-text elements, jsoup may incorrectly sanitize malformed HTML containing a tag name that ends in a control character. The tag may acquire the parsing behavior of a different element, causing content that should remain text to be emitted as active markup after serialization and potentially allowing XSS.

jsoup's built-in Safelists are unaffected.

Patches: Upgrade to jsoup 1.23.1.

Workarounds: Until upgrading, do not permit raw-text elements in custom Safelists used to clean untrusted HTML.

Additional security considerations: This fix addresses malformed tag-name handling only. Permitting raw-text elements in a custom *Safelist* does not make their contents inherently safe. For example, applications that permit *style* must apply appropriate CSS safeguards separately, because jsoup does not parse or sanitize CSS.

**GovWay**

Versione affette:

- 3.3.x: non affetta
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.26 CVE-2026-66909

Data: 2026-08-07

Severity: Critical

CVSS Score: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché risiede nel modulo `cxf-rt-transports-jms` (trasporto JMS di Apache CXF) non distribuito da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-66909
- https://cxf.apache.org/security-advisories.data/CVE-2026-66909.txt

Libreria: org.apache.cxf:cxf-rt-transports-jms (versioni affette: < 3.6.12, 4.0.0 - 4.1.7 e 4.2.0 - 4.2.2)

**Descrizione**

CWE-502: Deserialization of Untrusted Data

Apache CXF's JMS transport deserializes the body of any inbound JMS ObjectMessage using native Java deserialization, with no type restrictions in place. Any attacker able to place a message on the service's JMS destination can submit a malicious serialized object, leading to denial of service or, if a suitable gadget class is on the classpath, remote code execution. The fix disables ObjectMessage deserialization by default, with a configuration switch to re-enable it if needed. Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fix this issue.

**GovWay**

La vulnerabilità risiede nel trasporto JMS di Apache CXF (modulo `cxf-rt-transports-jms`) ed è sfruttabile solamente da un attaccante in grado di depositare un messaggio JMS sulla destinazione utilizzata da un endpoint CXF configurato su tale trasporto.

Il modulo `cxf-rt-transports-jms` **non fa parte della distribuzione di GovWay**: il prodotto utilizza esclusivamente il core CXF ed i runtime JAX-WS/JAX-RS su trasporto HTTP, e non espone alcun endpoint CXF su trasporto JMS. Le code JMS eventualmente utilizzate da GovWay (consegna asincrona verso il repository dei messaggi) sono gestite con logica propria, tramite le API JMS dell'application server, e non veicolano oggetti serializzati Java deserializzati da Apache CXF. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

**Nota**

La vulnerabilità è segnalata dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico degli artefatti `cxf-core` e `cxf-rt-transports-http-jetty`, in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `cxf-rt-transports-jms`, non distribuito da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.27 CVE-2026-68079, CVE-2026-61466, CVE-2026-63687, CVE-2026-65583, CVE-2026-57817, CVE-2026-57818, CVE-2026-68481

Data: 2026-08-07

Severity: Critical

CVSS Score:

- CVE-2026-68079: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-61466: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H)
- CVE-2026-63687: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
- CVE-2026-65583: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
- CVE-2026-57817: 8.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-57818: 8.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-68481: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché risiedono nei moduli `cxf-rt-rs-security-oauth2` (server OAuth2 di Apache CXF) e `cxf-rt-rs-security-sso-oidc` (relying party OpenID Connect di Apache CXF), non distribuiti da GovWay.

Riferimenti:

- CVE-2026-68079:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-68079
  - https://cxf.apache.org/security-advisories.data/CVE-2026-68079.txt
- CVE-2026-61466:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-61466
  - https://cxf.apache.org/security-advisories.data/CVE-2026-61466.txt
- CVE-2026-63687:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-63687
  - https://cxf.apache.org/security-advisories.data/CVE-2026-63687.txt
- CVE-2026-65583:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-65583
  - https://cxf.apache.org/security-advisories.data/CVE-2026-65583.txt
- CVE-2026-57817:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-57817
  - https://cxf.apache.org/security-advisories.data/CVE-2026-57817.txt
- CVE-2026-57818:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-57818
  - https://cxf.apache.org/security-advisories.data/CVE-2026-57818.txt
- CVE-2026-68481:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-68481
  - https://cxf.apache.org/security-advisories.data/CVE-2026-68481.txt

Libreria: org.apache.cxf:cxf-rt-rs-security-oauth2, org.apache.cxf:cxf-rt-rs-security-sso-oidc (versioni affette: < 3.6.12, 4.0.0 - 4.1.7 e 4.2.0 - 4.2.2)

**Descrizione**

Le sette vulnerabilità riguardano i moduli `cxf-rt-rs-security-oauth2` e `cxf-rt-rs-security-sso-oidc` di Apache CXF, ovvero l'implementazione del server OAuth2 (Authorization Server, endpoint di introspection, gestione dei code e dei token) e quella del relying party OpenID Connect.

1. [CVE-2026-68079] CWE-294: Authentication Bypass by Capture-replay

In Apache CXF's DefaultEncryptingCodeDataProvider, a captured authorization code can be redeemed an unlimited number of times due to a flaw in the implementation of the removeCodeGrant functionality. This violates the RFC requirement that «The authorization code MUST NOT be used more than once.» Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fix this issue.

2. [CVE-2026-61466] CWE-304: Missing Critical Step in Authentication

In Apache CXF's OAuth2 Dynamic Client Registration endpoint, the authorization server accepts and stores the *scope* value supplied in the client registration request verbatim, without validating it against an AS-defined allowlist. This could lead to a client self-assigning privileged scopes at registration time. Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fix this issue.

3. [CVE-2026-63687] CWE-345: Insufficient Verification of Data Authenticity

Apache CXF's JwtRequestCodeFilter copies all claims from a signed request JWT into the authorization parameter map without excluding security-sensitive parameters. A client that can produce a validly-signed request JWT (e.g., one whose client_secret is known or compromised) can thereby substitute the code_challenge, code_challenge_method, nonce, and state values that were set in the outer HTTP request, undermining PKCE integrity and OpenID Connect replay protection. Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fix this issue.

4. [CVE-2026-65583] CWE-345: Insufficient Verification of Data Authenticity

Apache CXF's OIDC relying-party token validation could accept self-issued ID tokens without enforcing required claim checks (issuer/subject/audience/time and sub_jwk binding), enabling authentication bypass with crafted tokens. However, note that self-issued ID tokens are not accepted by default in the validator. Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fixes this issue.

5. [CVE-2026-57817] CWE-20: Improper Input Validation

The OpenID Connect Core 1.0 specification mandates that the RP MUST validate the *c_hash* parameter when operating in the Hybrid Flow. If an Apache CXF RP is integrated with a non-compliant or misconfigured Identity Provider (IdP) that omits the *c_hash*, the RP becomes vulnerable to Authorization Code Substitution/Injection attacks. Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fix this issue.

6. [CVE-2026-57818] CWE-367: Time-of-check Time-of-use (TOCTOU) Race Condition

A race condition in JCacheCodeDataProvider allows an attacker to redeem a single authorization code multiple times via concurrent requests, resulting in the issuance of multiple distinct, valid access tokens. Users are recommended to upgrade to versions 4.2.3, 4.1.8 or 3.6.12, which fix this issue.

7. [CVE-2026-68481] CWE-672: Operation on a Resource after Expiration or Release

In Apache CXF's DefaultEncryptingOAuthDataProvider, revoked access tokens still decrypt successfully, and TokenIntrospectionService reports active:true. The same applies to refresh tokens. This violates the RFC stipulations that "The authorization server MUST invalidate the token." and "introspection of a revoked token MUST return {«active»:false}". Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fix this issue.

**GovWay**

Le sette vulnerabilità risiedono nei moduli con cui Apache CXF implementa il ruolo di Authorization Server OAuth2 (rilascio ed introspection dei token, gestione dei `DataProvider` per code e refresh token, registrazione dinamica dei client) e quello di relying party OpenID Connect (validazione degli ID token restituiti da un Identity Provider esterno).

Tali moduli **non fanno parte della distribuzione di GovWay**: il prodotto non espone alcun Authorization Server OAuth2 basato su Apache CXF, né utilizza il relying party OIDC di CXF. La gestione dei token in GovWay (validazione JWT, introspection e userinfo verso Identity Provider esterni, negoziazione dei token, PDND) è realizzata con logica propria, indipendente dai moduli OAuth2/OIDC di CXF; di Apache CXF viene utilizzato unicamente il modulo `cxf-rt-rs-security-jose` per le operazioni crittografiche su JOSE (JWS/JWE), non interessato da queste vulnerabilità. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico degli artefatti `cxf-core` e `cxf-rt-transports-http-jetty`, in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nei moduli `cxf-rt-rs-security-oauth2` e `cxf-rt-rs-security-sso-oidc`, non distribuiti da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.28 CVE-2026-54225, CVE-2026-64958

Data: 2026-08-07

Severity: High

CVSS Score:

- CVE-2026-54225: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-64958: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la deserializzazione degli allegati in ingresso non transita per il codice vulnerabile di Apache CXF, pertanto le vulnerabilità non si manifestano nel prodotto.

Riferimenti:

- CVE-2026-54225:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54225
  - https://cxf.apache.org/security-advisories.data/CVE-2026-54225.txt
- CVE-2026-64958:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-64958
  - https://cxf.apache.org/security-advisories.data/CVE-2026-64958.txt

Libreria: org.apache.cxf:cxf-core (versioni affette: < 3.6.12, 4.0.0 - 4.1.7 e 4.2.0 - 4.2.2)

**Descrizione**

1. [CVE-2026-54225] CWE-770: Allocation of Resources Without Limits or Throttling

Apache CXF allows to control the maximum attachment size via the «attachment-max-size». Prior to Apache CXF 4.2.3 and 4.1.8 and 3.6.12, there was no default placed on this size, meaning that a denial of service attack is possible if the user doesn't explicitly set the limit. Users should update to Apache CXF 4.2.3 or 4.1.8 or 3.6.12 which fixes this problem by imposing a default attachment size limit of 50mb.

2. [CVE-2026-64958] CWE-400: Uncontrolled Resource Consumption

An incomplete fix for CVE-2026-50645 means that it is still possible to perform a denial of service attack on Apache CXF by sending a message with many attachment headers. Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fix this issue.

**GovWay**

Entrambe le vulnerabilità risiedono nel deserializzatore degli allegati di Apache CXF (`org.apache.cxf.attachment.AttachmentDeserializer`), nel modulo `cxf-core`, e sono raggiungibili solo se i messaggi *multipart*/MTOM in ingresso vengono parsati tramite tale componente. La seconda, in particolare, è un fix incompleto della precedente CVE-2026-50645 (cfr. *CVE-2026-50645*).

Sebbene `cxf-core` faccia parte della distribuzione di GovWay, il prodotto **non utilizza** il deserializzatore di allegati di CXF per il parsing dei messaggi in ingresso:

- i messaggi SOAP con allegati (MTOM/SwA) sono parsati dall'implementazione SAAJ (`com.sun.xml.messaging.saaj`), con il relativo parser MIME interno;
- i messaggi REST *multipart* sono parsati tramite Jakarta Mail (`jakarta.mail.internet.MimeMultipart`).

Le classi `org.apache.cxf.attachment.*` sono impiegate da GovWay unicamente per operazioni non legate al parsing in ingresso (es. generazione del Content-ID per gli allegati in uscita e adattamento di `DataHandler` già parsati verso le strutture richieste da WSS4J). Il deserializzatore vulnerabile `AttachmentDeserializer` non viene quindi mai invocato sul flusso di ricezione dei messaggi. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

Si evidenzia inoltre che GovWay dispone di un controllo proprio, configurabile, sulla dimensione dei messaggi in ingresso (soglie di *Controllo del Traffico*, applicate sullo stream di ricezione), indipendente dall'opzione `attachment-max-size` di Apache CXF.

**Nota**

Le vulnerabilità sono correttamente attribuite all'artefatto `cxf-core` (oltre che a `cxf-rt-transports-http-jetty`), in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf`. Pur essendo `cxf-core` effettivamente distribuito da GovWay, lo specifico percorso di codice vulnerabile (`AttachmentDeserializer`) non è esercitato dal prodotto.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.29 CVE-2026-65432

Data: 2026-08-07

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, il prodotto non utilizza il percorso di lettura dei WSDL di Apache CXF, pertanto la vulnerabilità non si manifesta.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-65432
- https://cxf.apache.org/security-advisories.data/CVE-2026-65432.txt

Libreria: org.apache.cxf:cxf-rt-wsdl (versioni affette: < 3.6.12, 4.0.0 - 4.1.7 e 4.2.0 - 4.2.2)

**Descrizione**

CWE-611: Improper Restriction of XML External Entity Reference

Apache CXF reads a top-level WSDL through its hardened StaxUtils path, which disables XML DTDs and external entities. However, any <wsdl:import> or <xsd:import> referenced from that top-level WSDL is handed off to WSDL4J,

which does not disable DOCTYPE declarations or external entities. As a result, the protections applied to the top-level document do not extend to imported documents, leaving imported WSDL/XSD content vulnerable to XML External Entity (XXE) attacks. Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fix this issue.

**GovWay**

La vulnerabilità risiede nel modulo `cxf-rt-wsdl` di Apache CXF ed è raggiungibile solamente quando è CXF a leggere un documento WSDL (`WSDLManager/ServiceWSDLBuilder`), delegando poi a WSDL4J la risoluzione dei documenti referenziati tramite `wsdl:import` ed `xsd:import`.

GovWay **non utilizza tale percorso di codice**:

- gli endpoint SOAP esposti dal prodotto (IntegrationManager) sono pubblicati con Apache CXF in modalità *code-first*, a partire dalle annotazioni JAX-WS, senza indicazione di alcun `wsdlLocation`: CXF non legge quindi alcun documento WSDL esterno;
- i WSDL degli accordi di servizio registrati nel registro di GovWay (interfacce delle API, utilizzate per la validazione dei contenuti e per la pubblicazione delle interfacce) sono elaborati da un layer proprio del prodotto (`org.openspcoop2.utils.wsdl`), basato direttamente su WSDL4J e su un parser XML configurato con la disabilitazione delle dichiarazioni DOCTYPE (`http://apache.org/xml/features/disallow-doctype-decl`), oggetto di specifici test di non regressione sulle vulnerabilità XXE.

Per questi motivi la vulnerabilità non si manifesta nel prodotto. Si evidenzia inoltre che i documenti WSDL degli accordi di servizio sono caricati esclusivamente da utenti amministratori tramite la console di gestione o le API di configurazione, e non da soggetti non autenticati.

**Nota**

La vulnerabilità è segnalata dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico degli artefatti `cxf-core` e `cxf-rt-transports-http-jetty`, in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `cxf-rt-wsdl`.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.30 CVE-2026-57819

Data: 2026-08-07

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, nessuna risorsa JAX-RS esposta dal prodotto elabora contenuti `application/x-www-form-urlencoded` tramite Apache CXF, pertanto la vulnerabilità non si manifesta.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-57819
- https://cxf.apache.org/security-advisories.data/CVE-2026-57819.txt

Libreria: org.apache.cxf:cxf-rt-frontend-jaxrs (versioni affette: < 3.6.12, 4.0.0 - 4.1.7 e 4.2.0 - 4.2.2)

**Descrizione**

CWE-400: Uncontrolled Resource Consumption

Apache CXF allows to set a limit on the number of form parameters in a JAX-RS message via the «maxFormParameterCount» configuration option. However, no default limit is set which may lead to denial of service attacks when processing requests with very large numbers of form parameters. Users are recommended to upgrade to versions 4.2.3 or 4.1.8 or 3.6.12, which fix this issue by using a default limit of 500 parameters.

**GovWay**

La vulnerabilità risiede nel frontend JAX-RS di Apache CXF (modulo `cxf-rt-frontend-jaxrs`) ed è raggiungibile solamente quando una risorsa JAX-RS elabora il corpo di una richiesta `application/x-www-form-urlencoded`, ovvero quando il metodo dichiara parametri di tipo `@FormParam`, `Form` o `MultivaluedMap`, facendo così intervenire il componente di parsing dei parametri form di CXF.

Apache CXF viene utilizzato da GovWay come frontend JAX-RS unicamente per le API di configurazione e monitoraggio (`govway_api_config` e `govway_api_monitor`): tali API, definite dai relativi contratti OpenAPI, **non espongono alcuna risorsa che accetti contenuti** `application/x-www-form-urlencoded`, operando esclusivamente su rappresentazioni JSON. Nessun metodo delle interfacce JAX-RS del prodotto dichiara parametri di tipo `@FormParam`, `Form` o `MultivaluedMap`; il percorso di codice vulnerabile non viene quindi mai attivato.

I messaggi applicativi trattati dal Gateway non sono invece elaborati da Apache CXF: le richieste in ingresso verso erogazioni e fruizioni sono gestite dalle servlet proprie del prodotto e, nel caso di contenuti `application/x-www-form-urlencoded`, un apposito filtro (`FormUrlEncodedFilter`) impedisce che il corpo della richiesta venga interpretato come form dall'application server, preservandone lo stream per l'elaborazione del Gateway.

Per questi motivi la vulnerabilità non si manifesta nel prodotto.

**Nota**

La vulnerabilità è segnalata dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico degli artefatti `cxf-core` e `cxf-rt-transports-http-jetty`, in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `cxf-rt-frontend-jaxrs`.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.31 CVE-2026-66142, CVE-2026-66143, CVE-2026-66144

Data: 2026-08-01

Severity: High

CVSS Score:

- CVE-2026-66142: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-66143: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-66144: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- CVE-2026-66142:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-66142
  - https://lists.apache.org/thread/fomwtwt4pzzhxn4fyn3skykto913vfzt
- CVE-2026-66143:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-66143
  - https://lists.apache.org/thread/s6o6p5pvcbcsk54dlg6j699t5gxol28w
- CVE-2026-66144:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-66144
  - https://lists.apache.org/thread/80xwwbhkqvbwkkmco6yl6fr5xkpdysjf

Libreria: org.apache.neethi:neethi (versioni affette: < 3.2.3)

**Descrizione**

1. [CVE-2026-66142] CWE-400: Uncontrolled Resource Consumption

Apache Neethi is vulnerable to uncontrolled recursion when parsing policies that lack policy Ids or with deeply nested structures, which may lead to a denial of service attack when parsing policies due to runtime memory exhaustion. Users are recommended to upgrade to version 3.2.3, which fixes this issue.

2. [CVE-2026-66143] CWE-400: Uncontrolled Resource Consumption

It is possible to bypass the maximum number of normalized policy alternatives that was introduced in Apache Neethi 3.2.2 via certain crafted policies, which may lead to a denial of service attack via resource consumption. Users are recommended to upgrade to version 3.2.3, which fixes this issue.

3. [CVE-2026-66144] CWE-400: Uncontrolled Resource Consumption

Although remote policy references are not retrieved during policy normalization, if they are manually retrieved via the API it can cause a denial of service attack if a huge policy is retrieved. Users are recommended to upgrade to version 3.2.3, which fixes this issue by imposing a default maximum size on data read from remote policy references.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.32 CVE-2026-41720

Data: 2026-07-31

Severity: High

CVSS Score: 7.4 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-41720
- https://spring.io/security/cve-2026-41720
- https://github.com/advisories/GHSA-jrv5-8w28-4265
- https://github.com/spring-projects/spring-ldap/issues/407

Libreria: org.springframework.ldap:spring-ldap-core

- GovWay 3.3.x: <= 2.4.4
- GovWay 3.4.x: <= 4.0.3

**Descrizione**

CWE-287: Improper Authentication

Spring LDAP's DirContextAuthenticationStrategy implementations do not reject a bind request where a non-empty username is paired with an empty or null password.

Affected versions: Spring LDAP 2.4.0 through 2.4.4; 3.2.0 through 3.2.17; 3.3.0 through 3.3.7; 4.0.0 through 4.0.3.

A simple bind with a non-empty principal and an empty password is the LDAP unauthenticated bind shape (RFC 4513, section 5.1.2), which many directories accept as an anonymous bind and report as success. This can cause callers to believe authentication succeeded when no password was actually verified.

**GovWay**

La vulnerabilità si manifesta nelle applicazioni che utilizzano Spring LDAP per **verificare le credenziali di un'utenza**, effettuando una bind sul server LDAP con le credenziali fornite dall'utente ed interpretandone l'esito come autenticazione riuscita: in tale scenario una password vuota comporta una bind non autenticata che il server, se permissivo, accetta come anonima riportando successo.

GovWay non implementa alcuna funzionalità di questo tipo. La libreria Spring LDAP viene utilizzata unicamente come **client LDAP in uscita**, per il recupero di risorse esterne il cui riferimento sia indicato con una url di tipo `ldap:` (es. CRL, informazioni OCSP, keystore remoti): la connessione viene stabilita con le eventuali credenziali di servizio indicate dall'amministratore nella configurazione della risorsa, ed il risultato dell'operazione è il contenuto dell'attributo LDAP richiesto, mai un giudizio di autenticazione su un'utenza.

L'autenticazione degli applicativi fruitori e degli utenti delle console di gestione non coinvolge in alcun modo Spring LDAP; la libreria è infatti distribuita solamente nell'archivio `govway.ear` e non è presente in nessuno degli archivi web del prodotto (govwayConsole, govwayMonitor e le relative API di configurazione e monitoraggio).

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.33 CVE-2026-44891, CVE-2026-55831, CVE-2026-55833

Data: 2026-07-27

Severity: High

CVSS Score:

- CVE-2026-44891: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-55831: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-55833: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria Netty. Come descritto nella sezione **GovWay**, i moduli Netty che contengono il codice vulnerabile (`netty-codec-stomp` e `netty-codec-http`) non sono distribuiti dal prodotto: le vulnerabilità non si manifestano in GovWay.

Riferimenti:

- CVE-2026-44891 (GHSA-vhch-2wf3-m8rp):
  - https://nvd.nist.gov/vuln/detail/CVE-2026-44891
  - https://github.com/netty/netty/security/advisories/GHSA-vhch-2wf3-m8rp
  - https://github.com/netty/netty/pull/17063
- CVE-2026-55831 (GHSA-6jqx-86gh-f27w):
  - https://nvd.nist.gov/vuln/detail/CVE-2026-55831
  - https://github.com/netty/netty/security/advisories/GHSA-6jqx-86gh-f27w
- CVE-2026-55833 (GHSA-mvh2-crg5-v77c):
  - https://nvd.nist.gov/vuln/detail/CVE-2026-55833
  - https://github.com/netty/netty/security/advisories/GHSA-mvh2-crg5-v77c

Libreria:

- CVE-2026-44891: io.netty:netty-codec-stomp (<= 4.1.135.Final, >= 4.2.0.Final e <= 4.2.15.Final)
- CVE-2026-55831, CVE-2026-55833: io.netty:netty-codec-http (>= 4.1.0.Final e <= 4.1.135.Final, >= 4.2.0.Final e <= 4.2.15.Final)

**Descrizione**

1. [CVE-2026-44891] CWE-400: Uncontrolled Resource Consumption / CWE-770: Allocation of Resources Without Limits or Throttling

Netty is a network application framework for development of protocol servers and clients. Prior to 4.1.136.Final and 4.2.16.Final, io.netty.handler.codec.stomp.StompSubframeDecoder fails to limit the total number of headers or their cumulative size per frame, and the maxLineLength parameter only restricts individual header lines. An attacker can send a large number of short headers that are accumulated in memory inside DefaultStompHeadersSubframe until the JVM throws an OutOfMemoryError, causing denial of service for servers exposing a STOMP endpoint based on StompSubframeDecoder. This issue is fixed in versions 4.1.136.Final and 4.2.16.Final.

2. [CVE-2026-55831] CWE-400: Uncontrolled Resource Consumption / CWE-770: Allocation of Resources Without Limits or Throttling

Netty is a network application framework for development of protocol servers and clients. Prior to 4.1.136.Final and 4.2.16.Final, Netty's SPDY SETTINGS decoder accepts a peer-declared SETTINGS entry count up to the 24-bit frame-length limit and materializes every unique setting ID in DefaultSpdySettingsFrame, allowing a remote SPDY/3.1 peer to send a syntactically valid roughly 2 MiB SETTINGS frame that creates 262144 map entries and amplifies network input into heap growth and ordered-map insertion work. This issue is fixed in versions 4.1.136.Final and 4.2.16.Final.

3. [CVE-2026-55833] CWE-400: Uncontrolled Resource Consumption

Netty is a network application framework for development of protocol servers and clients. Prior to 4.1.136.Final and 4.2.16.Final, Netty SPDY header decoding continues inflating zlib-compressed header blocks after the raw header parser has exceeded maxHeaderSize and marked the frame truncated in SpdyFrameCodec, allowing a remote peer to send a small compressed HEADERS block that expands into much larger raw header data and causes compression-amplified CPU and allocation churn. This issue is fixed in versions 4.1.136.Final and 4.2.16.Final.

**GovWay**

Le tre vulnerabilità sono state segnalate dagli strumenti di analisi delle dipendenze sui jar Netty distribuiti da GovWay per effetto di un match sul CPE generico `cpe:2.3:a:netty:netty`, che identifica la libreria nel suo complesso senza distinguere i singoli moduli che la compongono.

Le librerie Netty non sono utilizzate direttamente da GovWay: vengono incluse esclusivamente come dipendenza di Redisson, il client utilizzato per connettersi a un server Redis quando l'amministratore abilita le funzionalità distribuite basate su Redis (contatori distribuiti del controllo del traffico / rate limiting in cluster, cache distribuita, protezione anti-replay JTI). Tutte le dipendenze transitive di Redisson sono escluse nel POM (`exclusion *:*`) e vengono distribuiti unicamente i moduli Netty strettamente necessari al client Redis:

- linea 3.3.x (`lib/redis`, Netty 4.1.133.Final): `netty-buffer`, `netty-codec`, `netty-codec-dns`, `netty-common`, `netty-handler`, `netty-resolver`, `netty-resolver-dns`, `netty-transport`, `netty-transport-native-unix-common`;
- linea 3.4.x (`lib/redis`, Netty 4.2.15.Final): i medesimi moduli, con l'aggiunta di `netty-codec-base`.

Il codice vulnerabile risiede invece in due moduli che GovWay non distribuisce:

- `io.netty:netty-codec-stomp`, che contiene `StompSubframeDecoder` (CVE-2026-44891);
- `io.netty:netty-codec-http`, che contiene il codec SPDY `SpdyFrameCodec` e la relativa decodifica degli header (CVE-2026-55831 e CVE-2026-55833).

La verifica del contenuto degli archivi effettivamente distribuiti in entrambe le linee ha confermato l'assenza delle classi dei package `io.netty.handler.codec.stomp` e `io.netty.handler.codec.spdy`.

Inoltre, tutte e tre le vulnerabilità richiedono l'esposizione di un endpoint *server* che parli STOMP o SPDY/3.1: nel prodotto Netty opera unicamente come *client* verso il server Redis e GovWay non espone alcun servizio basato su Netty, tantomeno sui protocolli STOMP o SPDY.

Le vulnerabilità non sono pertanto esercitabili in GovWay. Ciononostante, come misura precauzionale e per allineare la libreria alle release prive di vulnerabilità note, Netty viene aggiornato alle versioni 4.1.136.Final (linea 3.3.x) e 4.2.16.Final (linea 3.4.x).

Versione affette:

- 3.3.x: <= 3.3.20 (vulnerabilità non esercitabile)
- 3.4.x: <= 3.4.3 (vulnerabilità non esercitabile)

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.34 CVE-2026-49844

Data: 2026-07-15

Severity: Medium

CVSS Score: 6.3 (CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-49844
- https://ossindex.sonatype.org/vulnerability/CVE-2026-49844
- https://logging.apache.org/security.html#CVE-2026-49844
- https://github.com/apache/logging-log4j2/pull/4163

Libreria: org.apache.logging.log4j:log4j-api <= 2.25.4

**Descrizione**

[CVE-2026-49844] CWE-116: Improper Encoding or Escaping of Output

Improper encoding of non-finite floating-point values during MapMessage JSON serialization in Apache Log4j API produces output that is not valid JSON. This issue affects Apache Log4j API versions 2.13.1 through 2.25.4 and version 2.26.0.

The fix for CVE-2026-34481 did not cover all code paths: when a MapMessage contains a non-finite IEEE 754 value (NaN, Infinity, or -Infinity), MapMessage.asJson() emits the corresponding bare token. RFC 8259 does not permit these tokens, so a conformant parser rejects the resulting document.

The defect is reachable only when both of the following conditions hold: the application uses the message resolver of JsonTemplateLayout or any other layout that relies on MapMessage.asJson() or MapMessage.getFormattedMessage(new String[]{«JSON»}); and the application logs a MapMessage that contains an attacker-controlled floating-point value.

An attacker who can supply a non-finite value can cause the affected layout to emit malformed JSON, which may corrupt the enclosing log record or disrupt downstream log ingestion and parsing. Users are advised to upgrade to Apache Log4j API 2.25.5 or 2.26.1, both of which emit RFC 8259-compliant JSON for non-finite values.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.35 CVE-2026-54399, CVE-2026-54428

Data: 2026-07-07

Severity: High

CVSS Score:

- CVE-2026-54399: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-54428: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- CVE-2026-54399:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54399
  - https://lists.apache.org/thread/zmxh1pl2zohov5ntdh4lt85gfrlchgpy
- CVE-2026-54428:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54428
  - https://lists.apache.org/thread/5zjp8vczvxq19pw2rvhs21q446bhl0sd

Libreria: org.apache.httpcomponents.core5:httpcore5, org.apache.httpcomponents.core5:httpcore5-h2

- GovWay 3.4.x: <= 5.4.2

**Descrizione**

1. [CVE-2026-54399] CWE-400: Uncontrolled Resource Consumption

Uncontrolled Resource Consumption vulnerability in the HTTP/1.1 message parser in Apache HttpComponents Core (5.4.2 and earlier, 5.5-beta1 and earlier) allows an remote attacker to cause a denial of service through memory exhaustion by sending messages with excessive number of headers / excessive header length

2. [CVE-2026-54428] CWE-770: Allocation of Resources Without Limits or Throttling

Allocation of resources without limits or throttling in the HTTP/2 HPACK decoder in Apache HttpComponents Core (5.4.2 and earlier, 5.5-beta1 and earlier) allows an remote attacker to cause a denial of service through memory exhaustion by sending oversized compressed header blocks before the HTTP/2 SETTINGS acknowledgement causes the configured header list size limit to be applied.

**GovWay**

La linea 3.3.x non è interessata: distribuisce lo stack HTTP Apache HttpComponents 4.x (`lib/httpcore`: `httpcore-4.4.15`), ramo di codice distinto e non incluso nell'intervallo di versioni affette, che Apache circoscrive alla sola serie 5.x (dalla 5.0-alpha alla 5.4.2 e dalla 5.5-alpha alla 5.5-beta1).

Versione affette:

- 3.3.x: non affetta
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.36 CVE-2026-54515

Data: 2026-07-01

Severity: Medium

CVSS Score:

- CVE-2026-54515: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-54515
- https://github.com/advisories/GHSA-5jmj-h7xm-6q6v

Libreria: com.fasterxml.jackson.core:jackson-databind

- GovWay 3.4.x: <= 2.22.0
- GovWay 3.3.x: <= 2.18.8

**Descrizione**

Vulnerability in the jackson-databind library, detected by the CI environment via OSV-Scanner. The following is the official NVD description.

[CVE-2026-54515] (GHSA-5jmj-h7xm-6q6v) - CVSS 5.3 (Medium)

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.8.0 until 2.18.9, 2.21.5, and 3.1.4, in BeanDeserializerBase.createContextual(), per-property @JsonIgnoreProperties exclusions are applied by _handleByNameInclusion(), producing a contextual deserializer whose BeanPropertyMap has the ignored properties removed. The subsequent per-property case-insensitivity block (triggered by @JsonFormat(ACCEPT_CASE_INSENSITIVE_PROPERTIES)) rebuilds from this._beanProperties (the original, unfiltered map) instead of contextual._beanProperties, then overwrites the filtered map — restoring every property _handleByNameInclusion had just removed. The ignored property becomes writable again. This vulnerability is fixed in 2.18.9, 2.21.5, 2.22.1 and 3.1.4.

**GovWay**

Questa vulnerabilità era già stata segnalata, insieme alle altre della medesima famiglia, nell'avviso *CVE-2026-54512, CVE-2026-54513, CVE-2026-54514, CVE-2026-54515, CVE-2026-54516, CVE-2026-54517, CVE-2026-54518*, dove era stata affrontata aggiornando la libreria `com.fasterxml.jackson.core:jackson-databind` alla versione 2.22.0 (branch 3.4.x) e 2.18.8 (branch 3.3.x).

Tali versioni risolvono le altre vulnerabilità della famiglia ma non la presente CVE-2026-54515, la cui correzione è disponibile esclusivamente a partire dalle versioni 2.18.9, 2.21.5, 2.22.1 e 3.1.4 della libreria.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.37 CVE-2026-54512, CVE-2026-54513, CVE-2026-54514, CVE-2026-54515, CVE-2026-54516, CVE-2026-54517, CVE-2026-54518

Data: 2026-06-27

Severity: High

Riferimenti:

- CVE-2026-54512:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54512
  - https://github.com/advisories/GHSA-j3rv-43j4-c7qm
- CVE-2026-54513:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54513
  - https://github.com/advisories/GHSA-rmj7-2vxq-3g9f
- CVE-2026-54514:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54514

  - https://github.com/advisories/GHSA-hgj6-7826-r7m5
- CVE-2026-54515:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54515
  - https://github.com/advisories/GHSA-5jmj-h7xm-6q6v
- CVE-2026-54516:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54516
  - https://github.com/advisories/GHSA-9fxm-vc8v-hj55
- CVE-2026-54517:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54517
  - https://github.com/advisories/GHSA-5hh8-q8hv-fr38
- CVE-2026-54518:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-54518
  - https://github.com/advisories/GHSA-rcqc-6cw3-h962

Libreria: com.fasterxml.jackson.core:jackson-databind

- GovWay 3.4.x: <= 2.21.2
- GovWay 3.3.x: <= 2.18.6

**Descrizione**

Seven vulnerabilities in the jackson-databind library, detected by the CI environment via OSV-Scanner. The following are the official NVD descriptions.

[CVE-2026-54512] (GHSA-j3rv-43j4-c7qm) - CVSS 8.1 (High)

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.10.0 until 2.18.8, 2.21.4, and 3.1.4, jackson-databind's PolymorphicTypeValidator (PTV) is the primary safety mechanism guarding polymorphic deserialization. When polymorphic typing is enabled and a type identifier contains generic parameters (i.e. the type ID string contains <), DatabindContext._resolveAndValidateGeneric() validates only the raw container class name (the substring before <) against the configured PTV. If the container type is approved, the method parses the full canonical type string via TypeFactory.constructFromCanonical() and returns the fully parameterized type without ever validating the nested type arguments against the PTV. The nested type arguments are then resolved, instantiated, and populated as beans during deserialization. An attacker who controls the type ID can therefore place a denied class as a generic type parameter of an allowed container — for example java.util.ArrayList<com.evil.Gadget> when only java.util.ArrayList is allow-listed. The container passes the PTV check; com.evil.Gadget is loaded via Class.forName(name, true, loader), instantiated, and its properties are set from attacker-controlled JSON. This completely bypasses an explicitly configured PTV allow-list. This vulnerability is fixed in 2.18.8, 2.21.4, and 3.1.4.

[CVE-2026-54513] (GHSA-rmj7-2vxq-3g9f) - CVSS 8.1 (High)

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.10.0 until 2.18.8, 2.21.4, and 3.1.4, BasicPolymorphicTypeValidator.Builder.allowIfSubTypeIsArray() allowlists any array type based only on clazz.isArray(), without validating the array's component (element) type against the configured allowlist. A PTV built with allowIfSubTypeIsArray() plus an explicit concrete-type allowlist therefore still permits EvilType[] even though EvilType is not allowlisted. When Jackson deserializes the elements and no per-element type IDs are present, it instantiates the component type directly with no further PTV check, bypassing the allowlist. This vulnerability is fixed in 2.18.8, 2.21.4, and 3.1.4.

[CVE-2026-54514] (GHSA-hgj6-7826-r7m5) - CVSS 5.3

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.0.0 until 2.18.8, 2.21.4, and 3.1.4, JDKFromStringDeserializer constructed InetSocketAddress with new InetSocketAddress(host, port), which performs eager DNS name resolution for hostname inputs at deserialization time. An application that binds untrusted JSON into a type containing an InetSocketAddress field issues an attacker-chosen DNS query during readValue, before any application-level validation or connect logic. The fix uses InetSocketAddress.createUnresolved(host, port), deferring DNS to an explicit connect. This vulnerability is fixed in 2.18.8, 2.21.4, and 3.1.4.

[CVE-2026-54515] (GHSA-5jmj-h7xm-6q6v) - CVSS 5.3

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.8.0 until 2.18.9, 2.21.5, and 3.1.4, in BeanDeserializerBase.createContextual(), per-property @JsonIgnoreProperties exclusions are applied by _handleByNameInclusion(), producing a contextual deserializer whose BeanPropertyMap has the ignored properties removed. The subsequent per-property case-insensitivity block (triggered by @JsonFormat(ACCEPT_CASE_INSENSITIVE_PROPERTIES)) rebuilds from this._beanProperties (the original, unfiltered map) instead of contextual._beanProperties, then overwrites the filtered map — restoring every property _handleByNameInclusion had just removed. The ignored property becomes writable again. This vulnerability is fixed in 2.18.9, 2.21.5, and 3.1.4.

[CVE-2026-54516] (GHSA-9fxm-vc8v-hj55) - CVSS 5.3

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.21.0 until 2.21.4 and 3.1.4, POJOPropertiesCollector._renameProperties() allows a property with @JsonProperty(«renamed») on the getter and @JsonIgnore on the setter to be renamed rather than dropped. With MapperFeature.INFER_PROPERTY_MUTATORS enabled (default), the private backing field is retained; during deserialization BeanDeserializerFactory.addBeanProps() sees hasField()==true, builds a FieldProperty, and makes the backing field writable. An attacker supplying the renamed JSON key writes the backing field directly, bypassing the @JsonIgnore on the setter. This vulnerability is fixed in 3.1.4.

[CVE-2026-54517] (GHSA-5hh8-q8hv-fr38) - CVSS 5.3

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.21.0 until 2.21.4 and 3.1.4, in BeanDeserializer._deserializeUsingPropertyBased, the active-view (@JsonView) filter was applied only to creator properties; the regular property-buffering branch performed no prop.visibleInView(activeView) check. A change making SetterlessProperty.isMerging() return true routed setterless Collection/Map properties through this unguarded path, so a setterless collection annotated with a restricted @JsonView is populated from attacker JSON even when the active view excludes it. This vulnerability is fixed in 2.21.4 and 3.1.4.

[CVE-2026-54518] (GHSA-rcqc-6cw3-h962) - CVSS 6.5

jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. From 2.21.0 until 2.21.4 and 3.1.4, UnwrappedPropertyHandler.processUnwrappedCreatorProperties() replays buffered JSON into creator parameters but never consults prop.visibleInView(activeView). The normal property-based creator path gates creator properties on the active view, but this unwrapped-creator replay path bypasses that check, so a constructor parameter annotated with both @JsonView(AdminView.class) and @JsonUnwrapped is populated from attacker JSON even when a more restrictive view is active. This vulnerability is fixed in 2.21.4 and 3.1.4.

The vulnerabilities are resolved by upgrading to the latest available version of the jackson-databind library.

**GovWay**

Il branch 3.4.x distribuisce jackson-databind 2.21+ ed è affetto da tutte e 7 le vulnerabilità.

Il branch 3.3.x distribuisce jackson-databind 2.18+ ed è affetto solamente da CVE-2026-54512, CVE-2026-54513, CVE-2026-54514 e CVE-2026-54515; le restanti tre (CVE-2026-54516, CVE-2026-54517, CVE-2026-54518) interessano esclusivamente le versioni 2.19+ della libreria e non riguardano quindi il branch 3.3.x.

Versione affette:

- 3.3.x: <= 3.3.20 (limitatamente a CVE-2026-54512, CVE-2026-54513, CVE-2026-54514, CVE-2026-54515)

- 3.4.x: <= 3.4.3 (tutte le vulnerabilità)

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.38 CVE-2026-50631, CVE-2026-50623, CVE-2026-50630, CVE-2026-50629

Data: 2026-06-13

Severity: High

CVSS Score:

- CVE-2026-50631: 7.4 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)
- CVE-2026-50623: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)
- CVE-2026-50630: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)
- CVE-2026-50629: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché risiedono nel modulo `cxf-rt-rs-security-oauth2` (server OAuth2 di Apache CXF) non distribuito da GovWay.

Riferimenti:

- CVE-2026-50631:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-50631
  - https://cxf.apache.org/security-advisories.data/CVE-2026-50631.txt
- CVE-2026-50623:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-50623
  - https://cxf.apache.org/security-advisories.data/CVE-2026-50623.txt
- CVE-2026-50630:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-50630
  - https://cxf.apache.org/security-advisories.data/CVE-2026-50630.txt
- CVE-2026-50629:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-50629
  - https://cxf.apache.org/security-advisories.data/CVE-2026-50629.txt

Libreria: org.apache.cxf:cxf-rt-rs-security-oauth2 (versioni affette: < 3.6.12, 4.0.0 - 4.1.6 e 4.2.0 - 4.2.1)

**Descrizione**

Le quattro vulnerabilità riguardano il modulo `cxf-rt-rs-security-oauth2` di Apache CXF, ovvero l'implementazione del server OAuth2 (Authorization Server / endpoint di introspection).

1. [CVE-2026-50631] CWE-367: Time-of-check Time-of-use (TOCTOU) Race Condition

A race condition in AbstractOAuthDataProvider allows concurrent requests using the same Refresh Token to bypass single-use semantics and generate multiple valid Access Tokens, when "recycleRefreshTokens" is set to false. A leaked refresh token can be replayed concurrently by multiple attackers or threads. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fixes this issue.

2. [CVE-2026-50623] CWE-287: Improper Authentication

An authentication bypass vulnerability exists in the OAuth2 TokenIntrospectionService in Apache CXF. Due to a missing "throw" keyword in the security context check, the introspection endpoint (/services/oauth2/introspect) can be accessed by any unauthenticated network attacker. However note that this is a safeguard only in the case that someone forgot to enable authentication on the service. Users are recommended to upgrade to version 4.2.2 or 4.1.7, which fixes this issue.

3. [CVE-2026-50630] CWE-113: Improper Neutralization of CRLF Sequences in HTTP Headers ("HTTP Request/Response Splitting")

A CRLF injection vulnerability exists in the OAuth2 AuthorizationUtils class. When constructing the WWW-Authenticate response header, the "realm" parameter is concatenated without sanitizing Carriage Return (CR) and Line Feed (LF) characters. If an attacker can control the realm value, they can inject arbitrary HTTP headers or split the HTTP response entirely. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fixes this issue.

4. [CVE-2026-50629] CWE-93: Improper Neutralization of CRLF Sequences ("CRLF Injection")

The "clientId" parameter from incoming HTTP requests is directly concatenated into OAuth2 server log warning messages without sanitizing control characters. This allows an attacker to inject arbitrary content, including fake log entries, into the server's log files. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fixes this issue.

**GovWay**

Le quattro vulnerabilità risiedono nel modulo `cxf-rt-rs-security-oauth2` di Apache CXF, che implementa il ruolo di Authorization Server OAuth2 (rilascio token, endpoint di introspection `/services/oauth2/introspect`, gestione dei refresh token, header `WWW-Authenticate`).

Tale modulo **non fa parte della distribuzione di GovWay**: il prodotto non espone alcun Authorization Server OAuth2 basato su Apache CXF. La gestione dei token OAuth2 in GovWay (validazione e introspection dei token verso Identity Provider esterni, negoziazione PDND) è realizzata con logica propria, indipendente dal modulo server OAuth2 di CXF. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico degli artefatti `cxf-core` e `cxf-rt-transports-http-jetty`, in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `cxf-rt-rs-security-oauth2`, non distribuito da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.39 CVE-2026-50632, CVE-2026-50633

Data: 2026-06-13

Severity: High

CVSS Score:

- CVE-2026-50632: 8.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-50633: 8.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché risiedono nei moduli `cxf-rt-transports-jms` e `cxf-integration-jca` di Apache CXF, non distribuiti da GovWay.

Riferimenti:

- CVE-2026-50632:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-50632
  - https://cxf.apache.org/security-advisories.data/CVE-2026-50632.txt
- CVE-2026-50633:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-50633
  - https://cxf.apache.org/security-advisories.data/CVE-2026-50633.txt

Libreria: org.apache.cxf:cxf-rt-transports-jms, org.apache.cxf:cxf-integration-jca (versioni affette: < 3.6.12, 4.0.0 - 4.1.6 e 4.2.0 - 4.2.1)

**Descrizione**

1. [CVE-2026-50632] CWE-20: Improper Input Validation

A further incomplete fix for a previous advisory CVE-2026-44417 (Untrusted JMS configuration can lead to RCE) for Apache CXF has been identified, which can allow code execution capabilities, if untrusted users are allowed to configure JMS for Apache CXF. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fixes this issue.

2. [CVE-2026-50633] CWE-20: Improper Input Validation

A JNDI Injection vulnerability has been discovered in Apache CXF's JCA integration module, which can allow for code execution, if an attacker is able to manipulate the JCA deployment descriptor (ra.xml) or runtime activation parameters. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fixes this issue.

**GovWay**

Le due vulnerabilità abilitano l'esecuzione di codice (RCE) tramite componenti di Apache CXF che non fanno parte della distribuzione di GovWay:

- **CVE-2026-50632** riguarda la configurazione del trasporto JMS di CXF (modulo `cxf-rt-transports-jms`), non utilizzato da GovWay. Si tratta di un fix incompleto della precedente CVE-2026-44417 (cfr. *CVE-2026-44417, CVE-2026-44618, CVE-2026-44930*): il fix incluso in Apache CXF 4.2.1 è risultato non risolutivo e la correzione completa è disponibile in Apache CXF 4.2.2/4.1.7;
- **CVE-2026-50633** riguarda il modulo di integrazione JCA di CXF (`cxf-integration-jca`) e richiede il controllo del descrittore di deployment JCA (`ra.xml`) o dei parametri di attivazione runtime; tale modulo non è presente in GovWay.

GovWay utilizza esclusivamente il core CXF ed i runtime JAX-WS/JAX-RS su trasporto HTTP: non integra né il trasporto JMS né il modulo di integrazione JCA. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico degli artefatti `cxf-core` e `cxf-rt-transports-http-jetty`, in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nei moduli `cxf-rt-transports-jms` (CVE-2026-50632) e `cxf-integration-jca` (CVE-2026-50633), non distribuiti da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.40 CVE-2026-50634

Data: 2026-06-13

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto: GovWay non utilizza il filtro JAX-RS `JwsJsonContainerRequestFilter` di Apache CXF.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-50634
- https://cxf.apache.org/security-advisories.data/CVE-2026-50634.txt

Libreria: org.apache.cxf:cxf-rt-rs-security-jose-jaxrs (versioni affette: < 3.6.12, 4.0.0 - 4.1.6 e 4.2.0 - 4.2.1)

**Descrizione**

CWE-347: Improper Verification of Cryptographic Signature

A vulnerability in Apache CXF's JwsJsonContainerRequestFilter can be exploited to cause CXF to process metadata that was not authenticated by the accepted signature. This can bypass the application's assumption that accepted `Content-Type` or protected HTTP-header metadata came from a verified signature entry, and may steer downstream JAX-RS entity parsing or signed-header consistency checks. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fix this issue.

**GovWay**

La vulnerabilità risiede nella classe `JwsJsonContainerRequestFilter` del modulo `cxf-rt-rs-security-jose-jaxrs` di Apache CXF: si tratta di un filtro JAX-RS *auto-wired* che valida le firme JWS-JSON sulle richieste in ingresso a livello di container.

Il modulo `cxf-rt-rs-security-jose-jaxrs` è incluso nella distribuzione di GovWay, ma il prodotto **non utilizza** tale filtro (né gli altri filtri JAX-RS JOSE auto-wired di CXF, quali `JwsContainerRequestFilter`, `JweJsonContainerRequestFilter`, `JweContainerRequestFilter`): nessuno di essi è registrato come provider JAX-RS. La sicurezza dei messaggi REST basata su JOSE (firma e cifratura JWS/JWE) è realizzata da GovWay utilizzando direttamente l'**API JOSE** di CXF in modo programmatico (`JwsCompactConsumer`, `JwsJsonConsumer`, `JweCompactConsumer`, `JweJsonConsumer` e classi correlate), con validazione esplicita della firma effettuata prima dell'elaborazione del contenuto. Il filtro vulnerabile non viene quindi mai istanziato. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

**Nota**

La vulnerabilità è segnalata dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico degli artefatti `cxf-core` e `cxf-rt-transports-http-jetty`, in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `cxf-rt-rs-security-jose-jaxrs`.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.41 CVE-2026-50645

Data: 2026-06-13

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la deserializzazione degli allegati in ingresso non transita per il codice vulnerabile di Apache CXF, pertanto la vulnerabilità non si manifesta nel prodotto.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-50645
- https://cxf.apache.org/security-advisories.data/CVE-2026-50645.txt

Libreria: org.apache.cxf:cxf-core (versioni affette: < 3.6.12, 4.0.0 - 4.1.6 e 4.2.0 - 4.2.1)

**Descrizione**

CWE-400: Uncontrolled Resource Consumption

There is no restriction on the amount of attachment headers that a message can contain when being deserialized by Apache CXF, which can lead to uncontrolled resource consumption or a denial of service attack. Users are recommended to upgrade to versions 4.2.2 or 4.1.7, which fix this issue by imposing a maximum default of 500 attachments per message.

**GovWay**

La vulnerabilità risiede nel deserializzatore degli allegati di Apache CXF (`org.apache.cxf.attachment.AttachmentDeserializer`), nel modulo `cxf-core`, ed è raggiungibile solo se i messaggi *multipart*/MTOM in ingresso vengono parsati tramite tale componente.

Sebbene `cxf-core` faccia parte della distribuzione di GovWay, il prodotto **non utilizza** il deserializzatore di allegati di CXF per il parsing dei messaggi in ingresso:

- i messaggi SOAP con allegati (MTOM/SwA) sono parsati dall'implementazione SAAJ (`com.sun.xml.messaging.saaj`), con il relativo parser MIME interno;
- i messaggi REST *multipart* sono parsati tramite Jakarta Mail (`jakarta.mail.internet.MimeMultipart`).

Le classi `org.apache.cxf.attachment.*` sono impiegate da GovWay unicamente per operazioni non legate al parsing in ingresso (es. generazione del Content-ID per gli allegati in uscita e adattamento di `DataHandler` già parsati verso le strutture richieste da WSS4J). Il deserializzatore vulnerabile `AttachmentDeserializer` non viene quindi mai invocato sul flusso di ricezione dei messaggi. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

**Nota**

La vulnerabilità è correttamente attribuita all'artefatto `cxf-core` (oltre che a `cxf-rt-transports-http-jetty`), in quanto l'NVD associa le vulnerabilità di Apache CXF alla CPE di prodotto `cpe:2.3:a:apache:cxf`. Pur essendo `cxf-core` effettivamente distribuito da GovWay, lo specifico percorso di codice vulnerabile (`AttachmentDeserializer`) non è esercitato dal prodotto.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: 3.3.21
- 3.4.x: 3.4.4

### 2.1.42 CVE-2026-40988, CVE-2026-41003, CVE-2026-41694

Data: 2026-06-13

Severity: High

CVSS Score:

- CVE-2026-40988: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-41003: 5.4 (CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N)
- CVE-2026-41694: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché risiedono nel modulo `spring-security-saml2-service-provider` non distribuito da GovWay.

Riferimenti:

- CVE-2026-40988:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-40988
  - https://spring.io/security/cve-2026-40988
- CVE-2026-41003:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41003
  - https://spring.io/security/cve-2026-41003
- CVE-2026-41694:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41694
  - https://spring.io/security/cve-2026-41694

Libreria: org.springframework.security Spring Security (versioni affette: 5.7.0 - 5.7.23, 5.8.0 - 5.8.25, 6.3.0 - 6.3.16, 6.4.0 - 6.4.16, 6.5.0 - 6.5.10, 7.0.0 - 7.0.5)

**Descrizione**

Le tre vulnerabilità riguardano il modulo `spring-security-saml2-service-provider` di Spring Security, ovvero il supporto al ruolo di Service Provider SAML 2.0.

1. [CVE-2026-40988] CWE-400: Uncontrolled Resource Consumption

An application using spring-security-saml2-service-provider and the REDIRECT binding for SAML 2.0 Login or Logout may be vulnerable to a denial of service by way of an unbounded writer that inflates the compressed SAML payload into memory. Affected versions: Spring Security 5.7.0 through 5.7.23; 5.8.0 through 5.8.25; 6.3.0 through 6.3.16; 6.4.0 through 6.4.16; 6.5.0 through 6.5.10; 7.0.0 through 7.0.5.

2. [CVE-2026-41003] CWE-79: Improper Neutralization of Input During Web Page Generation ("Cross-site Scripting")

An attacker able to influence values in RelyingPartyRegistration may be able to run arbitrary code on HTML forms generated by Spring Security filters. Affected versions: Spring Security 5.7.0 through 5.7.23; 5.8.0 through 5.8.25; 6.3.0 through 6.3.16; 6.4.0 through 6.4.16; 6.5.0 through 6.5.10; 7.0.0 through 7.0.5.

3. [CVE-2026-41694] CWE-347: Improper Verification of Cryptographic Signature

Since Spring Security SAML decrypts SAML Responses as well as elements of SAML LogoutRequests and LogoutResponses without requiring a valid signature, attackers may be able to craft these SAML payloads and use the Service Provider as a decryption oracle. Affected versions: Spring Security 5.7.0 through 5.7.23; 5.8.0 through 5.8.25; 6.3.0 through 6.3.16; 6.4.0 through 6.4.16; 6.5.0 through 6.5.10; 7.0.0 through 7.0.5.

**GovWay**

Le tre vulnerabilità risiedono nel modulo `spring-security-saml2-service-provider` di Spring Security, che implementa il ruolo di Service Provider SAML 2.0 (SAML Login/Logout, gestione di `RelyingPartyRegistration`, binding REDIRECT, cifratura/decifratura dei messaggi SAML).

Tale modulo **non fa parte della distribuzione di GovWay**: il prodotto include unicamente i moduli `spring-security-core`, `spring-security-config`, `spring-security-web` e `spring-security-crypto`, utilizzati esclusivamente per autenticazione, autorizzazione e codifica delle password (es. `AuthenticationProvider`, `UserDetailsService`, filtri di pre-autenticazione, `SecurityContextHolder`, `SCryptPasswordEncoder`). GovWay non utilizza il supporto SAML 2.0 di Spring Security e non configura alcun Service Provider basato su Spring Security: le funzionalità SAML eventualmente impiegate nella sicurezza dei messaggi si basano sulla libreria OpenSAML, indipendente da Spring Security. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `spring-security-core`, in quanto l'NVD associa le vulnerabilità di Spring Security alla CPE di prodotto `cpe:2.3:a:vmware:spring_security` senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `spring-security-saml2-service-provider`, non distribuito da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.43 CVE-2026-41842, CVE-2026-41841, CVE-2026-41843

Data: 2026-06-13

Severity: High

CVSS Score:

- CVE-2026-41842: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-41841: 5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)
- CVE-2026-41843: 5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità delle librerie. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto, poiché risiedono in moduli di Spring Framework (`spring-webmvc` / `spring-webflux`) non distribuiti da GovWay.

Riferimenti:

- CVE-2026-41842:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41842
  - https://spring.io/security/cve-2026-41842
- CVE-2026-41841:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41841
  - https://spring.io/security/cve-2026-41841
- CVE-2026-41843:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41843
  - https://spring.io/security/cve-2026-41843

Libreria: org.springframework Spring Framework (versioni affette: 5.3.0 - 5.3.48, 6.1.0 - 6.1.27, 6.2.0 - 6.2.18, 7.0.0 - 7.0.7)

**Descrizione**

1. [CVE-2026-41842] CWE-400: Uncontrolled Resource Consumption

Spring MVC and WebFlux applications are vulnerable to Denial of Service (DoS) attacks when resolving static resources. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

2. [CVE-2026-41841] CWE-524: Use of Cache Containing Sensitive Information

Spring MVC and WebFlux applications are vulnerable to Information Disclosure attacks when resolving static resources. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

3. [CVE-2026-41843] CWE-22: Improper Limitation of a Pathname to a Restricted Directory ("Path Traversal")

Spring MVC and WebFlux applications are vulnerable to Path Traversal attacks when resolving static resources. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

**GovWay**

Le tre vulnerabilità risiedono nei moduli `spring-webmvc` e `spring-webflux` di Spring Framework, ovvero nel framework web MVC/WebFlux e nel relativo meccanismo di *resource handling* (`ResourceHttpRequestHandler` e componenti correlati).

Tali moduli **non fanno parte della distribuzione di GovWay**: il prodotto utilizza Spring esclusivamente come container di *dependency injection* (moduli `spring-core`, `spring-beans`, `spring-context`, `spring-context-support`, `spring-expression`), insieme a `spring-aop`/`spring-aspects`, `spring-tx` e `spring-web`; non integra Spring MVC né Spring WebFlux ed espone i propri servizi tramite uno stack servlet/JAX-RS proprio. Il meccanismo di risoluzione delle risorse statiche di Spring non viene quindi mai istanziato. Per questi motivi le vulnerabilità non si manifestano nel prodotto.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `spring-core`, in quanto l'NVD associa le vulnerabilità di Spring Framework alla CPE di prodotto `cpe:2.3:a:vmware:spring_framework` (con gli alias `pivotal_software` e `springsource`), senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nei moduli `spring-webmvc` / `spring-webflux`, non distribuiti da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.44 CVE-2026-41845, CVE-2026-41846

Data: 2026-06-13

Severity: Medium

CVSS Score:

- CVE-2026-41845: 6.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)
- CVE-2026-41846: 6.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità delle librerie. Come descritto nella sezione **GovWay**, le vulnerabilità non si manifestano nel prodotto: GovWay non utilizza né il metodo `JavaScriptUtils.javaScriptEscape()` né la tag library JSP di Spring MVC.

Riferimenti:

- CVE-2026-41845:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41845
  - https://spring.io/security/cve-2026-41845
- CVE-2026-41846:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41846
  - https://spring.io/security/cve-2026-41846

Libreria: org.springframework Spring Framework (versioni affette: 5.3.0 - 5.3.48, 6.1.0 - 6.1.27, 6.2.0 - 6.2.18, 7.0.0 - 7.0.7)

**Descrizione**

1. [CVE-2026-41845] CWE-79: Improper Neutralization of Input During Web Page Generation ("Cross-site Scripting")

Due to incorrect escaping, the use of JavaScriptUtils.javaScriptEscape() may lead to JavaScript code injection in the browser, potentially resulting in a cross-site scripting (XSS) vulnerability. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

2. [CVE-2026-41846] CWE-79: Improper Neutralization of Input During Web Page Generation ("Cross-site Scripting")

Spring MVC applications which accept user-supplied values in the cssClass, cssErrorClass, or cssStyle attributes of JSP form tags allow arbitrary HTML/JavaScript code injection, potentially resulting in a cross-site scripting (XSS) vulnerability. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

**GovWay**

La vulnerabilità **CVE-2026-41846** risiede nella *form tag library* JSP del modulo `spring-webmvc`, che non fa parte della distribuzione di GovWay: il prodotto non integra Spring MVC e non utilizza i tag JSP di Spring. La vulnerabilità non si manifesta quindi nel prodotto.

La vulnerabilità **CVE-2026-41845** riguarda invece il metodo `JavaScriptUtils.javaScriptEscape()` del modulo `spring-web`, effettivamente incluso nella distribuzione. Tale metodo è una utility di *escaping* destinata alla generazione di contenuto JavaScript lato view (tipicamente in pagine JSP tramite la tag library di Spring MVC, non utilizzata da GovWay). Di `spring-web` GovWay impiega unicamente l'utility di decodifica URI `UriUtils` e l'accesso al contesto applicativo dai servlet della console di monitoraggio (`WebApplicationContextUtils`); il

metodo `JavaScriptUtils.javaScriptEscape()` non risulta utilizzato dal prodotto. Anche questa vulnerabilità non si manifesta pertanto nel prodotto.

**Nota**

Le vulnerabilità sono segnalate dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `spring-core`, in quanto l'NVD associa le vulnerabilità di Spring Framework alla CPE di prodotto `cpe:2.3:a:vmware:spring_framework` (con gli alias `pivotal_software` e `springsource`), senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nei moduli `spring-webmvc` (CVE-2026-41846) e `spring-web` (CVE-2026-41845).

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.45 CVE-2026-41844

Data: 2026-06-13

Severity: Medium

CVSS Score: 6.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché risiede in moduli di Spring Framework (`spring-webmvc` / `spring-webflux`) non distribuiti da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-41844
- https://spring.io/security/cve-2026-41844

Libreria: org.springframework Spring Framework (versioni affette: 5.3.0 - 5.3.48, 6.1.0 - 6.1.27, 6.2.0 - 6.2.18, 7.0.0 - 7.0.7)

**Descrizione**

CWE-601: URL Redirection to Untrusted Site ("Open Redirect")

A Spring MVC or Spring WebFlux application which configures a mapping for «/**» where the view name is not explicitly specified allows an attacker to craft a link resulting in a 302 redirect to an arbitrary external host via the redirect: prefix. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

**GovWay**

La vulnerabilità risiede nei moduli `spring-webmvc` e `spring-webflux` di Spring Framework, nello specifico nella gestione dei *view name* e dei relativi prefissi `redirect:` / `forward:`.

Tali moduli **non fanno parte della distribuzione di GovWay**: il prodotto non integra Spring MVC né Spring WebFlux, non configura mapping di view e non utilizza i prefissi `redirect:` / `forward:` di Spring; i propri servizi sono esposti tramite uno stack servlet/JAX-RS proprio. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

**Nota**

La vulnerabilità è segnalata dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `spring-core`, in quanto l'NVD associa le vulnerabilità di Spring Framework alla CPE di prodotto `cpe:2.3:a:vmware:spring_framework` (con gli alias `pivotal_software` e `springsource`), senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nei moduli `spring-webmvc` / `spring-webflux`, non distribuiti da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.46 CVE-2026-41840

Data: 2026-06-13

Severity: Medium

CVSS Score: 5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché risiede nel modulo Spring WebFlux (`spring-webflux`) non distribuito da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-41840
- https://spring.io/security/cve-2026-41840

Libreria: org.springframework Spring Framework (versioni affette: 5.3.0 - 5.3.48, 6.1.0 - 6.1.27, 6.2.0 - 6.2.18, 7.0.0 - 7.0.7)

**Descrizione**

CWE-400: Uncontrolled Resource Consumption

Spring WebFlux applications are vulnerable to Denial of Service (DoS) attacks when processing multipart requests. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

**GovWay**

La vulnerabilità risiede nel modulo `spring-webflux` di Spring Framework, nella gestione reattiva delle richieste *multipart*.

Tale modulo **non fa parte della distribuzione di GovWay**: il prodotto non integra Spring WebFlux e non utilizza lo stack web reattivo di Spring per la ricezione delle richieste; la gestione delle richieste (incluse quelle multipart) avviene tramite uno stack servlet/JAX-RS proprio. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

**Nota**

La vulnerabilità è segnalata dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `spring-core`, in quanto l'NVD associa le vulnerabilità di Spring Framework alla CPE di prodotto `cpe:2.3:a:vmware:spring_framework` (con gli alias `pivotal_software` e `springsource`), senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `spring-webflux`, non distribuito da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.47 CVE-2026-41838

Data: 2026-06-13

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la vulnerabilità non si manifesta nel prodotto, poiché risiede nel modulo Spring WebSocket (`spring-websocket`) non distribuito da GovWay.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-41838
- https://spring.io/security/cve-2026-41838

Libreria: org.springframework Spring Framework (versioni affette: 5.3.0 - 5.3.48, 6.1.0 - 6.1.27, 6.2.0 - 6.2.18, 7.0.0 - 7.0.7)

**Descrizione**

CWE-330: Use of Insufficiently Random Values

IDs for WebSocket sessions in the spring-websocket module are not cryptographically unpredictable, which may be possible to exploit in combination with inadequate authorization rules. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

**GovWay**

La vulnerabilità risiede nel modulo `spring-websocket` di Spring Framework, nella generazione degli identificativi di sessione WebSocket.

Tale modulo **non fa parte della distribuzione di GovWay**: il prodotto non integra Spring WebSocket e non espone endpoint WebSocket basati su Spring. Per questi motivi la vulnerabilità non si manifesta nel prodotto.

**Nota**

La vulnerabilità è segnalata dai tool di analisi delle dipendenze (es. OWASP dependency-check) a carico dell'artefatto `spring-core`, in quanto l'NVD associa le vulnerabilità di Spring Framework alla CPE di prodotto `cpe:2.3:a:vmware:spring_framework` (con gli alias `pivotal_software` e `springsource`), senza distinguere il singolo modulo Maven. Il codice vulnerabile risiede tuttavia nel modulo `spring-websocket`, non distribuito da GovWay.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.48 CVE-2026-41850, CVE-2026-41851, CVE-2026-41852

Data: 2026-06-13

Severity: High

CVSS Score:

- CVE-2026-41850: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-41851: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-41852: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità della libreria. Come descritto nella sezione **GovWay**, la condizione necessaria allo sfruttamento (valutazione di espressioni SpEL fornite da input non fidato) non è presente nel prodotto.

Riferimenti:

- CVE-2026-41850:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41850
  - https://spring.io/security/cve-2026-41850
- CVE-2026-41851:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41851
  - https://spring.io/security/cve-2026-41851
- CVE-2026-41852:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-41852
  - https://spring.io/security/cve-2026-41852

Libreria: org.springframework:spring-expression (versioni affette: 5.3.0 - 5.3.48, 6.1.0 - 6.1.27, 6.2.0 - 6.2.18, 7.0.0 - 7.0.7)

**Descrizione**

1. [CVE-2026-41850] CWE-407: Inefficient Algorithmic Complexity

Applications that evaluate user-supplied Spring Expression Language (SpEL) expressions are vulnerable to an Algorithmic Denial of Service (DoS). By providing a specially crafted expression, an attacker can trigger excessive resource consumption during evaluation, leading to application degradation or unavailability. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

2. [CVE-2026-41851] CWE-770: Allocation of Resources Without Limits or Throttling

Applications which accept user-supplied Spring Expression Language (SpEL) expressions may be vulnerable to a Denial of Service (DoS) attack if the evaluation of a SpEL expression triggers unbounded cache growth. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

3. [CVE-2026-41852] CWE-863: Incorrect Authorization

A vulnerability in Spring Expression Language (SpEL) evaluation logic allows for arbitrary zero-argument method invocation, even within restricted or read-only contexts, which may allow an attacker to invoke unintended application logic. Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

**GovWay**

Il modulo `spring-expression` è incluso nella distribuzione di GovWay in quanto dipendenza del container di *dependency injection* di Spring. SpEL viene utilizzato da Spring per la risoluzione delle espressioni `#{...}` presenti nei file di configurazione dei bean: si tratta di espressioni statiche, definite a tempo di sviluppo/configurazione e **non influenzabili da input di runtime**.

GovWay **non valuta espressioni SpEL fornite da utenti o derivanti dal traffico applicativo** (header, payload, parametri di richiesta o valori configurabili a runtime). Le funzionalità di valutazione di espressioni esposte dal prodotto si basano su motori distinti e indipendenti da SpEL (XPath, XQuery, JSONPath ed espressioni regolari). La condizione necessaria allo sfruttamento delle tre vulnerabilità - la valutazione di un'espressione SpEL controllata dall'attaccante - non è quindi presente, e le vulnerabilità non si manifestano nel prodotto.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.49 CVE-2026-41848

Data: 2026-06-13

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria. Come descritto nella sezione **GovWay**, GovWay non utilizza la classe `AntPathMatcher` e la condizione necessaria allo sfruttamento (pattern controllato dall'attaccante) non è presente nel prodotto.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-41848
- https://spring.io/security/cve-2026-41848

Libreria: org.springframework:spring-core (versioni affette: 5.3.0 - 5.3.48, 6.1.0 - 6.1.27, 6.2.0 - 6.2.18, 7.0.0 - 7.0.7)

**Descrizione**

CWE-1333: Inefficient Regular Expression Complexity

Applications may be vulnerable to a Regular Expression Denial of Service (ReDoS) attack if an attacker is able to provide a pattern which is then directly or indirectly supplied to one of the following methods in AntPathMatcher: match(String pattern, String path), matchStart(String pattern, String path), extractUriTemplateVariables(String pattern, String path). Affected versions: Spring Framework 7.0.0 through 7.0.7; 6.2.0 through 6.2.18; 6.1.0 through 6.1.27; 5.3.0 through 5.3.48.

**GovWay**

La classe vulnerabile `org.springframework.util.AntPathMatcher` appartiene al modulo `spring-core`, incluso nella distribuzione di GovWay. Tuttavia GovWay **non utilizza** `AntPathMatcher` (né l'interfaccia `PathMatcher` di Spring): le funzionalità di *matching* di percorsi e di instradamento sono realizzate con logica propria, indipendente da Spring.

Inoltre, lo sfruttamento della vulnerabilità richiede che sia il *pattern* (e non il path) ad essere controllato dall'attaccante: nelle normali architetture i pattern costituiscono regole di instradamento di natura configurativa/amministrativa, non influenzabili dal traffico applicativo. Per entrambi i motivi la vulnerabilità non si manifesta nel prodotto.

Versione affette:

- 3.3.x: <= 3.3.20
- 3.4.x: <= 3.4.3

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.4

### 2.1.50 CVE-2026-47691, CVE-2026-45674, CVE-2026-44249, CVE-2026-45416, CVE-2026-45673

Data: 2026-06-09

Severity: High

CVSS Score:

- CVE-2026-47691: 8.7 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N)
- CVE-2026-45674: 8.7 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N)
- CVE-2026-44249: 8.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-45416: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-45673: 6.8 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:N/I:H/A:N)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità delle librerie. Come descritto nella sezione **GovWay**, le vulnerabilità lato server (CVE-2026-44249 e CVE-2026-45416) non si manifestano nel prodotto, mentre per quelle relative al resolver DNS (CVE-2026-47691, CVE-2026-45674, CVE-2026-45673) il rischio è fortemente limitato dal contesto di deployment.

Riferimenti:

- CVE-2026-47691 (GHSA-5pvg-856g-cp85):
  - https://github.com/advisories/GHSA-5pvg-856g-cp85
  - https://github.com/netty/netty/security/advisories/GHSA-5pvg-856g-cp85
- CVE-2026-45674 (GHSA-676x-f7gg-47vc):
  - https://github.com/advisories/GHSA-676x-f7gg-47vc
  - https://github.com/netty/netty/security/advisories/GHSA-676x-f7gg-47vc
- CVE-2026-44249 (GHSA-3qp7-7mw8-wx86):
  - https://github.com/advisories/GHSA-3qp7-7mw8-wx86
  - https://github.com/netty/netty/security/advisories/GHSA-3qp7-7mw8-wx86
- CVE-2026-45416 (GHSA-x4gw-5cx5-pgmh):
  - https://github.com/advisories/GHSA-x4gw-5cx5-pgmh
  - https://github.com/netty/netty/security/advisories/GHSA-x4gw-5cx5-pgmh
- CVE-2026-45673 (GHSA-xmv7-r254-6q78):
  - https://github.com/advisories/GHSA-xmv7-r254-6q78
  - https://github.com/netty/netty/security/advisories/GHSA-xmv7-r254-6q78

Libreria: io.netty:netty-resolver-dns, io.netty:netty-handler (>= 4.2.0.Final, <= 4.2.14.Final)

**Descrizione**

1. [CVE-2026-47691] CWE-349: Acceptance of Extraneous Untrusted Data With Trusted Data (DNS Cache Poisoning)

Il resolver DNS di Netty (`DnsResolveContext.AuthoritativeNameServerList#add`) non valida correttamente la *bailiwick* dei record NS: accetta qualsiasi record NS presente nella sezione AUTHORITY purché il nome del record sia un suffisso della *questionName*. Un attaccante che controlli un name server autoritativo per un sottodominio può quindi inserire record NS che rivendicano autorità sul dominio padre (es. `co.uk.`); i corrispondenti record A presenti nella sezione ADDITIONAL vengono memorizzati in `authoritativeDnsServerCache` sotto la chiave del dominio padre, avvelenando la cache per tutte le risoluzioni successive. Risolto nella versione 4.2.15.Final.

2. [CVE-2026-45674] CWE-349: Acceptance of Extraneous Untrusted Data With Trusted Data (DNS Cache Poisoning)

Il resolver DNS di Netty (`DnsResolveContext#buildAliasMap`) elabora la sezione ANSWER di una risposta DNS e memorizza tutti i record CNAME senza verificarne l'origine (*bailiwick*), in violazione di quanto previsto da RFC 5452, Section 6 (i dati vanno accettati solo se l'originatore è autoritativo per la QNAME o per un suo genitore). Ciò abilita attacchi di DNS Cache Poisoning. Risolto nella versione 4.2.15.Final.

3. [CVE-2026-44249] CWE-284: Improper Access Control (IPv6 Subnet Filter Bypass)

Il metodo `IpSubnetFilterRule#compareTo(InetSocketAddress)` di Netty esegue l'operazione di AND bit a bit tra l'indirizzo IP in ingresso e il `networkAddress` configurato anziché con la `subnetMask`. Per effetto di questo masking errato, indirizzi IPv6 pubblici validi possono eludere le regole di subnet configurate, bypassando i controlli di accesso basati su `IpSubnetFilter`. Risolto nella versione 4.2.15.Final.

4. [CVE-2026-45416] CWE-770: Allocation of Resources Without Limits or Throttling

`SslClientHelloHandler.decode()` legge la lunghezza a 24 bit dell'handshake TLS e, quando il ClientHello non rientra nel primo record, alloca immediatamente un buffer di dimensione pari alla lunghezza dichiarata. Con i costruttori comunemente usati di `SniHandler/AbstractSniHandler` (`maxClientHelloLength=0` e `handshakeTimeoutMillis=0`) il controllo sulla lunghezza è disabilitato e non viene schedulato alcun timeout: una richiesta che dichiara 16 MiB provoca un'allocazione immediata (non poolizzata) trattenuta fino alla chiusura del canale. Un attaccante può così innescare una Denial of Service inviando pochi byte. Risolto nella versione 4.2.15.Final.

5. [CVE-2026-45673] CWE-330: Use of Insufficiently Random Values (DNS Cache Poisoning / Kaminsky)

Il resolver DNS di Netty utilizza un PRNG prevedibile per la generazione dei transaction ID DNS (`DnsQueryIdSpace` reinserisce gli ID tramite `ThreadLocalRandom`, un LCG prevedibile) e, con il `channelStrategy` di default `ChannelPerResolver`, una porta UDP sorgente statica. La combinazione riduce l'entropia delle query DNS, facilitando attacchi di DNS Cache Poisoning (Kaminsky). Risolto nella versione 4.2.15.Final.

**GovWay**

Le librerie Netty non sono utilizzate direttamente da GovWay: vengono incluse esclusivamente come dipendenza transitiva di Redisson (`org.redisson:redisson:4.3.1`), il client utilizzato per connettersi a un server Redis quando l'amministratore abilita le funzionalità distribuite basate su Redis (contatori distribuiti del controllo del traffico / rate limiting in cluster, cache distribuita, protezione anti-replay JTI). In questo contesto Netty opera unicamente come *client* verso il server Redis.

Le cinque vulnerabilità presentano un impatto differenziato sul prodotto.

*Vulnerabilità non esercitate (non si manifestano in GovWay)*

- CVE-2026-44249 riguarda l'handler di access control `IpSubnetFilter` di Netty (filtro lato server della pipeline), che non viene mai istanziato né da Redisson né da GovWay;
- CVE-2026-45416 riguarda `SslClientHelloHandler/SniHandler`, ovvero la gestione *lato server* del ClientHello TLS in ingresso; GovWay non espone alcun server TLS basato su Netty (Redisson agisce esclusivamente come client TLS verso Redis), pertanto tali handler non vengono utilizzati.

*Vulnerabilità sul resolver DNS (rischio residuo limitato dal deployment)*

Le tre vulnerabilità di DNS Cache Poisoning (CVE-2026-47691, CVE-2026-45674, CVE-2026-45673) insistono invece su codice effettivamente esercitato: Redisson impiega il resolver DNS di Netty per risolvere e monitorare gli hostname dei nodi Redis. Il codice vulnerabile è quindi raggiungibile e la criticità è da considerarsi potenzialmente sfruttabile, sebbene il rischio effettivo sia fortemente limitato dal contesto di esercizio:

- la risoluzione riguarda esclusivamente gli hostname dei nodi Redis configurati dall'amministratore, e non il traffico applicativo gestito da GovWay; un'eventuale cache avvelenata potrebbe al più dirottare le connessioni verso il backend Redis, non le richieste verso gli applicativi esposti;
- Redis viene tipicamente collocato in una rete interna fidata; lo sfruttamento richiede un attaccante in grado di iniettare risposte DNS contraffatte per quelle specifiche query (posizione on-path, oppure attacco off-path tipo Kaminsky contro il resolver utilizzato);
- come mitigazione applicabile da subito, è possibile configurare l'endpoint Redis tramite indirizzo IP anziché hostname, evitando del tutto la risoluzione DNS, oppure affidarsi a un resolver DNS fidato e protetto.

Il rischio è pertanto valutato basso, ma non nullo, fino all'aggiornamento della libreria.

Versione affette:

- 3.3.x: <= 3.3.19.p1

- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.51 CVE-2026-44417, CVE-2026-44618, CVE-2026-44930

Data: 2026-05-22

Severity: Critical

CVSS Score:

- CVE-2026-44417: 7.5 (CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-44618: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
- CVE-2026-44930: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

**Nota**

La severity e i CVSS Score si riferiscono alle vulnerabilità delle librerie; come descritto nella sezione **GovWay** le vulnerabilità non si manifestano nel prodotto.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-44417
- https://nvd.nist.gov/vuln/detail/CVE-2026-44618
- https://nvd.nist.gov/vuln/detail/CVE-2026-44930
- https://lists.apache.org/thread/bqg6gjy2cx7rfyqjxcpv3jwjvmclvz4o
- https://lists.apache.org/thread/c7vb015f8ljmjl44030mn0yfq71f7sd7
- https://lists.apache.org/thread/c1zqxppo1m5z3kbdhjn5p991zk09ynkh

Libreria: org.apache.cxf:* <= 4.2.0

**Descrizione**

1. [CVE-2026-44417] CWE-20: Improper Input Validation

The fix for CVE-2025-48913: Apache CXF: Untrusted JMS configuration can lead to RCE was not complete, meaning that another path in the code might lead to code execution capabilities, if untrusted users are allowed to configure JMS for Apache CXF. Users are recommended to upgrade to versions 4.2.1, 4.1.6 or 3.6.11, which fix this issue.

**Nota**

Il fix per CVE-2026-44417 incluso in Apache CXF 4.2.1 (presente in GovWay 3.4.3) è successivamente risultato a sua volta incompleto: un ulteriore percorso di sfruttamento è stato tracciato come CVE-2026-50632, risolto in Apache CXF 4.2.2/4.1.7 (cfr. *CVE-2026-50632, CVE-2026-50633*). Trattandosi del medesimo modulo `cxf-rt-transports-jms` non distribuito da GovWay, il prodotto non è comunque esposto; il recepimento della correzione completa è tracciato nella segnalazione *CVE-2026-50632, CVE-2026-50633*.

2. [CVE-2026-44618] CWE-611: Improper Restriction of XML External Entity Reference

Insecure XML parser configuration in Apache CXF's WS-Transfer module may allow attackers to perform XXE attacks. Users are recommended to upgrade to versions 4.2.1, 4.1.6 or 3.6.11, which fix this issue.

3. [CVE-2026-44930] CWE-90: Improper Neutralization of Special Elements used in an LDAP Query ("LDAP Injection")

An LDAP injection vulnerability in the LDAP Certificate repository of the XKMS server in Apache CXF may allow an attacker to retrieve arbitrary certificates from the repository. Users are recommended to upgrade to versions 4.2.1, 4.1.6 or 3.6.11, which fix this issue.

**GovWay**

Le tre vulnerabilità interessano componenti di Apache CXF che non fanno parte della distribuzione di GovWay, il quale utilizza esclusivamente il core CXF e i runtime JAX-WS/JAX-RS su trasporto HTTP (oltre al modulo JOSE per la sicurezza dei messaggi):

- CVE-2026-44930 riguarda il server XKMS di CXF (modulo `cxf-services-xkms`), non presente in GovWay;
- CVE-2026-44417 riguarda la configurazione del trasporto JMS di CXF (modulo `cxf-rt-transports-jms`), non utilizzato da GovWay;
- CVE-2026-44618 riguarda il modulo WS-Transfer di CXF (`cxf-ws-transfer`), non presente in GovWay.

Per questi motivi le vulnerabilità non si manifestano nel prodotto.

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.52 CVE-2026-42579

Data: 2026-05-07

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)

Riferimenti:

- https://guide.sonatype.com/vulnerability/CVE-2026-42579
- https://github.com/netty/netty/security/advisories/GHSA-cm33-6792-r9fm
- https://tools.ietf.org/html/rfc1035#section-2.3.4
- https://tools.ietf.org/html/rfc1035#section-4.1.4

Libreria: io.netty:netty-codec-dns <= 4.1.132.Final

**Descrizione**

CWE-20: Improper Input Validation / CWE-626: Null Byte Interaction Error / CWE-400: Uncontrolled Resource Consumption

Netty's DNS codec (`io.netty.handler.codec.dns.DnsCodecUtil`) does not enforce RFC 1035 domain name constraints during either encoding or decoding. Both `encodeDomainName()` and `decodeDomainName()` are affected. On the encoder side, label data is not validated for null bytes, per-label length (RFC 1035 max: 63 bytes) or total domain name length (RFC 1035 max: 255 bytes); empty labels silently truncate the domain name. This enables differential interpretation between Java and native DNS resolvers (DNS cache poisoning, domain validation bypass),

label/pointer confusion (length values >= 192 are interpreted as compression pointers per RFC 1035 Section 4.1.4) and silent truncation of domain names containing consecutive dots. On the decoder side, malicious DNS responses with oversized labels or unbounded total length cause excessive `StringBuilder` allocation. The issue is fixed in versions 4.1.133.Final and 4.2.13.Final.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.53 CVE-2026-42583

Data: 2026-05-07

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://guide.sonatype.com/vulnerability/CVE-2026-42583
- https://github.com/netty/netty/security/advisories/GHSA-mj4r-2hfc-f8p6

Libreria: io.netty:netty-codec <= 4.1.132.Final

**Descrizione**

CWE-400: Uncontrolled Resource Consumption / CWE-770: Allocation of Resources Without Limits or Throttling

Netty's `io.netty.handler.codec.compression.Lz4FrameDecoder` is vulnerable to resource exhaustion. When decoding LZ4 frames, the decoder trusts the `decompressedLength` header field for sizing and allocates a `ByteBuf` of that size (up to 32 MB per block) before decompression actually runs. A peer only needs to send 22 bytes (a 21-byte header plus a 1-byte compressed payload, when `compressedLength == 1`) to force the server to allocate the maximum 32 MB buffer. Untrusted senders, in absence of per-channel or aggregate limits, can therefore stress server memory with many small requests, causing a Denial of Service. The issue is fixed in versions 4.1.133.Final (`io.netty:netty-codec`) and 4.2.13.Final (`io.netty:netty-codec-compression`).

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.54 CVE-2026-42402, CVE-2026-42403, CVE-2026-42404

Data: 2026-05-03

Severity: High

CVSS Score:

- CVE-2026-42402: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-42403: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-42404: 7.2 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-42402
- https://nvd.nist.gov/vuln/detail/CVE-2026-42403
- https://nvd.nist.gov/vuln/detail/CVE-2026-42404

Libreria: org.apache.neethi:neethi <= 3.2.1

**Descrizione**

1. [CVE-2026-42402] CWE-400: Uncontrolled Resource Consumption

Apache Neethi is vulnerable to a Denial of Service attack through algorithmic complexity in policy normalization. Specially crafted WS-Policy documents can trigger an exponential Cartesian cross-product expansion during the normalization process, causing unbounded memory allocation that exhausts the JVM heap. This occurs when the normalization process generates an excessive number of policy alternatives without bounds, leading to runtime memory exhaustion. Users should upgrade to 3.2.2 which limits the maximum number of normalized policy alternatives.

2. [CVE-2026-42403] CWE-400: Uncontrolled Resource Consumption

Apache Neethi does not properly detect circular references in policy definitions. When a WS-Policy document contains circular policy references (where Policy A references Policy B which references Policy A), the policy normalization process can enter an infinite loop or cause excessive recursion, leading to a stack overflow or application hang. An attacker can craft malicious policy documents with circular references to cause a Denial of Service condition. Users are recommended to upgrade to version 3.2.2, which fixes this issue.

3. [CVE-2026-42404] CWE-918: Server-Side Request Forgery (SSRF)

Apache Neethi does not impose any restrictions on URIs when manually fetching remote policy references through the PolicyReference API. When an application explicitly calls the API to retrieve a policy from a remote URI, an outbound request is made for arbitrary protocols and internal IP addresses. From 3.2.2, only http or https URIs are allowed, and link-local/multicast/any-local addresses are forbidden. Users are recommended to upgrade to version 3.2.2, which fixes this issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.55 CVE-2026-0636

Data: 2026-04-22

Severity: Medium

CVSS Score: 5.5 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/E:P/S:N/AU:Y/R:A/RE:M/U:Amber)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-0636
- https://ossindex.sonatype.org/vulnerability/CVE-2026-0636
- https://github.com/advisories/GHSA-c3fc-8qff-9hwx

Libreria: org.bouncycastle:bcprov-jdk18on <= 1.84

**Descrizione**

[CVE-2026-0636] CWE-90: Improper Neutralization of Special Elements used in an LDAP Query ("LDAP Injection")

Improper neutralization of special elements used in an LDAP query ("LDAP injection") vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcprov on all (prov modules). This vulnerability is associated with program files LDAPStoreHelper. This issue affects BC-JAVA: from 1.74 before 1.84.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.56 CVE-2026-5588

Data: 2026-04-22

Severity: Medium

CVSS Score: 6.3 (CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N/U:Amber)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-5588
- https://ossindex.sonatype.org/vulnerability/CVE-2026-5588
- https://github.com/advisories/GHSA-wg6q-6289-32hp

Libreria: org.bouncycastle:bcpkix-jdk18on <= 1.84

**Descrizione**

[CVE-2026-5588] CWE-327: Use of a Broken or Risky Cryptographic Algorithm

Use of a Broken or Risky Cryptographic Algorithm vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcpkix on all (pkix modules), Legion of the Bouncy Castle Inc. BCPKIX-FIPS bcpkix on All (pkix modules). This vulnerability is associated with program files JcaContentVerifierProviderBuilder.Java. This issue affects BC-JAVA: from 1.67 before 1.84; BCPKIX-FIPS: from 2.0.6 before 2.0.11, from 2.1.7 before 2.1.11.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.57 GHSA-h8r8-wccr-v5f2, GHSA-cjmm-f4jc-qw8r, GHSA-cj63-jhhr-wcxv

Data: 2026-04-15

Severity: Medium

Riferimenti:

- https://github.com/cure53/DOMPurify/security/advisories/GHSA-h8r8-wccr-v5f2
- https://github.com/cure53/DOMPurify/security/advisories/GHSA-cjmm-f4jc-qw8r
- https://github.com/cure53/DOMPurify/security/advisories/GHSA-cj63-jhhr-wcxv
- https://github.com/cure53/DOMPurify/releases/tag/3.3.2

Libreria: DOMPurify < 3.3.2 (bundlato in org.webjars:swagger-ui:5.24.1-1)

**Descrizione**

Tre vulnerabilità di tipo XSS nella libreria JavaScript DOMPurify versione 3.2.4, inclusa come dipendenza transitiva nel bundle JavaScript di swagger-ui (swagger-ui-bundle.js):

1. [GHSA-h8r8-wccr-v5f2] mXSS via Re-Contextualization: l'HTML sanitizzato con DOMPurify.sanitize() può mutare in markup eseguibile quando viene reinserito in un nuovo contesto di parsing tramite innerHTML con wrapper speciali (script, xmp, iframe, noembed, noframes, noscript). Reported by Fluid Attacks.
2. [GHSA-cjmm-f4jc-qw8r] URI Validation Bypass: utilizzando ADD_ATTR come funzione predicato tramite EXTRA_ELEMENT_HANDLING.attributeCheck, un attaccante può far sopravvivere URL con protocollo javascript: bypassando la validazione URI di DOMPurify, causando DOM-based XSS. Identified by Cantina's Apex.
3. [GHSA-cj63-jhhr-wcxv] Prototype Pollution Bypass: quando USE_PROFILES è abilitato, ALLOWED_ATTR viene ricostruito come array. Se Array.prototype è inquinato (es. Array.prototype.onclick = true), DOMPurify accetta event handler pericolosi normalmente vietati, causando DOM-based XSS. Identified by Cantina's Apex.

Tutte e tre le vulnerabilità sono state risolte in DOMPurify 3.3.2.

**GovWay**

La libreria swagger-ui è presente nei WAR govwayAPIConfig e govwayAPIMonitor solamente se la funzionalità Swagger UI è stata abilitata in fase di build (parametro enableSwaggerUi=true). Di default la funzionalità non è abilitata e la libreria non è inclusa nei WAR distribuiti.

Versione affette:

- 3.3.x: <= 3.3.19.p1 (solo se Swagger UI abilitato)
- 3.4.x: <= 3.4.2.p1 (solo se Swagger UI abilitato)

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.58 CVE-2026-34481

Data: 2026-04-15

Severity: Medium

CVSS Score: 6.3 (CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-34481
- https://ossindex.sonatype.org/vulnerability/CVE-2026-34481
- https://github.com/advisories/GHSA-w35j-pv5h-q9q9

Libreria: org.apache.logging.log4j:log4j-layout-template-json <= 2.25.3

**Descrizione**

[CVE-2026-34481] CWE-116: Improper Encoding or Escaping of Output

Apache Log4j's JsonTemplateLayout https://logging.apache.org/log4j/2.x/manual/json-template-layout.html , in versions up to and including 2.25.3, produces invalid JSON output when log events contain non-finite floating-point values (NaN, Infinity, or -Infinity), which are prohibited by RFC 8259. This may cause downstream log processing systems to reject or fail to index affected records. An attacker can exploit this issue only if both of the following conditions are met: * The application uses JsonTemplateLayout. * The application logs a MapMessage containing an attacker-controlled floating-point value. Users are advised to upgrade to Apache Log4j JSON Template Layout 2.25.4, which corrects this issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.59 CVE-2026-34479

Data: 2026-04-15

Severity: Medium

CVSS Score: 6.9 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-34479
- https://ossindex.sonatype.org/vulnerability/CVE-2026-34479
- https://github.com/advisories/GHSA-h383-gmxw-35v2

Libreria: org.apache.logging.log4j:log4j-1.2-api <= 2.25.3

**Descrizione**

[CVE-2026-34479] CWE-116: Improper Encoding or Escaping of Output

The Log4j1XmlLayout from the Apache Log4j 1-to-Log4j 2 bridge fails to escape characters forbidden by the XML 1.0 standard, producing malformed XML output. Conforming XML parsers are required to reject documents containing

such characters with a fatal error, which may cause downstream log processing systems to drop or fail to index affected records. Two groups of users are affected: * Those using Log4j1XmlLayout directly in a Log4j Core 2 configuration file. * Those using the Log4j 1 configuration compatibility layer with org.apache.log4j.xml.XMLLayout specified as the layout class. Users are advised to upgrade to Apache Log4j 1-to-Log4j 2 bridge version 2.25.4, which corrects this issue. Note: The Apache Log4j 1-to-Log4j 2 bridge is deprecated and will not be present in Log4j 3. Users are encouraged to consult the Log4j 1 to Log4j 2 migration guide https://logging.apache.org/log4j/2.x/migrate-from-log4j1.html , and specifically the section on eliminating reliance on the bridge.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.60 CVE-2026-34480

Data: 2026-04-15

Severity: Medium

CVSS Score: 6.9 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-34480
- https://ossindex.sonatype.org/vulnerability/CVE-2026-34480
- https://github.com/advisories/GHSA-3pxv-7cmr-fjr4

Libreria: org.apache.logging.log4j:log4j-core <= 2.25.3

**Descrizione**

[CVE-2026-34480] CWE-116: Improper Encoding or Escaping of Output

Apache Log4j Core's XmlLayout https://logging.apache.org/log4j/2.x/manual/layouts.html#XmlLayout , in versions up to and including 2.25.3, fails to sanitize characters forbidden by the XML 1.0 specification https://www.w3.org/TR/xml/#charsets producing invalid XML output whenever a log message or MDC value contains such characters. The impact depends on the StAX implementation in use: * JRE built-in StAX: Forbidden characters are silently written to the output, producing malformed XML. Conforming parsers must reject such documents with a fatal error, which may cause downstream log-processing systems to drop the affected records. * Alternative StAX implementations (e.g., Woodstox https://github.com/FasterXML/woodstox , a transitive dependency of the Jackson XML Dataformat module): An exception is thrown during the logging call, and the log event is never delivered to its intended appender, only to Log4j's internal status logger. Users are advised to upgrade to Apache Log4j Core 2.25.4, which corrects this issue by sanitizing forbidden characters before XML output.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20

- 3.4.x: 3.4.3

### 2.1.61 CVE-2026-34478

Data: 2026-04-15

Severity: Medium

CVSS Score: 6.9 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-34478
- https://ossindex.sonatype.org/vulnerability/CVE-2026-34478
- https://github.com/advisories/GHSA-445c-vh5m-36rj

Libreria: org.apache.logging.log4j:log4j-core <= 2.25.3

**Descrizione**

[CVE-2026-34478] CWE-117: Improper Output Neutralization for Logs

Apache Log4j Core's Rfc5424Layout https://logging.apache.org/log4j/2.x/manual/layouts.html#RFC5424Layout , in versions 2.21.0 through 2.25.3, is vulnerable to log injection via CRLF sequences due to undocumented renames of security-relevant configuration attributes. Two distinct issues affect users of stream-based syslog services who configure Rfc5424Layout directly: * The newLineEscape attribute was silently renamed, causing newline escaping to stop working for users of TCP framing (RFC 6587), exposing them to CRLF injection in log output. * The useTlsMessageFormat attribute was silently renamed, causing users of TLS framing (RFC 5425) to be silently downgraded to unframed TCP (RFC 6587), without newline escaping. Users of the SyslogAppender are not affected, as its configuration attributes were not modified. Users are advised to upgrade to Apache Log4j Core 2.25.4, which corrects this issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.62 CVE-2026-34477

Data: 2026-04-15

Severity: Medium

CVSS Score: 6.3 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:L/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-34477
- https://ossindex.sonatype.org/vulnerability/CVE-2026-34477
- https://github.com/advisories/GHSA-6hg6-v5c8-fphq

Libreria: org.apache.logging.log4j:log4j-core <= 2.25.3

**Descrizione**

[CVE-2026-34477] CWE-297: Improper Validation of Certificate with Host Mismatch

The fix for CVE-2025-68161 https://logging.apache.org/security.html#CVE-2025-68161 was incomplete: it addressed hostname verification only when enabled via the log4j2.sslVerifyHostName https://logging.apache.org/log4j/2.x/manual/systemproperties.html#log4j2.sslVerifyHostName system property, but not when configured through the verifyHostName https://logging.apache.org/log4j/2.x/manual/appenders/network.html#SslConfiguration-attr-verifyHostName attribute of the <Ssl> element. Although the verifyHostName configuration attribute was introduced in Log4j Core 2.12.0, it was silently ignored in all versions through 2.25.3, leaving TLS connections vulnerable to interception regardless of the configured value. A network-based attacker may be able to perform a man-in-the-middle attack when all of the following conditions are met: * An SMTP, Socket, or Syslog appender is in use. * TLS is configured via a nested <Ssl> element. * The attacker can present a certificate issued by a CA trusted by the appender's configured trust store, or by the default Java trust store if none is configured. This issue does not affect users of the HTTP appender, which uses a separate verifyHostname https://logging.apache.org/log4j/2.x/manual/appenders/network.html#HttpAppender-attr-verifyHostName attribute that was not subject to this bug and verifies host names by default. Users are advised to upgrade to Apache Log4j Core 2.25.4, which corrects this issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.63 CVE-2026-33871

Data: 2026-04-02

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-33871
- https://ossindex.sonatype.org/vulnerability/CVE-2026-33871
- https://github.com/netty/netty/security/advisories/GHSA-w9fj-cfpg-grvv

Libreria: io.netty:netty-transport <= 4.1.132.Final e <= 4.2.10.Final

**Descrizione**

CWE-770: Allocation of Resources Without Limits or Throttling

Netty is an asynchronous, event-driven network application framework. In versions prior to 4.1.132.Final and 4.2.10.Final, a remote user can trigger a Denial of Service (DoS) against a Netty HTTP/2 server by sending a flood of *CONTINUATION* frames. The server's lack of a limit on the number of *CONTINUATION* frames, combined with a bypass of existing size-based mitigations using zero-byte frames, allows an user to cause excessive CPU consumption with minimal bandwidth, rendering the server unresponsive. Versions 4.1.132.Final and 4.2.10.Final fix the issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.64 CVE-2026-33870

Data: 2026-04-02

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-33870
- https://ossindex.sonatype.org/vulnerability/CVE-2026-33870
- https://github.com/netty/netty/security/advisories/GHSA-pwqr-wmgm-9rr8

Libreria: io.netty:netty-transport <= 4.1.132.Final e <= 4.2.10.Final

**Descrizione**

CWE-444: Inconsistent Interpretation of HTTP Requests ("HTTP Request Smuggling")

Netty is an asynchronous, event-driven network application framework. In versions prior to 4.1.132.Final and 4.2.10.Final, Netty incorrectly parses quoted strings in HTTP/1.1 chunked transfer encoding extension values, enabling request smuggling attacks. Versions 4.1.132.Final and 4.2.10.Final fix the issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.65 CVE-2026-22732

Data: 2026-03-20

Severity: Critical

CVSS Score: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)

**Nota**

La severity e il CVSS Score si riferiscono alla vulnerabilità della libreria; come descritto nella sezione **GovWay** la vulnerabilità non si manifesta nel prodotto.

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-22732
- https://ossindex.sonatype.org/vulnerability/CVE-2026-22732
- https://spring.io/security/cve-2025-41242

Libreria: org.springframework.security:spring-security-core <= 5.8.23 e <= 6.5.8

**Descrizione**

CWE-425: Direct Request ("Forced Browsing")

When applications specify HTTP response headers for servlet applications using Spring Security, there is the possibility that the HTTP Headers will not be written. This issue affects Spring Security: from 5.7.0 through 5.7.21, from 5.8.0 through 5.8.23, from 6.3.0 through 6.3.14, from 6.4.0 through 6.4.14, from 6.5.0 through 6.5.8, from 7.0.0 through 7.0.3.

**GovWay**

La vulnerabilità interessa la gestione degli header HTTP nelle response delle applicazioni servlet protette da Spring Security. In GovWay la filter chain di Spring Security, che include la gestione degli header HTTP, è attiva esclusivamente nelle API di configurazione e monitoraggio. La documentazione fornisce indicazioni su come rendere fruibili tali API non direttamente ma tramite erogazioni di GovWay stesso, che gestisce autonomamente gli header delle risposte verso il chiamante. Per questo motivo la vulnerabilità non si manifesta.

Versione affette:

- 3.3.x: <= 3.3.19.p1
- 3.4.x: <= 3.4.2.p1

Risoluzione:

- 3.3.x: 3.3.20
- 3.4.x: 3.4.3

### 2.1.66 GHSA-72hv-8253-57qq

Data: 2026-03-08

Severity: High

CVSS Score: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N)

Riferimenti:

- https://github.com/advisories/GHSA-72hv-8253-57qq

Libreria: com.fasterxml.jackson.core:jackson-core <= 2.18.5 e < < 2.21.1

**Descrizione**

CWE-770 Allocation of Resources Without Limits or Throttling

The non-blocking (async) JSON parser in jackson-core bypasses the maxNumberLength constraint (default: 1000 characters) defined in StreamReadConstraints. This allows an attacker to send JSON with arbitrarily long numbers through the async parser API, leading to excessive memory allocation and potential CPU exhaustion, resulting in a Denial of Service (DoS).

The standard synchronous parser correctly enforces this limit, but the async parser fails to do so, creating an inconsistent enforcement policy.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.19
- 3.4.x: <= 3.4.2

Risoluzione:

- 3.3.x: 3.3.19.p1
- 3.4.x: 3.4.2.p1

### 2.1.67 CVE-2025-67735

Data: 2026-01-06

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-67735
- https://ossindex.sonatype.org/vulnerability/CVE-2025-67735
- https://github.com/netty/netty/security/advisories/GHSA-84h7-rjj3-6jx4

Libreria: io.netty:netty-transport < 4.1.129.Final e < 4.2.8.Final

**Descrizione**

[CVE-2025-67735] CWE-93: Improper Neutralization of CRLF Sequences ("CRLF Injection")

Netty is an asynchronous, event-driven network application framework. In versions prior to 4.1.129.Final and 4.2.8.Final, the *io.netty.handler.codec.http.HttpRequestEncoder* has a CRLF injection with the request URI when constructing a request. This leads to request smuggling when *HttpRequestEncoder* is used without proper sanitization of the URI. Any application / framework using *HttpRequestEncoder* can be subject to be abused to perform request smuggling using CRLF injection. Versions 4.1.129.Final and 4.2.8.Final fix the issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.18
- 3.4.x: <= 3.4.1.p1

Risoluzione:

- 3.3.x: 3.3.19
- 3.4.x: 3.4.2

## 2.2 Avvisi di Sicurezza 2025

- *CVE-2025-68161*
- *CVE-2025-66453*
- *CWE-200*
- *CWE-307*
- *CWE-384*
- *CVE-2025-41248*

- *CVE-2025-41249*
- *CVE-2025-55163, CVE-2025-58057 e CVE-2025-58056*
- *CVE-2025-7962*
- *CVE-2025-41242*
- *CVE-2025-48913*
- *CVE-2025-4949*
- *CVE-2025-8916*
- *CVE-2025-48795*
- *CVE-2025-31672*
- *CVE-2025-48924*
- *CVE-2025-53864*
- *CVE-2025-48976*
- *CVE-2025-48734*
- *CVE-2025-22228*
- *CVE-2025-25193*
- *CVE-2025-23184*
- *CVE-2024-38827*

### 2.2.1 CVE-2025-68161

Data: 2025-12-24

Severity: Medium

CVSS Score: 6.3 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:L/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-68161
- https://ossindex.sonatype.org/vulnerability/CVE-2025-68161
- https://github.com/advisories/GHSA-vc5p-v9hr-52mj

Libreria: org.apache.logging.log4j:log4j-core <= 2.25.2

**Descrizione**

[CVE-2025-68161] CWE-297: Improper Validation of Certificate with Host Mismatch

The Socket Appender in Apache Log4j Core versions 2.0-beta9 through 2.25.2 does not perform TLS hostname verification of the peer certificate, even when the verifyHostName https://logging.apache.org/log4j/2.x/manual/appenders/network.html#SslConfiguration-attr-verifyHostName configuration attribute or the log4j2.sslVerifyHostName https://logging.apache.org/log4j/2.x/manual/systemproperties.html#log4j2.sslVerifyHostName system property is set to true. This issue may allow a man-in-the-middle attacker to intercept or redirect log traffic under the following conditions: * The attacker is able to intercept or redirect network traffic between the client and the log receiver. * The attacker can present a server certificate issued by a certification authority trusted by the Socket Appender's configured trust store (or by the default Java trust store if no custom trust store is configured). Users are advised to upgrade to Apache Log4j Core version 2.25.3, which addresses this issue. As an alternative mitigation, the Socket Appender may be configured to use a private or restricted trust root to limit the set of trusted certificates.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.18
- 3.4.x: <= 3.4.1.p1

Risoluzione:

- 3.3.x: 3.3.19
- 3.4.x: 3.4.2

### 2.2.2 CVE-2025-66453

Data: 2025-12-09

Severity: Medium

CVSS Score: 5.5 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N/E:P)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-66453
- https://ossindex.sonatype.org/vulnerability/CVE-2025-66453
- https://github.com/advisories/GHSA-3w8q-xq97-5j7x

Libreria: org.mozilla:rhino < 1.7.14.1 o = 1.8.0

**Descrizione**

[CVE-2025-66453] CWE-400: Uncontrolled Resource Consumption (“Resource Exhaustion”)

Rhino is an open-source implementation of JavaScript written entirely in Java. Prior to 1.8.1, 1.7.15.1, and 1.7.14.1, when an application passed an attacker controlled float poing number into the toFixed() function, it might lead to high CPU consumption and a potential Denial of Service. Small numbers go through this call stack: NativeNumber.numTo > DToA.JS_dtostr > DToA.JS_dtoa > DToA.pow5mult where pow5mult attempts to raise 5 to a ridiculous power. This vulnerability is fixed in 1.8.1, 1.7.15.1, and 1.7.14.1.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.18
- 3.4.x: <= 3.4.1

Risoluzione:

- 3.3.x: 3.3.19
- 3.4.x: 3.4.2

### 2.2.3 CWE-200

Data: 2025-10-06

Severity: None

CVSS Score: 0.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N)

Riferimenti:

- https://cwe.mitre.org/data/definitions/200.html

Componenti: govwayConsole e govwayMonitor

**Descrizione**

[Information Exposure]

Esposizione delle Versioni delle Librerie Frontend

Attraverso strumenti di analisi passiva o l'ispezione del codice sorgente, è possibile identificare le versioni specifiche delle librerie JavaScript client-side utilizzate.

**GovWay**

Versione affette:

- 3.3.x: *
- 3.4.x: <= 3.4.0

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.1

### 2.2.4 CWE-307

Data: 2025-10-06

Severity: Medium

CVSS Score: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

Riferimenti:

- https://cwe.mitre.org/data/definitions/307.html

Componenti: govwayConsole, govwayMonitor, govwayAPIConfig, govwayAPIMonitor

**Descrizione**

[Brute Force]

The product does not implement sufficient measures to prevent multiple failed authentication attempts within a short time frame.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: <= 3.4.0

Risoluzione:

- 3.3.x: 3.3.18
- 3.4.x: 3.4.1

### 2.2.5 CWE-384

Data: 2025-10-06

Severity: Medium

CVSS Score: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

Riferimenti:

- https://cwe.mitre.org/data/definitions/384.html

Componenti: govwayConsole e govwayMonitor

**Descrizione**

[Session Fixation]

Authenticating a user, or otherwise establishing a new user session, without invalidating any existing session identifier gives an attacker the opportunity to steal authenticated sessions.

Such a scenario is commonly observed when:

- A web application authenticates a user without first invalidating the existing session, thereby continuing to use the session already associated with the user.
- An attacker is able to force a known session identifier on a user so that, once the user authenticates, the attacker has access to the authenticated session.
- The application or container uses predictable session identifiers.

In the generic exploit of session fixation vulnerabilities, an attacker creates a new session on a web application and records the associated session identifier. The attacker then causes the victim to associate, and possibly authenticate, against the server using that session identifier, giving the attacker access to the user's account through the active session.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: <= 3.4.0

Risoluzione:

- 3.3.x: 3.3.18
- 3.4.x: 3.4.1

### 2.2.6 CVE-2025-41248

Data: 2025-09-18

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-41248
- https://ossindex.sonatype.org/vulnerability/CVE-2025-41248
- https://spring.io/security/cve-2025-41248

Libreria: org.springframework.security:spring-security-core <= 6.5.4

**Descrizione**

The Spring Security annotation detection mechanism may not correctly resolve annotations on methods within type hierarchies with a parameterized super type with unbounded generics. This can be an issue when using @PreAuthorize and other method security annotations, resulting in an authorization bypass. Your application may be affected by this if you are using Spring Security's @EnableMethodSecurity feature. You are not affected by this if you are not using @EnableMethodSecurity or if you do not use security annotations on methods in generic superclasses or generic interfaces.

This CVE is published in conjunction with CVE-2025-41249 https://spring.io/security/cve-2025-41249 .

**GovWay**

Versione affette:

- 3.3.x: -
- 3.4.x: <= 3.4.0

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.1

### 2.2.7 CVE-2025-41249

Data: 2025-09-18

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-41249
- https://ossindex.sonatype.org/vulnerability/CVE-2025-41249
- https://spring.io/security/cve-2025-41249

Libreria: org.springframework:spring-core <= 5.3.44 e <= 6.2.10

**Descrizione**

The Spring Framework annotation detection mechanism may not correctly resolve annotations on methods within type hierarchies with a parameterized super type with unbounded generics. This can be an issue if such annotations are used for authorization decisions. Your application may be affected by this if you are using Spring Security's @EnableMethodSecurity feature. You are not affected by this if you are not using @EnableMethodSecurity or if you do not use security annotations on methods in generic superclasses or generic interfaces.

This CVE is published in conjunction with CVE-2025-41248 https://spring.io/security/cve-2025-41248.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: <= 3.4.0

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.1

### 2.2.8 CVE-2025-55163, CVE-2025-58057 e CVE-2025-58056

Data: 2025-09-12

Severity: High

CVSS Score: 8.2 (CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N)

Riferimenti:

- (High) https://nvd.nist.gov/vuln/detail/CVE-2025-55163

- (Medium) https://nvd.nist.gov/vuln/detail/CVE-2025-58057
- (Low) https://nvd.nist.gov/vuln/detail/CVE-2025-58056

Libreria: io.netty:netty-transport <= 4.1.125.Final

**Descrizione**

- CVE-2025-55163

  Netty is an asynchronous, event-driven network application framework. Prior to versions 4.1.124.Final and 4.2.4.Final, Netty is vulnerable to MadeYouReset DDoS. This is a logical vulnerability in the HTTP/2 protocol, that uses malformed HTTP/2 control frames in order to break the max concurrent streams limit - which results in resource exhaustion and distributed denial of service. This issue has been patched in versions 4.1.124.Final and 4.2.4.Final.

- CVE-2025-58057

  Netty is an asynchronous event-driven network application framework for rapid development of maintainable high performance protocol servers & clients. In netty-codec-compression versions 4.1.124.Final and below, and netty-codec versions 4.2.4.Final and below, when supplied with specially crafted input, BrotliDecoder and certain other decompression decoders will allocate a large number of reachable byte buffers, which can lead to denial of service. BrotliDecoder.decompress has no limit in how often it calls pull, decompressing data 64K bytes at a time. The buffers are saved in the output list, and remain reachable until OOM is hit. This is fixed in versions 4.1.125.Final of netty-codec and 4.2.5.Final of netty-codec-compression.

- CVE-2025-58056

  Netty is an asynchronous event-driven network application framework for development of maintainable high performance protocol servers and clients. In versions 4.1.124.Final, and 4.2.0.Alpha3 through 4.2.4.Final, Netty incorrectly accepts standalone newline characters (LF) as a chunk-size line terminator, regardless of a preceding carriage return (CR), instead of requiring CRLF per HTTP/1.1 standards. When combined with reverse proxies that parse LF differently (treating it as part of the chunk extension), attackers can craft requests that the proxy sees as one request but Netty processes as two, enabling request smuggling attacks. This is fixed in versions 4.1.125.Final and 4.2.5.Final.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: <= 3.4.0

Risoluzione:

- 3.3.x: 3.3.18
- 3.4.x: 3.4.1

### 2.2.9 CVE-2025-7962

Data: 2025-08-26

Severity: Medium

CVSS Score: 6.0 (CVSS:4.0/AV:N/AC:H/AT:N/PR:L/UI:N/VC:N/VI:H/VA:N/SC:N/SI:L/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-7962
- https://ossindex.sonatype.org/vulnerability/CVE-2025-7962
- https://github.com/advisories/GHSA-9342-92gg-6v29

Libreria: org.eclipse.angus:angus-mail < 2.0.4

**Descrizione**

In Jakarta Mail 2.0.2 it is possible to preform a SMTP Injection by utilizing the r and n UTF-8 characters to separate different messages.

**GovWay**

Versione affette:

- 3.4.x: <= 3.4.0

Risoluzione:

- 3.4.x: 3.4.1

### 2.2.10 CVE-2025-41242

Data: 2025-08-26

Severity: Medium

CVSS Score: 5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-41242
- https://ossindex.sonatype.org/vulnerability/CVE-2025-41242
- https://spring.io/security/cve-2025-41242

Libreria: org.springframework:spring-core <= 5.3.43 e <= 6.2.9

**Descrizione**

Spring Framework MVC applications can be vulnerable to a "Path Traversal Vulnerability" when deployed on a non-compliant Servlet container. An application can be vulnerable when all the following are true:

- the application is deployed as a WAR or with an embedded Servlet container
- the Servlet container does not reject suspicious sequences https://jakarta.ee/specifications/servlet/6.1/jakarta-servlet-spec-6.1.html#uri-path-canonicalization
- the application serves static resources https://docs.spring.io/spring-framework/reference/web/webmvc/mvc-config/static-resources.html#page-title with Spring resource handling

We have verified that applications deployed on Apache Tomcat or Eclipse Jetty are not vulnerable, as long as default security features are not disabled in the configuration. Because we cannot check exploits against all Servlet containers and configuration variants, we strongly recommend upgrading your application.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: <= 3.4.0

Risoluzione:

- 3.3.x: -
- 3.4.x: 3.4.1

### 2.2.11 CVE-2025-48913

Data: 2025-08-26

Severity: Critical

CVSS Score: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-48913
- https://ossindex.sonatype.org/vulnerability/CVE-2025-48913
- https://lists.apache.org/thread/f1nv488ztc0js4g5ml2v88mzkzslyh83

Libreria: org.apache.cxf:* < 3.6.8 o < 4.1.3

**Descrizione**

[CVE-2025-48913] CWE-20: Improper Input Validation

If untrusted users are allowed to configure JMS for Apache CXF, previously they could use RMI or LDAP URLs, potentially leading to code execution capabilities. This interface is now restricted to reject those protocols, removing this possibility.

Users are recommended to upgrade to versions 3.6.8, 4.0.9 or 4.1.3, which fix this issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: <= 3.4.0

Risoluzione:

- 3.3.x: 3.3.18
- 3.4.x: 3.4.1

### 2.2.12 CVE-2025-4949

Data: 2025-08-26

Severity: Medium

CVSS Score: 6.8 (CVSS:4.0/AV:N/AC:H/AT:N/PR:L/UI:A/VC:H/VI:N/VA:N/SC:H/SI:N/SA:N/S:N/AU:Y/R:U/V:D/RE:L/U:Green)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-4949
- https://ossindex.sonatype.org/vulnerability/CVE-2025-4949

Libreria: org.eclipse.jgit:org.eclipse.jgit <= 7.2.0.202503040940-r

**Descrizione**

[CVE-2025-4949] CWE-611: Improper Restriction of XML External Entity Reference ("XXE")

In Eclipse JGit versions 7.2.0.202503040940-r and older, the ManifestParser class used by the repo command and the AmazonS3 class used to implement the experimental amazons3 git transport protocol allowing to store git pack files in an Amazon S3 bucket, are vulnerable to XML External Entity (XXE) attacks when parsing XML files. This vulnerability can lead to information disclosure, denial of service, and other security issues.

**GovWay**

Versione affette:

- 3.4.x: <= 3.4.0

Risoluzione:

- 3.4.x: 3.4.1

### 2.2.13 CVE-2025-8916

Data: 2025-08-26

Severity: Medium

CVSS Score: 6.3 (CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N/S:P/R:U/RE:M/U:Amber)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-8916
- https://ossindex.sonatype.org/vulnerability/CVE-2025-8916
- https://github.com/advisories/GHSA-4cx2-fc23-5wg6

Libreria: org.bouncycastle:bcpkix-jdk18on < 1.79

**Descrizione**

[CVE-2025-8916] CWE-770: Allocation of Resources Without Limits or Throttling

Allocation of Resources Without Limits or Throttling vulnerability in Legion of the Bouncy Castle Inc. Bouncy Castle for Java bcpkix, bcprov, bcpkix-fips on All (API modules) allows Excessive Allocation. This vulnerability is associated with program files https://github.Com/bcgit/bc-java/blob/main/pkix/src/main/java/org/bouncycastle/pkix/jcajce/PKIXCertP… https://github.Com/bcgit/bc-java/blob/main/pkix/src/main/java/org/bouncycastle/pkix/jcajce/PKIXCertPathReviewer.java , https://github.Com/bcgit/bc-java/blob/main/prov/src/main/java/org/bouncycastle/x509/PKIXCertPathRevi… https://github.Com/bcgit/bc-java/blob/main/prov/src/main/java/org/bouncycastle/x509/PKIXCertPathReviewer.java .

This issue affects Bouncy Castle for Java: from BC 1.44 through 1.78, from BCPKIX FIPS 1.0.0 through 1.0.7, from BCPKIX FIPS 2.0.0 through 2.0.7.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: nessuna

Risoluzione:

- 3.3.x: 3.3.18
- 3.4.x: >= 3.4.0

### 2.2.14 CVE-2025-48795

Data: 2025-07-21

Severity: High

CVSS Score: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-48795

- https://ossindex.sonatype.org/vulnerability/CVE-2025-48795
- https://lists.apache.org/thread/vo5qv02mvv5plmb6z2xf1ktjmrpv3jmn

Libreria: org.apache.cxf:cxf-core < 3.6.6 e < 4.1.1

**Descrizione**

[CVE-2025-48795] CWE-400: Uncontrolled Resource Consumption ("Resource Exhaustion")

Apache CXF stores large stream based messages as temporary files on the local filesystem. A bug was introduced which means that the entire temporary file is read into memory and then logged. An attacker might be able to exploit this to cause a denial of service attack by causing an out of memory exception. In addition, it is possible to configure CXF to encrypt temporary files to prevent sensitive credentials from being cached unencrypted on the local filesystem, however this bug means that the cached files are written out to logs unencrypted. Users are recommended to upgrade to versions 3.5.11, 3.6.6, 4.0.7 or 4.1.1, which fixes this issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: nessuna

Risoluzione:

- 3.3.x: 3.3.18
- 3.4.x: >= 3.4.0

### 2.2.15 CVE-2025-31672

Data: 2025-07-21

Severity: Medium

CVSS Score: 6.9 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-31672
- https://ossindex.sonatype.org/vulnerability/CVE-2025-31672
- https://www.openwall.com/lists/oss-security/2025/04/08/2

Libreria: org.apache.poi:poi < 5.4.0

**Descrizione**

[CVE-2025-31672] CWE-20: Improper Input Validation

Improper Input Validation vulnerability in Apache POI. The issue affects the parsing of OOXML format files like xlsx, docx and pptx. These file formats are basically zip files and it is possible for malicious users to add zip entries with duplicate names (including the path) in the zip. In this case, products reading the affected file could read different data because 1 of the zip entries with the duplicate name is selected over another but different products may choose a different zip entry. This issue affects Apache POI poi-ooxml before 5.4.0. poi-ooxml 5.4.0 has a check that throws an exception if zip entries with duplicate file names are found in the input file. Users are recommended to upgrade to version poi-ooxml 5.4.0, which fixes the issue. Please read https://poi.apache.org/security.html for recommendations about how to use the POI libraries securely.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17

- 3.4.x: nessuna

Risoluzione:

- 3.3.x: 3.3.18
- 3.4.x: >= 3.4.0

### 2.2.16 CVE-2025-48924

Data: 2025-05-30

Severity: Medium

CVSS Score: 6.9 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-48924
- https://ossindex.sonatype.org/vulnerability/CVE-2025-48924
- https://github.com/advisories/GHSA-j288-q9x7-2f5v

Librerie:

- org.apache.commons:commons-lang3 < 3.18.0
- commons-lang:commons-lang <= 2.6

**Descrizione**

Uncontrolled Recursion vulnerability in Apache Commons Lang. This issue affects Apache Commons Lang: Starting with commons-lang:commons-lang 2.0 to 2.6, and, from org.apache.commons:commons-lang3 3.0 before 3.18.0. The methods ClassUtils.getClass(...) can throw StackOverflowError on very long inputs. Because an Error is usually not handled by applications and libraries, a StackOverflowError could cause an application to stop. Users are recommended to upgrade to version 3.18.0, which fixes the issue.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: 3.4.0 solamente per l'artefatto "commons-lang:commons-lang"

Risoluzione:

- 3.3.x: 3.3.18 per org.apache.commons:commons-lang3
- 3.4.x: 3.4.1

### 2.2.17 CVE-2025-53864

Data: 2025-07-12

Severity: Medium

CVSS Score: 5.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:L)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-53864
- https://ossindex.sonatype.org/vulnerability/CVE-2025-53864
- https://github.com/advisories/GHSA-xwmg-2g98-w7v9

Libreria: com.nimbusds:nimbus-jose-jwt < 10.0.2

**Descrizione**

[CVE-2025-53864] CWE-674: Uncontrolled Recursion

Connect2id Nimbus JOSE + JWT before 10.0.2 allows a remote attacker to cause a denial of service via a deeply nested JSON object supplied in a JWT claim set, because of uncontrolled recursion. NOTE: this is independent of the Gson 2.11.0 issue because the Connect2id product could have checked the JSON object nesting depth, regardless of what limits (if any) were imposed by Gson.

**GovWay**

Versione affette:

- 3.3.x: <= 3.3.17
- 3.4.x: nessuna

Risoluzione:

- 3.3.x: 3.3.18
- 3.4.x: >= 3.4.0

### 2.2.18 CVE-2025-48976

Data: 2025-06-20

Severity: High

CVSS Score: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-48976
- https://ossindex.sonatype.org/vulnerability/CVE-2025-48976
- https://github.com/advisories/GHSA-vv7r-c36w-3prj

Libreria: commons-fileupload:commons-fileupload < 1.6.0

**Descrizione**

[CVE-2025-48976] CWE-770: Allocation of Resources Without Limits or Throttling

Allocation of resources for multipart headers with insufficient limits enabled a DoS vulnerability in Apache Commons FileUpload.

This issue affects Apache Commons FileUpload: from 1.0 before 1.6; from 2.0.0-M1 before 2.0.0-M4.

Users are recommended to upgrade to versions 1.6 or 2.0.0-M4, which fix the issue.

**GovWay**

Versione affette: <= 3.3.16.p2

Risoluzione: 3.3.17

### 2.2.19 CVE-2025-48734

Data: 2025-05-30

Severity: High

CVSS Score: 8.8 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-48734
- https://ossindex.sonatype.org/vulnerability/CVE-2025-48734
- https://github.com/advisories/GHSA-wxr5-93ph-8wr9

Libreria: commons-beanutils:commons-beanutils < 1.11.0

**Descrizione**

[CVE-2025-48734] CWE-284: Improper Access Control

Improper Access Control vulnerability in Apache Commons. A special BeanIntrospector class was added in version 1.9.2. This can be used to stop attackers from using the declared class property of Java enum objects to get access to the classloader. However this protection was not enabled by default. PropertyUtilsBean (and consequently BeanUtilsBean) now disallows declared class level property access by default. Releases 1.11.0 and 2.0.0-M2 address a potential security issue when accessing enum properties in an uncontrolled way. If an application using Commons BeanUtils passes property paths from an external source directly to the getProperty() method of PropertyUtilsBean, an attacker can access the enum's class loader via the "declaredClass" property available on all Java "enum" objects. Accessing the enum's "declaredClass" allows remote attackers to access the ClassLoader and execute arbitrary code. The same issue exists with PropertyUtilsBean.getNestedProperty(). Starting in versions 1.11.0 and 2.0.0-M2 a special BeanIntrospector suppresses the "declaredClass" property. Note that this new BeanIntrospector is enabled by default, but you can disable it to regain the old behavior; see section 2.5 of the user's guide and the unit tests. This issue affects Apache Commons BeanUtils 1.x before 1.11.0, and 2.x before 2.0.0-M2.Users of the artifact commons-beanutils:commons-beanutils 1.x are recommended to upgrade to version 1.11.0, which fixes the issue. Users of the artifact org.apache.commons:commons-beanutils2 2.x are recommended to upgrade to version 2.0.0-M2, which fixes the issue.

**GovWay**

Versione affette: <= 3.3.16.p2

Risoluzione: 3.3.17

### 2.2.20 CVE-2025-22228

Data: 2025-03-20

Severity: High

CVSS Score: 7.4 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-22228
- https://ossindex.sonatype.org/vulnerability/CVE-2025-22228
- https://spring.io/security/cve-2025-22228

Libreria: org.springframework.security:spring-security-crypto <= 5.8.17

**Descrizione**

CWE-287: Improper Authentication

BCryptPasswordEncoder.matches(CharSequence,String) will incorrectly return true for passwords larger than 72 characters as long as the first 72 characters are the same.

**GovWay**

Versione affette: <= 3.3.16

Risoluzione: 3.3.16.p1

### 2.2.21 CVE-2025-25193

Data: 2025-02-13

Severity: Medium

CVSS Score: 5.5 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-25193
- https://ossindex.sonatype.org/vulnerability/CVE-2025-25193
- https://github.com/netty/netty/security/advisories/GHSA-389x-839f-4rhx

Libreria: io.netty:netty-common < 4.1.118.Final

**Descrizione**

CWE-400: Uncontrolled Resource Consumption ("Resource Exhaustion")

Netty, an asynchronous, event-driven network application framework, has a vulnerability in versions up to and including 4.1.118.Final. An unsafe reading of environment file could potentially cause a denial of service in Netty. When loaded on an Windows application, Netty attempts to load a file that does not exist. If an attacker creates such a large file, the Netty application crash. A similar issue was previously reported as CVE-2024-47535. This issue was fixed, but the fix was incomplete in that null-bytes were not counted against the input limit. Commit d1fbda62d3a47835d3fb35db8bd42ecc205a5386 contains an updated fix.

**GovWay**

Versione affette: <= 3.3.16

Risoluzione: 3.3.16.p1

### 2.2.22 CVE-2025-23184

Data: 2025-01-22

Severity: Medium

CVSS Score: 5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-23184
- https://ossindex.sonatype.org/vulnerability/CVE-2025-23184
- https://cxf.apache.org/security-advisories.data/CVE-2025-23184.txt

Libreria: org.apache.cxf:cxf-core < 3.6.5

**Descrizione**

CWE-400: Uncontrolled Resource Consumption ("Resource Exhaustion")

A potential denial of service vulnerability is present in versions of Apache CXF before 3.5.10, 3.6.5 and 4.0.6.

In some edge cases, the CachedOutputStream instances may not be closed and, if backed by temporary files, may fill up the file system (it applies to servers and clients).

**GovWay**

Versione affette: <= 3.3.15.p2

Risoluzione: 3.3.16

### 2.2.23 CVE-2024-38827

Data: 2025-01-12

Severity: Medium

CVSS Score: 4.8 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-38827
- https://ossindex.sonatype.org/vulnerability/CVE-2024-38827
- https://spring.io/security/cve-2024-38827

Libreria: org.springframework.security:spring-security-* < 5.8.16

**Descrizione**

CWE-639: Authorization Bypass Through User-Controlled Key

Spring Security Authorization Bypass for Case Sensitive Comparisons

The usage of String.toLowerCase() and String.toUpperCase() has some Locale dependent exceptions that could potentially result in authorization rules not working properly.

**GovWay**

Versione affette: <= 3.3.15.p2

Risoluzione: 3.3.16

## 2.3 Avvisi di Sicurezza 2024

- *CVE-2024-38829*
- *CVE-2024-47535*
- *CVE-2024-38821*
- *CVE-2024-38820*
- *CVE-2024-45772*
- *CVE-2024-47554*
- *CVE-2024-45801*
- *CVE-2024-38809*
- *CVE-2024-38808*
- *CVE-2024-41172*
- *CVE-2024-32007*
- *CVE-2024-31573*
- *CVE-2024-34447*
- *CVE-2024-22262*
- *CVE-2024-30172*
- *CVE-2024-30171*
- *CVE-2024-29857*

- *CVE-2024-22257*
- *CVE-2024-28752*
- *CVE-2024-21742*
- *CVE-2024-22243*
- *CVE-2024-25710*
- *CVE-2023-52428*
- *CVE-2023-51074*

### 2.3.1 CVE-2024-38829

Data: 2024-12-21

Severity: Low

CVSS Score: 3.7 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-38829
- https://ossindex.sonatype.org/vulnerability/CVE-2024-38829
- https://spring.io/security/cve-2024-38829

Libreria: org.springframework.ldap:spring-ldap-core < 2.4.4

**Descrizione**

A vulnerability in Spring LDAP allows data exposure for case sensitive comparisons.

This issue affects Spring LDAP: from 2.4.0 through 2.4.3, from 3.0.0 through 3.0.9, from 3.1.0 through 3.1.7, from 3.2.0 through 3.2.7, AND all versions prior to 2.4.0.

The usage of String.toLowerCase() and String.toUpperCase() has some Locale dependent exceptions that could potentially result in unintended columns from being queried Related to CVE-2024-38820 https://spring.io/security/cve-2024-38820

**GovWay**

Versione affette: <= 3.3.15.p2

Risoluzione: 3.3.16

### 2.3.2 CVE-2024-47535

Data: 2024-11-13

Severity: Medium

CVSS Score: 5.5 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-47535
- https://github.com/netty/netty/security/advisories/GHSA-xq3w-v528-46rv

Libreria: io.netty:netty-common < 4.1.115

**Descrizione**

Netty is an asynchronous event-driven network application framework for rapid development of maintainable high performance protocol servers & clients.

An unsafe reading of environment file could potentially cause a denial of service in Netty.

When loaded on an Windows application, Netty attempts to load a file that does not exist. If an attacker creates such a large file, the Netty application crashes.

This vulnerability is fixed in 4.1.115.

**GovWay**

Versione affette: <= 3.3.15.p2

Risoluzione: 3.3.16

### 2.3.3 CVE-2024-38821

Data: 2024-10-29

Severity: High

CVSS Score: 8.2 (CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-38821
- https://ossindex.sonatype.org/vulnerability/CVE-2024-38821
- https://spring.io/security/cve-2024-38821

Libreria: org.springframework.security:spring-security-web < 5.8.15

**Descrizione**

CWE-770: Allocation of Resources Without Limits or Throttling

Spring WebFlux applications that have Spring Security authorization rules on static resources can be bypassed under certain circumstances.

For this to impact an application, all of the following must be true:

- It must be a WebFlux application
- It must be using Spring's static resources support
- It must have a non-permitAll authorization rule applied to the static resources support

**GovWay**

Versione affette: <= 3.3.15.p1

Risoluzione: 3.3.15.p2

### 2.3.4 CVE-2024-38820

Data: 2024-10-29

Severity: Medium

CVSS Score: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-38820
- https://ossindex.sonatype.org/vulnerability/CVE-2024-38820

- https://spring.io/security/cve-2024-38820

Libreria: org.springframework:* < 5.3.41

**Descrizione**

The fix for CVE-2022-22968 made disallowedFields patterns in DataBinder case insensitive.

However, String.toLowerCase() has some Locale dependent exceptions that could potentially result in fields not protected as expected.

**GovWay**

Versione affette: <= 3.3.15.p1

Risoluzione: 3.3.15.p2

### 2.3.5 CVE-2024-45772

Data: 2024-10-08

Severity: High

CVSS Score: 8.0 (CVSS:3.1/AV:A/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-45772
- https://lists.apache.org/thread/3f3oph7bqnqspb9q5p0gm5mgc1b6thjo

Libreria: org.apache.lucene:lucene-core < 9.12.0

**Descrizione**

CWE-502 Deserialization of Untrusted Data

Deserialization of Untrusted Data vulnerability in Apache Lucene Replicator.

This issue affects Apache Lucene's replicator module: from 4.4.0 before 9.12.0.

The deprecated org.apache.lucene.replicator.http package is affected.

The org.apache.lucene.replicator.nrt package is not affected.

Users are recommended to upgrade to version 9.12.0, which fixes the issue.

Java serialization filters (such as -Djdk.serialFilter="!*" on the commandline) can mitigate the issue on vulnerable versions without impacting functionality.

**GovWay**

Versione affette: <= 3.3.15.p1

Risoluzione: 3.3.15.p2

### 2.3.6 CVE-2024-47554

Data: 2024-10-08

Severity: High

CVSS Score: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-47554
- https://lists.apache.org/thread/6ozr91rr9cj5lm0zyhv30bsp317hk5z1

- https://ossindex.sonatype.org/vulnerability/CVE-2024-47554

Libreria: commons-io:commons-io < 2.14.0

**Descrizione**

CWE-400: Uncontrolled Resource Consumption (“Resource Exhaustion”)

Uncontrolled Resource Consumption vulnerability in Apache Commons IO. The org.apache.commons.io.input.XmlStreamReader class may excessively consume CPU resources when processing maliciously crafted input. This issue affects Apache Commons IO: from 2.0 before 2.14.0. Users are recommended to upgrade to version 2.14.0 or later, which fixes the issue.

**GovWay**

Versione affette: <= 3.3.15.p1

Risoluzione: 3.3.15.p2

### 2.3.7 CVE-2024-45801

Data: 2024-09-20

Severity: High

CVSS Score: 7.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-45801
- https://ossindex.sonatype.org/vulnerability/CVE-2024-45801

Libreria: org.webjars:swagger-ui <= 4.15.0

**Descrizione**

“swagger-ui-bundle.js”

DOMPurify is a DOM-only, super-fast, uber-tolerant XSS sanitizer for HTML, MathML and SVG. It has been discovered that malicious HTML using special nesting techniques can bypass the depth checking added to DOMPurify in recent releases. It was also possible to use Prototype Pollution to weaken the depth check. This renders dompurify unable to avoid cross site scripting (XSS) attacks. This issue has been addressed in versions 2.5.4 and 3.1.3 of DOMPurify. All users are advised to upgrade. There are no known workarounds for this vulnerability.

**GovWay**

Versione affette: <= 3.3.15

Risoluzione: 3.3.15.p1

### 2.3.8 CVE-2024-38809

Data: 2024-08-28

Severity: High

CVSS Score: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N)

Riferimenti:

- https://ossindex.sonatype.org/vulnerability/CVE-2024-38809
- https://spring.io/security/cve-2024-38809

Libreria: org.springframework:spring-web <= 5.3.38

**Descrizione**

CWE-1333

Spring Framework - Regular expression Denial of Service (ReDoS)

Spring Framework DoS via conditional HTTP request

Applications that parse ETags from «If-Match» or «If-None-Match» request headers are vulnerable to DoS attack.

**GovWay**

Versione affette: <= 3.3.15

Risoluzione: 3.3.15.p1

### 2.3.9 CVE-2024-38808

Data: 2024-08-28

Severity: Medium

CVSS Score: 4.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:L)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-38808
- https://ossindex.sonatype.org/vulnerability/CVE-2024-38808
- https://spring.io/security/cve-2024-38808

Libreria: org.springframework:spring-expression <= 5.3.38

**Descrizione**

CWE-770: Allocation of Resources Without Limits or Throttling

In Spring Framework versions 5.3.0 - 5.3.38 and older unsupported versions, it is possible for a user to provide a specially crafted Spring Expression Language (SpEL) expression that may cause a denial of service (DoS) condition. Specifically, an application is vulnerable when the following is true: * The application evaluates user-supplied SpEL expressions.

**GovWay**

Versione affette: <= 3.3.15

Risoluzione: 3.3.15.p1

### 2.3.10 CVE-2024-41172

Data: 2024-07-21

Severity: High

CVSS Score: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-41172
- https://ossindex.sonatype.org/vulnerability/CVE-2024-41172

Libreria: org.apache.cxf:cxf-rt-transports-http < 3.6.4 and 4.0.5

**Descrizione**

In versions of Apache CXF before 3.6.4 and 4.0.5 (3.5.x and lower versions are not impacted), a CXF HTTP client conduit may prevent HTTPClient instances from being garbage collected and it is possible that memory consumption will continue to increase, eventually causing the application to run out of memory

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.11 CVE-2024-32007

Data: Data: 2024-07-21

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-32007
- https://ossindex.sonatype.org/vulnerability/CVE-2024-32007

Libreria: org.apache.cxf:cxf-core < 4.0.5, 3.6.4 and 3.5.9

**Descrizione**

An improper input validation of the p2c parameter in the Apache CXF JOSE code before 4.0.5, 3.6.4 and 3.5.9 allows an attacker to perform a denial of service attack by specifying a large value for this parameter in a token.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.12 CVE-2024-31573

Data: 2024-06-04

Severity: Critical

CVSS Score: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

Riferimenti:

- https://ossindex.sonatype.org/vulnerability/CVE-2024-31573
- https://github.com/advisories/GHSA-chfm-68vv-pvw5
- https://github.com/xmlunit/xmlunit/issues/264

Libreria: org.xmlunit:xmlunit-core < 2.10.0

**Descrizione**

[CVE-2024-31573] CWE-1188

xmlunit-core - XSLT Injection

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.13 CVE-2024-34447

Data: 2024-06-04

Severity: High

CVSS Score: 7.7 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L)

Riferimenti:

- https://ossindex.sonatype.org/vulnerability/CVE-2024-34447
- https://www.bouncycastle.org/releasenotes.html

Libreria: org.bouncycastle:bcprov-ext-jdk18on < 1.78

**Descrizione**

[CVE-2024-34447] CWE-297: Improper Validation of Certificate with Host Mismatch

bouncycastle - Improper Validation of Certificate with Host Mismatch

The software communicates with a host that provides a certificate, but the software does not properly ensure that the certificate is actually associated with that host.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.14 CVE-2024-22262

Data: 2024-04-26

Severity: High

CVSS Score: 8.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-22262
- https://ossindex.sonatype.org/vulnerability/CVE-2024-22262

Libreria: org.springframework:spring-web < 5.3.34

**Descrizione**

Applications that use UriComponentsBuilder to parse an externally provided URL (e.g. through a query parameter) AND perform validation checks on the host of the parsed URL may be vulnerable to a open redirect https://cwe.mitre.org/data/definitions/601.html attack or to a SSRF attack if the URL is used after passing validation checks. This is the same as CVE-2024-22259 https://spring.io/security/cve-2024-22259 and CVE-2024-22243 https://spring.io/security/cve-2024-22243 , but with different input.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.15 CVE-2024-30172

Data: 2024-04-26

Severity: Medium

CVSS Score: 5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://ossindex.sonatype.org/vulnerability/CVE-2024-30172
- https://www.bouncycastle.org/releasenotes.html

Libreria: org.bouncycastle:bcprov-ext-jdk18on < 1.78

**Descrizione**

[CVE-2024-30172] CWE-835: Loop with Unreachable Exit Condition ("Infinite Loop")

An issue was discovered in Bouncy Castle Java Cryptography APIs before 1.78. An Ed25519 verification code infinite loop can occur via a crafted signature and public key.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.16 CVE-2024-30171

Data: 2024-04-26

Severity: Medium

CVSS Score: 5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)

Riferimenti:

- https://ossindex.sonatype.org/vulnerability/CVE-2024-30171
- https://www.bouncycastle.org/releasenotes.html
- https://github.com/bcgit/bc-java/issues/1528

Libreria: org.bouncycastle:bcprov-ext-jdk18on < 1.78

**Descrizione**

[CVE-2024-30171] CWE-208: Information Exposure Through Timing Discrepancy

An issue was discovered in Bouncy Castle Java TLS API and JSSE Provider before 1.78. Timing-based leakage may occur in RSA based handshakes because of exception processing.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.17 CVE-2024-29857

Data: 2024-04-26

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://ossindex.sonatype.org/vulnerability/CVE-2024-29857
- https://www.bouncycastle.org/releasenotes.html

Libreria: org.bouncycastle:bcprov-ext-jdk18on < 1.78

**Descrizione**

[CVE-2024-29857] CWE-400: Uncontrolled Resource Consumption (“Resource Exhaustion”)

An issue was discovered in ECCurve.java and ECCurve.cs in Bouncy Castle Java (BC Java) before 1.78, BC Java LTS before 2.73.6, BC-FJA before 1.0.2.5, and BC C# .Net before 2.3.1. Importing an EC certificate with crafted F2m parameters can lead to excessive CPU consumption during the evaluation of the curve parameters.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.18 CVE-2024-22257

Data: 2024-03-21

Severity: High

CVSS Score: 8.2 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-22257
- https://ossindex.sonatype.org/vulnerability/CVE-2024-22257
- https://github.com/advisories/GHSA-f3jh-qvm4-mg39

Libreria: org.springframework.security:* < 5.8.11

**Descrizione**

In Spring Security, versions 5.7.x prior to 5.7.12, 5.8.x prior to 5.8.11, versions 6.0.x prior to 6.0.9, versions 6.1.x prior to 6.1.8, versions 6.2.x prior to 6.2.3, an application is possible vulnerable to broken access control when it directly uses the AuthenticatedVoter#vote passing a null Authentication parameter.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.19 CVE-2024-28752

Data: 2024-03-21

Severity: High

CVSS Score: 7.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:L)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-28752
- https://ossindex.sonatype.org/vulnerability/CVE-2024-28752
- https://github.com/advisories/GHSA-qmgx-j96g-4428

Libreria: org.apache.cxf:* < 3.6.3

**Descrizione**

A SSRF vulnerability using the Aegis DataBinding in versions of Apache CXF before 4.0.4, 3.6.3 and 3.5.8 allows an attacker to perform SSRF style attacks on webservices that take at least one parameter of any type. Users of other data bindings (including the default databinding) are not impacted.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.20 CVE-2024-21742

Data: 2024-03-01

Severity: Medium

CVSS Score: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-21742
- https://ossindex.sonatype.org/vulnerability/CVE-2024-21742
- https://github.com/advisories/GHSA-jw7r-rxff-gv24

Libreria: org.apache.james:apache-mime4j-core < 0.8.10

**Descrizione**

Improper input validation allows for header injection in MIME4J library when using MIME4J DOM for composing message. This can be exploited by an attacker to add unintended headers to MIME messages.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.21 CVE-2024-22243

Data: 2024-02-23

Severity: High

CVSS Score: 8.2 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-22243
- https://ossindex.sonatype.org/vulnerability/CVE-2024-22243
- https://spring.io/security/cve-2024-22243

Libreria: org.springframework:spring-web <= 5.3.31

**Descrizione**

Applications that use UriComponentsBuilder to parse an externally provided URL (e.g. through a query parameter) AND perform validation checks on the host of the parsed URL may be vulnerable to a open redirect https://cwe.mitre.org/data/definitions/601.html attack or to a SSRF attack if the URL is used after passing validation checks.

CWE-601: URL Redirection to Untrusted Site ("Open Redirect").

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.22 CVE-2024-25710

Data: 2024-02-23

Severity: Medium

CVSS Score: 5.5 (CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-25710
- https://ossindex.sonatype.org/vulnerability/CVE-2024-25710

Libreria: org.apache.commons:commons-compress < 1.26.0

**Descrizione**

Loop with Unreachable Exit Condition ("Infinite Loop") vulnerability in Apache Commons Compress. This issue affects Apache Commons Compress: from 1.3 through 1.25.0. Users are recommended to upgrade to version 1.26.0 which fixes the issue.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.23 CVE-2023-52428

Data: 2024-02-14

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2023-52428
- https://ossindex.sonatype.org/vulnerability/CVE-2023-52428

Libreria: com.nimbusds:nimbus-jose-jwt < 9.37.2

**Descrizione**

In Connect2id Nimbus JOSE+JWT before 9.37.2, an attacker can cause a denial of service (resource consumption) via a large JWE p2c header value (aka iteration count) for the PasswordBasedDecrypter (PBKDF2) component.

**GovWay**

Versione affette: <= 3.3.14

Risoluzione: 3.3.15

### 2.3.24 CVE-2023-51074

Data: 2024-01-22

Severity: Medium

CVSS Score: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)

Riferimenti: https://ossindex.sonatype.org/vulnerability/CVE-2023-51074

Libreria: com.jayway.jsonpath:json-path <= 2.8.0

**Descrizione**

json-path v2.8.0 was discovered to contain a stack overflow via the Criteria.parse() method.

**GovWay**

Versione affette: <= 3.3.13.p1

Risoluzione: 3.3.14

## 2.4 Avvisi di Sicurezza 2023

- *CVE-2023-44483*
- *CVE-2023-45860*
- *CVE-2023-5072*
- *CVE-2023-4586*
- *CVE-2023-34042*
- *CVE-2023-40167*
- *CVE-2023-4759*
- *CVE-2023-2976*
- *CVE-2023-34034*
- *CVE-2023-34462*
- *CVE-2023-33201*
- *CVE-2017-9096*
- *CVE-2022-24196 e CVE-2022-24197*
- *CVE-2023-34411*
- *CVE-2023-33264*
- *CVE-2023-20862*
- *CVE-2023-20863*
- *CVE-2022-42003*
- *CVE-2023-20861*
- *CVE-2023-1436*
- *CVE-2023-1370*
- *CVE-2020-8908*
- *CVE-2023-24998*

- *CVE-2022-45688*

### 2.4.1 CVE-2023-44483

Data: 2023-10-21

Severity: High

CVSS Score: 7.4 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2023-44483
- https://ossindex.sonatype.org/vulnerability/CVE-2023-44483

Libreria: org.apache.santuario:xmlsec <= 2.3.3, <=3.0.2

**Descrizione**

All versions of Apache Santuario - XML Security for Java prior to 2.2.6, 2.3.4, and 3.0.3, when using the JSR 105 API, are vulnerable to an issue where a private key may be disclosed in log files when generating an XML Signature and logging with debug level is enabled. Users are recommended to upgrade to version 2.2.6, 2.3.4, or 3.0.3, which fixes this issue.

**GovWay**

Versione affette: <= 3.3.13.p1

Risoluzione: 3.3.14

### 2.4.2 CVE-2023-45860

Data: 2023-10-18

Severity: High

CVSS Score: 7.2 (CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H)

Riferimenti:

- https://ossindex.sonatype.org/vulnerability/CVE-2023-45860
- https://github.com/hazelcast/hz-docs/pull/860

Libreria: com.hazelcast:hazelcast <= 5.3.2

**Descrizione**

hazelcast - Improper Authorization

**GovWay**

Versione affette: <= 3.3.13.p1

Risoluzione: 3.3.14

### 2.4.3 CVE-2023-5072

Data: 2023-10-18

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-5072

Libreria: org.json:json <= 20230618

**Descrizione**

Denial of Service in JSON-Java versions up to and including 20230618. A bug in the parser means that an input string of modest size can lead to indefinite amounts of memory being used.

**GovWay**

Versione affette: <= 3.3.13.p1

Risoluzione: 3.3.14

### 2.4.4 CVE-2023-4586

Data: 2023-10-12

Severity: High

CVSS Score: 7.4 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-4586

Libreria: io.netty:netty-transport <= 4.1.99

**Descrizione**

A vulnerability was found in the Hot Rod client. This security issue occurs as the Hot Rod client does not enable hostname validation when using TLS, possibly resulting in a man-in-the-middle (MITM) attack.

**GovWay**

Versione affette: <= 3.3.13.p1

Risoluzione: 3.3.14

### 2.4.5 CVE-2023-34042

Data: 2023-09-20

Severity: Medium

CVSS Score: 4.1 (CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:N/I:H/A:N)

Riferimenti:

- https://ossindex.sonatype.org/vulnerability/CVE-2023-34042
- https://spring.io/security/cve-2023-34042

Libreria: org.springframework.security:spring-security-config <= 5.8.6

**Descrizione**

The spring-security.xsd file inside the spring-security-config jar is world writable which means that if it were extracted it could be written by anyone with access to the file system.

While there are no known exploits, this is an example of "CWE-732: Incorrect Permission Assignment for Critical Resource" and could result in an exploit. Users should update to the latest version of Spring Security to mitigate any future exploits found around this issue.

**GovWay**

Versione affette: <= 3.3.13.p1

Risoluzione: 3.3.14

### 2.4.6 CVE-2023-40167

Data: 2023-09-15

Severity: Moderate

CVSS Score: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2023-40167
- https://github.com/advisories/GHSA-hmr7-m48g-48f6

Libreria: org.eclipse.jetty:jetty-http <= 10.0.15

**Descrizione**

Jetty accepts the "+" character proceeding the content-length value in a HTTP/1 header field. This is more permissive than allowed by the RFC and other servers routinely reject such requests with 400 responses. There is no known exploit scenario, but it is conceivable that request smuggling could result if jetty is used in combination with a server that does not close the connection after sending such a 400 response.

**GovWay**

Versione affette: <= 3.3.13.p1

Risoluzione: 3.3.14

### 2.4.7 CVE-2023-4759

Data: 2023-09-15

Severity: High

CVSS Score: 8.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-4759

Libreria: org.eclipse.jgit:org.eclipse.jgit <= 6.6.0.202305301015-r

**Descrizione**

Arbitrary File Overwrite in Eclipse JGit <= 6.6.0 In Eclipse JGit, all versions <= 6.6.0.202305301015-r, a symbolic link present in a specially crafted git repository can be used to write a file to locations outside the working tree when this repository is cloned with JGit to a case-insensitive filesystem, or when a checkout from a clone of such a repository is performed on a case-insensitive filesystem. This can happen on checkout (DirCacheCheckout), merge (ResolveMerger via its WorkingTreeUpdater), pull (PullCommand using merge), and when applying a patch (PatchApplier). This can be exploited for remote code execution (RCE), for instance if the file written outside the working tree is a git filter that gets executed on a subsequent git command. The issue occurs only on case-insensitive filesystems, like the default filesystems on Windows and macOS. The user performing the clone or checkout must have the rights to create symbolic links for the problem to occur, and symbolic links must be enabled in the git configuration. Setting git configuration option core.symlinks = false before checking out avoids the problem. The issue was fixed in Eclipse JGit version 6.6.1.202309021850-r and 6.7.0.202309050840-r, available via Maven Central https://repo1.maven.org/maven2/org/eclipse/jgit/ and repo.eclipse.org https://repo.eclipse.org/content/repositories/jgit-releases/ . The JGit maintainers would like to thank RyotaK for finding and reporting this issue.

**GovWay**

Versione affette: <= 3.3.13.p1

Risoluzione: 3.3.14; il jar viene utilizzato solamente in fase di compilazione degli archivi e non a runtime.

### 2.4.8 CVE-2023-2976

Data: 2023-07-27

Severity: High

CVSS Score: 7.1 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-2976

Libreria: com.google.guava:guava <= 32.0.0-jre

**Descrizione**

Use of Java's default temporary directory for file creation in *FileBackedOutputStream* in Google Guava versions 1.0 to 31.1 on Unix systems and Android Ice Cream Sandwich allows other users and apps on the machine with access to the default Java temporary directory to be able to access the files created by the class. Even though the security vulnerability is fixed in version 32.0.0, we recommend using version 32.0.1 as version 32.0.0 breaks some functionality under Windows.

**GovWay**

Versione affette:

- = 3.3.13: solamente su windows poiché utilizzata la v32.0.0 della libreria guava;
- < 3.3.13: qualsiasi ambiente.

Risoluzione: 3.3.13.p1

### 2.4.9 CVE-2023-34034

Data: 2023-07-20

Severity: Critical

CVSS Score: 9.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)

Riferimenti:

- https://spring.io/security/cve-2023-34034
- https://nvd.nist.gov/vuln/detail/CVE-2023-34034
- https://ossindex.sonatype.org/vulnerability/CVE-2023-34034

Libreria: org.springframework.security:* < 5.8.5

**Descrizione**

Using «**» as a pattern in Spring Security configuration for WebFlux creates a mismatch in pattern matching between Spring Security and Spring WebFlux, and the potential for a security bypass.

**GovWay**

Versione affette: <= 3.3.13

Risoluzione: 3.3.13.p1

### 2.4.10 CVE-2023-34462

Data: 2023-07-05

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-34462

Libreria: io.netty:netty-transport < 4.1.94.Final

**Descrizione**

Netty is an asynchronous event-driven network application framework for rapid development of maintainable high performance protocol servers & clients. The *SniHandler* can allocate up to 16MB of heap for each channel during the TLS handshake. When the handler or the channel does not have an idle timeout, it can be used to make a TCP server using the *SniHandler* to allocate 16MB of heap. The *SniHandler* class is a handler that waits for the TLS handshake to configure a *SslHandler* according to the indicated server name by the *ClientHello* record. For this matter it allocates a *ByteBuf* using the value defined in the *ClientHello* record. Normally the value of the packet should be smaller than the handshake packet but there are not checks done here and the way the code is written, it is possible to craft a packet that makes the *SslClientHelloHandler*. This vulnerability has been fixed in version 4.1.94.Final.

**GovWay**

Versione affette: <= 3.3.13

Risoluzione: 3.3.13.p1

### 2.4.11 CVE-2023-33201

Data: 2023-06-20

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N)

Riferimenti: https://github.com/bcgit/bc-java/wiki/CVE-2023-33201

Libreria: org.bouncycastle:bcprov-ext-jdk18on < 1.74

**Descrizione**

The Bouncy Castle Crypto package is a Java implementation of cryptographic algorithms. This jar contains JCE provider and lightweight API for the Bouncy Castle Cryptography APIs for JDK 1.8 and up. Note: this package includes the NTRU encryption algorithms.

**GovWay**

Versione affette: <= 3.3.12

Risoluzione: 3.3.13

### 2.4.12 CVE-2017-9096

Data: 2023-06-15

Severity: High

CVSS Score: 8.8 (CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2017-9096

Libreria: com.lowagie:itext < 5.5.12

**Descrizione**

The XML parsers in iText before 5.5.12 and 7.x before 7.0.3 do not disable external entities, which might allow remote attackers to conduct XML external entity (XXE) attacks via a crafted PDF.

**GovWay**

Versione affette: <= 3.3.12

Risoluzione: 3.3.13

### 2.4.13 CVE-2022-24196 e CVE-2022-24197

Data: 2023-06-15

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2022-24196
- https://nvd.nist.gov/vuln/detail/CVE-2022-24197

Libreria: com.lowagie:itext < 7.1.17

**Descrizione**

- CVE-2022-24196: iText v7.1.17, up to (exluding)»: 7.1.18 and 7.2.2 was discovered to contain an out-of-memory error via the component readStreamBytesRaw, which allows attackers to cause a Denial of Service (DoS) via a crafted PDF file.
- CVE-2022-24197: iText v7.1.17 was discovered to contain a stack-based buffer overflow via the component ByteBuffer.append, which allows attackers to cause a Denial of Service (DoS) via a crafted PDF file.

**GovWay**

Versione affette: <= 3.3.12

Risoluzione: 3.3.13

### 2.4.14 CVE-2023-34411

Data: 2023-06-14

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-34411

Libreria: com.fasterxml.woodstox:woodstox-core <= 6.4.0

**Descrizione**

The xml-rs crate before 0.8.14 for Rust and Crab allows a denial of service (panic) via an invalid <! token (such as <!DOCTYPEs/%<!A nesting) in an XML document. The earliest affected version is 0.8.9.

**GovWay**

Versione affette: <= 3.3.12

Risoluzione: 3.3.13

### 2.4.15 CVE-2023-33264

Data: 2023-05-23

Severity: Medium

CVSS Score: 4.3 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-33264

Libreria: com.hazelcast:hazelcast < 5.3.0

**Descrizione**

In Hazelcast through 5.0.4, 5.1 through 5.1.6, and 5.2 through 5.2.3, configuration routines don't mask passwords in the member configuration properly. This allows Hazelcast Management Center users to view some of the secrets.

**GovWay**

Versione affette: <= 3.3.12

Risoluzione: 3.3.13

### 2.4.16 CVE-2023-20862

Data: 2023-04-20

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-20862

Libreria: org.springframework.security:spring-security-* < 5.7.8

**Descrizione**

In Spring Security, versions 5.7.x prior to 5.7.8, versions 5.8.x prior to 5.8.3, and versions 6.0.x prior to 6.0.3, the logout support does not properly clean the security context if using serialized versions. Additionally, it is not possible to explicitly save an empty security context to the HttpSessionSecurityContextRepository. This vulnerability can keep users authenticated even after they performed logout. Users of affected versions should apply the following mitigation. 5.7.x users should upgrade to 5.7.8. 5.8.x users should upgrade to 5.8.3. 6.0.x users should upgrade to 6.0.3.

**GovWay**

Versione affette: <= 3.3.12

Risoluzione: 3.3.13

### 2.4.17 CVE-2023-20863

Data: 2023-04-16

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-20863

Libreria: org.springframework:spring-expression <= 5.3.26

**Descrizione**

In spring framework versions prior to 5.2.24 release+ ,5.3.27+ and 6.0.8+ , it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

**GovWay**

Versione affette: <= 3.3.11

Risoluzione: 3.3.12

### 2.4.18 CVE-2022-42003

Data: 2023-04-04

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2022-42003

Libreria: com.fasterxml.jackson.core:jackson-databind <= 2.13.4.1

**Descrizione**

In FasterXML jackson-databind before 2.14.0-rc1, resource exhaustion can occur because of a lack of a check in primitive value deserializers to avoid deep wrapper array nesting, when the UNWRAP_SINGLE_VALUE_ARRAYS feature is enabled. Additional fix version in 2.13.4.1 and 2.12.17.1

**GovWay**

Versione affette: <= 3.3.11

Risoluzione: 3.3.12

### 2.4.19 CVE-2023-20861

Data: 2023-03-29

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-20861

Libreria: org.springframework:spring-* <= 5.3.25

**Descrizione**

In Spring Framework versions 6.0.0 - 6.0.6, 5.3.0 - 5.3.25, 5.2.0.RELEASE - 5.2.22.RELEASE, and older unsupported versions, it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

**GovWay**

Versione affette: <= 3.3.11

Risoluzione: 3.3.12

### 2.4.20 CVE-2023-1436

Data: 2023-03-18

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://ossindex.sonatype.org/vulnerability/CVE-2023-1436

Libreria: org.codehaus.jettison:jettison <= 1.5.3

**Descrizione**

CWE-400: Uncontrolled Resource Consumption (“Resource Exhaustion”)

jettison - Denial of Service (DoS)

**GovWay**

Versione affette: <= 3.3.11

Risoluzione: 3.3.12

### 2.4.21 CVE-2023-1370

Data: 2023-03-18

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://ossindex.sonatype.org/vulnerability/CVE-2023-1370

Libreria: net.minidev:json-smart <= 2.4.8

**Descrizione**

CWE-400: Uncontrolled Resource Consumption ("Resource Exhaustion")

json-smart - Denial of Service (DoS)

**GovWay**

Versione affette: <= 3.3.11

Risoluzione: 3.3.12

### 2.4.22 CVE-2020-8908

Data: 2023-03-08

Severity: Low

CVSS Score: 3.3 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2020-8908

Libreria: com.google.guava:guava <= 31.1-jre

**Descrizione**

A temp directory creation vulnerability exists in all versions of Guava, allowing an attacker with access to the machine to potentially access data in a temporary directory created by the Guava API com.google.common.io.Files.createTempDir(). By default, on unix-like systems, the created directory is world-readable (readable by an attacker with access to the system). The method in question has been marked @Deprecated in versions 30.0 and later and should not be used. For Android developers, we recommend choosing a temporary directory API provided by Android, such as context.getCacheDir(). For other Java developers, we recommend migrating to the Java 7 API java.nio.file.Files.createTempDirectory() which explicitly configures permissions of 700, or configuring the Java runtime's java.io.tmpdir system property to point to a location whose permissions are appropriately configured.

**GovWay**

Versione affette: <= 3.3.10

Risoluzione: 3.3.13

### 2.4.23 CVE-2023-24998

Data: 2023-02-22

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-24998

Libreria: commons-fileupload:commons-fileupload <= 1.4

**Descrizione**

Apache Commons FileUpload before 1.5 does not limit the number of request parts to be processed resulting in the possibility of an attacker triggering a DoS with a malicious upload or series of uploads.

**GovWay**

Versione affette: <= 3.3.10

Risoluzione: 3.3.11

### 2.4.24 CVE-2022-45688

Data: 2023-02-06

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2022-45688

Libreria: org.json:json <= 20220924

**Descrizione**

A stack overflow in the XML.toJSONObject component of hutool-json v5.8.10 allows attackers to cause a Denial of Service (DoS) via crafted JSON or XML data.

**GovWay**

Versione affette: <= 3.3.10

Risoluzione: 3.3.11

## 2.5 Avvisi di Sicurezza 2022

- *CVE-2022-46364*
- *CVE-2022-41915*
- *CVE-2021-37533*
- *CVE-2022-40150*
- *CVE-2022-[40152-40156]*
- *CVE-2022-31692*
- *CVE-2022-34169*
- *CVE-2021-44832*

### 2.5.1 CVE-2022-46364

Data: 2022-12-14

Severity: Critical

CVSS Score: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2022-46364

Libreria: org.apache.cxf:cxf-core >= 3.5.0, < 3.5.5

**Descrizione**

A SSRF vulnerability in parsing the href attribute of XOP:Include in MTOM requests in versions of Apache CXF before 3.5.5 and 3.4.10 allows an attacker to perform SSRF style attacks on webservices that take at least one parameter of any type.

**GovWay**

Versione affette: <= 3.3.9.p3

Risoluzione: 3.3.10

### 2.5.2 CVE-2022-41915

Data: 2022-12-14

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2022-41915

Libreria: io.netty:netty-codec < 4.1.86.Final

**Descrizione**

Netty project is an event-driven asynchronous network application framework. In versions prior to 4.1.86.Final, when calling *DefaultHttpHeadesr.set* with an _iterator_ of values, header value validation was not performed, allowing malicious header values in the iterator to perform HTTP Response Splitting. This issue has been patched in version 4.1.86.Final. Integrators can work around the issue by changing the *DefaultHttpHeaders.set(CharSequence, Iterator<?>)* call, into a *remove()* call, and call *add()* in a loop over the iterator of values.

**GovWay**

Versione affette: <= 3.3.9.p3

Risoluzione: 3.3.10

### 2.5.3 CVE-2021-37533

Data: 2022-12-07

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2021-37533

Libreria: apache:commons_net <= 3.8.0

**Descrizione**

Prior to Apache Commons Net 3.9.0, Net's FTP client trusts the host from PASV response by default. A malicious server can redirect the Commons Net code to use a different host, but the user has to connect to the malicious server in the first place. This may lead to leakage of information about services running on the private network of the client. The default in version 3.9.0 is now false to ignore such hosts, as cURL does. See https://issues.apache.org/jira/browse/NET-711.

**GovWay**

**Nota**

GovWay non utilizza il codice che possiede la vulnerabilità.

Versione affette: <= 3.3.9.p2

Risoluzione: 3.3.9.p3

### 2.5.4 CVE-2022-40150

Data: 2022-12-03

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2022-40150

Libreria: jettison_project:jettison <= 1.5.1

**Descrizione**

Those using Jettison to parse untrusted XML or JSON data may be vulnerable to Denial of Service attacks (DOS). If the parser is running on user supplied input, an attacker may supply content that causes the parser to crash by Out of memory. This effect may support a denial of service attack.

**GovWay**

Versione affette: <= 3.3.9.p2

Risoluzione: 3.3.9.p3

### 2.5.5 CVE-2022-[40152-40156]

Data: 2022-10-28

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2022-40152
- https://nvd.nist.gov/vuln/detail/CVE-2022-40153
- https://nvd.nist.gov/vuln/detail/CVE-2022-40154
- https://nvd.nist.gov/vuln/detail/CVE-2022-40155
- https://nvd.nist.gov/vuln/detail/CVE-2022-40156

Libreria: com.fasterxml.woodstox:woodstox-core >= 6.0.0, < 6.4.0

**Descrizione**

Those using Xstream to seralize XML data may be vulnerable to Denial of Service attacks (DOS). If the parser is running on user supplied input, an attacker may supply content that causes the parser to crash by stackoverflow. This effect may support a denial of service attack.

**GovWay**

Versione affette: <= 3.3.8

Risoluzione: 3.3.9

### 2.5.6 CVE-2022-31692

Data: 2022-10-29

Severity: Critical

CVSS Score: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2022-31692

Libreria: org.springframework.security:spring-security-core >= 5.7.0, < 5.7.5

**Descrizione**

Spring Security, versions 5.7 prior to 5.7.5 and 5.6 prior to 5.6.9 could be susceptible to authorization rules bypass via forward or include dispatcher types. Specifically, an application is vulnerable when all of the following are true: The application expects that Spring Security applies security to forward and include dispatcher types. The application uses the AuthorizationFilter either manually or via the authorizeHttpRequests() method. The application configures the FilterChainProxy to apply to forward and/or include requests (e.g. spring.security.filter.dispatcher-types = request, error, async, forward, include). The application may forward or include the request to a higher privilege-secured endpoint.The application configures Spring Security to apply to every dispatcher type via authorizeHttpRequests().shouldFilterAllDispatcherTypes(true)

**GovWay**

Versioni affette: <= 3.3.8

Risoluzione: 3.3.9

### 2.5.7 CVE-2022-34169

Data: 2022-10-27

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2022-34169

Libreria: xalan:xalan <= 2.7.2

**Descrizione**

The Apache Xalan Java XSLT library is vulnerable to an integer truncation issue when processing malicious XSLT stylesheets. This can be used to corrupt Java class files generated by the internal XSLTC compiler and execute arbitrary Java bytecode. The Apache Xalan Java project is dormant and in the process of being retired. No future releases of Apache Xalan Java to address this issue are expected. Note: Java runtimes (such as OpenJDK) include repackaged copies of Xalan.

A fix for this issue was published in September 2022 as part of an anticipated 2.7.3 release.

**GovWay**

Versione affette: <= 3.3.8

Risoluzione: 3.3.9

### 2.5.8 CVE-2021-44832

Data: 2022-01-04

Severity: Medium

CVSS Score: 6.6 (CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2021-44832

Libreria: org.apache.logging.log4j:log4j-core <= 2.17.0

**Descrizione**

Apache Log4j2 versions 2.0-beta7 through 2.17.0 (excluding security fix releases 2.3.2 and 2.12.4) are vulnerable to a remote code execution (RCE) attack when a configuration uses a JDBC Appender with a JNDI LDAP data source URI

when an attacker has control of the target LDAP server. This issue is fixed by limiting JNDI data source names to the java protocol in Log4j2 versions 2.17.1, 2.12.4, and 2.3.2.

**GovWay**

Versioni affette: <= 3.3.5.p2

Risoluzione: 3.3.6

## 2.6 Avvisi di Sicurezza 2021


- *CVE-2021-45105*
- *CVE-2021-45046*
- *CVE-2021-44228*


### 2.6.1 CVE-2021-45105

Data: 2021-12-20

Severity: Medium

CVSS Score: 5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2021-45105

Libreria: org.apache.logging.log4j:log4j-core <= 2.16.0

**Descrizione**

Apache Log4j2 versions 2.0-alpha1 through 2.16.0 (excluding 2.12.3 and 2.3.1) did not protect from uncontrolled recursion from self-referential lookups. This allows an attacker with control over Thread Context Map data to cause a denial of service when a crafted string is interpreted. This issue was fixed in Log4j 2.17.0, 2.12.3, and 2.3.1.

**GovWay**

Versioni affette: <= 3.3.5.p2

Risoluzione: 3.3.6

### 2.6.2 CVE-2021-45046

Data: 2021-12-11

Severity: Critical

CVSS Score: 9.0 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2021-45046

Libreria: org.apache.logging.log4j:log4j-core <= 2.15.0

**Descrizione**

It was found that the fix to address CVE-2021-44228 in Apache Log4j 2.15.0 was incomplete in certain non-default configurations. This could allows attackers with control over Thread Context Map (MDC) input data when the logging configuration uses a non-default Pattern Layout with either a Context Lookup (for example, $${ctx:loginId}) or a Thread Context Map pattern (%X, %mdc, or %MDC) to craft malicious input data using a JNDI Lookup pattern resulting in an information leak and remote code execution in some environments and local code execution in all environments. Log4j 2.16.0 (Java 8) and 2.12.2 (Java 7) fix this issue by removing support for message lookup patterns and disabling JNDI functionality by default.

**GovWay**

Versioni affette: <= 3.3.5.p1

Risoluzione: 3.3.5.p2

### 2.6.3 CVE-2021-44228

Data: 2021-12-07

Severity: Critical

CVSS Score: 10.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2021-44228

Libreria: org.apache.logging.log4j:log4j-core <= 2.14.1

**Descrizione**

Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers when message lookup substitution is enabled. From log4j 2.15.0, this behavior has been disabled by default. From version 2.16.0 (along with 2.12.2, 2.12.3, and 2.3.1), this functionality has been completely removed. Note that this vulnerability is specific to log4j-core and does not affect log4net, log4cxx, or other Apache Logging Services projects.

**GovWay**

Versioni affette: <= 3.3.5

Risoluzione: 3.3.5.p1

# CHAPTER 3

# Falsi Positivi

A valle dell'analisi di una vulnerabilità, rilevata dal processo descritto in releaseProcessGovWay_thirdPartyDynamicAnalysis, se la vulnerabilità viene identificata come un falso positivo viene registrata come tale nella configurazione del tool OWASP Dependency-Check, in modo che successive verifiche non ne segnalino più la presenza.

Nelle sezioni seguenti vengono descritte i falsi positivi rilevati per le versioni 3.4.x e 3.3.x.

## 3.1 Falsi Positivi v3.4.x


- *CVE-2026-39882, CVE-2026-40894, CVE-2026-41178, CVE-2026-44967, CVE-2026-54285*
- *CVE-2026-53914*
- *CVE-2025-15599, CVE-2026-0540, GHSA-39q2-94rc-95cp*
- *Librerie incluse in com.hazelcast:hazelcast*
- *CVE-2025-48976*
- *CVE-2016-2175, CVE-2018-8036, CVE-2018-11797*
- *Generazione classi*


### 3.1.1 CVE-2026-39882, CVE-2026-40894, CVE-2026-41178, CVE-2026-44967, CVE-2026-54285

Data: 2026-10-06

Severity: Medium

CVSS Score: 5.3

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2026-39882
- https://nvd.nist.gov/vuln/detail/CVE-2026-40894

- https://nvd.nist.gov/vuln/detail/CVE-2026-41178
- https://nvd.nist.gov/vuln/detail/CVE-2026-44967
- https://nvd.nist.gov/vuln/detail/CVE-2026-54285

Libreria: io.opentelemetry.proto:opentelemetry-proto

**Descrizione**

- *CVE-2026-39882*: OpenTelemetry-Go is the Go implementation of OpenTelemetry. Prior to 1.43.0, the otlp HTTP exporters (traces/metrics/logs) read the full HTTP response body into an in-memory bytes.Buffer without a size cap. This is exploitable for memory exhaustion when the configured collector endpoint is attacker-controlled (or a network attacker can mitm the exporter connection). This vulnerability is fixed in 1.43.0.
- *CVE-2026-40894*: OpenTelemetry dotnet is a dotnet telemetry framework. In OpenTelemetry.Api 0.5.0-beta.2 to 1.15.2 and OpenTelemetry.Extensions.Propagators 1.3.1 to 1.15.2, The implementation details of the baggage, B3 and Jaeger processing code in the OpenTelemetry.Api and OpenTelemetry.Extensions.Propagators NuGet packages can allocate excessive memory when parsing which could create a potential denial of service (DoS) in the consuming application. This vulnerability is fixed in 1.15.3.
- *CVE-2026-41178*: OpenTelemetry-Go is the Go implementation of OpenTelemetry. Versions 1.41.0 and 1.43.0 removed raw-length rejection and it causes `Parse` to process arbitrarily large/invalid baggage headers and log errors, enabling DoS via oversized inputs. Versions 1.42.0 and 1.44.0 fix the issue.
- *CVE-2026-44967*: OpenTelemetry-cpp is the C++ implementation of OpenTelemetry. Prior to release 1.27.0, the OTLP HTTP exporters (traces/metrics/logs) read the full HTTP response into an in-memory vector of bytes without a size cap. This is exploitable for memory exhaustion when the configured collector endpoint is attacker-controlled (or a network attacker can MITM the exporter connection). This vulnerability is fixed in opentelemetry-cpp release 1.27.0.
- *CVE-2026-54285*: opentelemetry-js is the OpenTelemetry JavaScript Client. Prior to 2.8.0, W3CBaggagePropagator.extract() in @opentelemetry/core does not enforce size limits when parsing inbound baggage HTTP headers. The W3C Baggage specification recommends a maximum of 8,192 bytes and 180 entries; these limits were only enforced on the outbound (inject()) path, not on the inbound (extract()) path. Parsing oversized baggage causes memory allocation proportional to the header size without any cap. This vulnerability is fixed in 2.8.0.

**Falso Positivo per GovWay**

Le vulnerabilità riguardano esclusivamente implementazioni di OpenTelemetry in altri linguaggi: Go (CVE-2026-39882, CVE-2026-41178), .NET (CVE-2026-40894), C++ (CVE-2026-44967) e JavaScript (CVE-2026-54285). Coerentemente, i CPE vulnerabili indicati da NVD sono qualificati per linguaggio (`target_sw` valorizzato a `go`, `.net`, `c++` e `node.js`).

Il dependency-check produce un falso positivo poiché associa al jar Java `opentelemetry-proto-1.11.1-alpha.jar` il CPE generico `cpe:2.3:a:opentelemetry:opentelemetry:1.11.1`, senza distinguere il linguaggio dell'implementazione.

La libreria `opentelemetry-proto` contiene unicamente le classi Java generate dalle definizioni protobuf del protocollo OTLP e non include exporter HTTP né propagatori (baggage, B3, Jaeger). In GovWay viene utilizzata solamente per la serializzazione delle metriche inviate al collector OpenTelemetry. Si tratta quindi di un falso positivo.

Configuration File: false-positive.xml

### 3.1.2 CVE-2026-53914

Data: 2026-07-01

Severity: Critical

CVSS Score: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/E:P/RC:R/MAV:A)

Riferimenti: - https://nvd.nist.gov/vuln/detail/CVE-2026-53914

Libreria: org.jetbrains.kotlin:kotlin-stdlib

**Descrizione**

In JetBrains Kotlin before 2.4.20 code execution was possible via unsafe deserialization in the build cache metadata.

**Falso Positivo per GovWay**

La vulnerabilità "CVE-2026-53914" riguarda il tooling di build di Kotlin: la deserializzazione insicura interessa i metadati della build cache utilizzati durante la compilazione incrementale. Tale logica risiede negli artefatti di build di Kotlin (compilatore, build-tools, plugin Gradle/Maven) e non nella libreria standard a runtime "kotlin-stdlib", che non gestisce né deserializza metadati di build cache. Coerentemente, il vettore d'attacco documentato dal vendor (JetBrains) è locale, in ambiente di build e con privilegi elevati (CVSS 6.7), quindi non sfruttabile su un'applicazione in esecuzione.

In GovWay la libreria "kotlin-stdlib" è utilizzata unicamente come dipendenza a runtime della libreria json-sKema (validazione OpenAPI/JSON Schema); GovWay non compila codice Kotlin e non utilizza la build cache di Kotlin. Si tratta quindi di un falso positivo.

Configuration File: false-positive.xml

### 3.1.3 CVE-2025-15599, CVE-2026-0540, GHSA-39q2-94rc-95cp

Data: 2026-04-21

Severity: MEDIUM

CVSS Score: 5.1 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:L/SI:L/SA:N)

Riferimenti: - https://nvd.nist.gov/vuln/detail/CVE-2025-15599 - https://nvd.nist.gov/vuln/detail/CVE-2026-0540 - https://github.com/cure53/DOMPurify/security/advisories/GHSA-39q2-94rc-95cp

Libreria: org.webjars:swagger-ui (DOMPurify incluso nei bundle JavaScript)

**Descrizione**

Le vulnerabilità riguardano la libreria JavaScript DOMPurify, inclusa all'interno dei bundle JavaScript distribuiti dal jar `swagger-ui` (in particolare `swagger-ui-bundle.js` e `swagger-ui-es-bundle.js`).

- *CVE-2025-15599*: DOMPurify 3.1.3 through 3.2.6 and 2.5.3 through 2.5.8 contain a cross-site scripting vulnerability that allows attackers to bypass attribute sanitization by exploiting missing textarea rawtext element validation in the SAFE_FOR_XML regex. Attackers can include closing rawtext tags like `</textarea>` in attribute values to break out of rawtext contexts and execute JavaScript when sanitized output is placed inside rawtext elements. The 3.x branch was fixed in 3.2.7; the 2.x branch was never patched.
- *CVE-2026-0540*: DOMPurify 3.1.3 through 3.3.1 and 2.5.3 through 2.5.8, fixed in commit 729097f, contain a cross-site scripting vulnerability that allows attackers to bypass attribute sanitization by exploiting five missing rawtext elements (noscript, xmp, noembed, noframes, iframe) in the SAFE_FOR_XML regex. Attackers can include payloads like `</noscript><img src=x onerror=alert(1)>` in attribute values to execute JavaScript when sanitized output is placed inside these unprotected rawtext contexts.
- *GHSA-39q2-94rc-95cp*: In `src/purify.ts` (v3.3.3, commit 883ac15) `ADD_TAGS` as a function (via `EXTRA_ELEMENT_HANDLING.tagCheck`) bypasses `FORBID_TAGS` a causa di una short-circuit evaluation: quando `tagCheck(tagName)` restituisce `true`, l'intera condizione diventa `false` e l'elemento viene mantenuto senza valutare `FORBID_TAGS`. Applicazioni che utilizzano contemporaneamente `ADD_TAGS` come funzione e `FORBID_TAGS` ottengono quindi un comportamento inatteso, con i tag proibiti che vengono comunque accettati.

**Falso Positivo per GovWay**

Swagger UI viene disabilitato nelle API di GovWay (proprietà `support.swagger.ui=false` nel file `openapi-configuration.json`) e i file JavaScript del bundle non vengono mai serviti a runtime dal Gateway.

Tutte le vulnerabilità DOMPurify rilevate all'interno del jar `swagger-ui` (incluse quelle future che dovessero essere segnalate da RetireJS sulla stessa libreria) si possono quindi considerare falsi positivi.

Configuration File: false-positive.xml

### 3.1.4 Librerie incluse in com.hazelcast:hazelcast

Data: 2026-10-15

Severity: Moderate / High

Libreria: `com.hazelcast:hazelcast` 5.7.0, che include al proprio interno (rilocate in `com/hazelcast/shaded/...`):

- `com.fasterxml.jackson.core:jackson-core` 2.21.2
- `com.fasterxml.jackson.core:jackson-databind` 2.21.2
- `tools.jackson.core:jackson-core` 3.1.2
- `tools.jackson.core:jackson-databind` 3.1.2

**Descrizione**

Gli scanner Trivy e Grype, analizzando l'immagine di GovWay, rilevano all'interno di `hazelcast-5.7.0.jar` le librerie Jackson sopra indicate tramite i file `META-INF/maven/.../pom.properties` presenti nel jar e vi associano i seguenti advisory:

| Advisory | CVE | Severity | Descrizione |
|---|---|---|---|
| GHSA-7hhh-6rmp-j9qf | CVE-2026-89425 | High | jackson-core: UTF8DataInputJsonParser._reportInvalidToken() missing maxErrorTokenLength limit |
| GHSA-p6pp-m3f8-5c89 | CVE-2026-89407 | High | jackson-core: ReDoS: quadratic backtracking in NumberInput.PATTERN_FLOAT via looksLikeValidNumber() |
| GHSA-r7wm-3cxj-wff9 | CVE-2026-68494 | High | jackson-core: Async parser maxNumberLength bypass via chunked digit accumulation |
| GHSA-j3rv-43j4-c7qm | CVE-2026-54512 | High | jackson-databind: PolymorphicTypeValidator bypass via generic type parameters |
| GHSA-rmj7-2vxq-3g9f | CVE-2026-54513 | High | jackson-databind: array subtype allowlist bypass in BasicPolymorphicTypeValidator |
| GHSA-q4xh-88c3-wmh7 | CVE-2026-68497 | High | jackson-databind: Duration XMLGregorianCalendar Unbounded Number Parse DoS |
| GHSA-cxp5-3px4-pw24 | CVE-2026-91777 | High | jackson-databind: quadratic forward-reference completion |
| GHSA-wv8q-qhhj-9h54 | CVE-2026-91776 | High | jackson-databind: retains every unknown raw type ID |
| GHSA-hgj6-7826-r7m5 | CVE-2026-54514 | Moderate | jackson-databind: InetSocketAddress deserialization triggers eager DNS resolution (SSRF) |
| GHSA-vvgp-rfg2-7rr6 | CVE-2026-77310 | Moderate | jackson-databind: incomplete fix for CVE-2026-54514 (InetAddress) |
| GHSA-wjgm-6hv5-3cvf | CVE-2026-19032 | Moderate | jackson-databind: Path deserialization missing scheme allowlist for FileSystemProvider resolution |
| GHSA-gx83-3vf8-gh7j | CVE-2026-83557 | Moderate | jackson-databind: Comparable missing from DefaultBaseTypeLimitingValidator's unsafe base types |
| GHSA-5jmj-h7xm-6q6v | CVE-2026-54515 | Moderate | jackson-databind: case-insensitive deserialization bypasses per-property @JsonIgnoreProperties |
| GHSA-9fxm-vc8v-hj55 | CVE-2026-54516 | Moderate | jackson-databind: renamed @JsonIgnore'd setters can deserialize via private fields |
| GHSA-3pjw-73gf-8qr5 | CVE-2026-59888 | Moderate | jackson-databind: @JsonIgnore on a Record property is bypassed with a PropertyNamingStrategy |
| GHSA-5hh8-q8hv-fr38 | CVE-2026-54517 | Moderate | jackson-databind: @JsonView bypass for setterless creator properties |
| GHSA-rcqc-6cw3-h962 | CVE-2026-54518 | Moderate | jackson-databind: @JsonView bypass for unwrapped creator parameters |
| GHSA-5gvw-p9qm-jgwh | CVE-2026-59889 | Moderate | jackson-databind: @JsonView bypassed for @JsonUnwrapped container properties on deserialization |
| GHSA-mhm7-754m-9p8w | | Moderate | jackson-databind: @JsonView bypass for creator properties with @JsonTypeInfo(include=As.EXTERNAL_PROPERTY) |

Gli advisory su jackson-core interessano sia la copia 2.21.2 che la copia 3.1.2; gli advisory su jackson-databind interessano la copia 2.21.2 e, ad eccezione di GHSA-mhm7-754m-9p8w, anche la copia 3.1.2.

**Falso Positivo per GovWay**

Le librerie Jackson utilizzate direttamente da GovWay (`com.fasterxml.jackson.core:jackson-core` e `jackson-databind`) non sono interessate da nessuno degli advisory indicati.

Le segnalazioni riguardano esclusivamente le copie incluse in `hazelcast-5.7.0.jar`. Hazelcast non viene distribuito in una versione priva delle librerie incluse: sul repository Maven Central è disponibile il solo jar

`hazelcast-5.7.0.jar`, costruito con il `maven-shade-plugin` che copia integralmente le dipendenze rilocandole in `com.hazelcast.shaded.*`, comprese le classi non utilizzate da Hazelcast. Le classi rilocate non sono sostituibili dalle librerie Jackson incluse in GovWay.

L'utilizzo delle copie incluse è stato verificato tramite ispezione del bytecode di tutte le classi di `hazelcast-5.7.0.jar` esterne ai package `com.hazelcast.shaded.*`, ricercando sia i riferimenti diretti alle classi sia i riferimenti per nome (reflection, `META-INF/services`):

- `com.fasterxml.jackson.core:jackson-core` 2.21.2, `com.fasterxml.jackson.core:jackson-databind` 2.21.2 e `tools.jackson.core:jackson-databind` 3.1.2 non sono referenziate da alcuna classe di Hazelcast; jackson-core 2.21.2 è utilizzata unicamente da jackson-databind 2.21.2. Gli unici riferimenti esterni sono i file `META-INF/services` con cui le librerie registrano le proprie implementazioni, utilizzati solo da chi ne richiede il tipo, cosa che non avviene. Si tratta quindi di bytecode non raggiungibile da alcun codepath a runtime.
- `tools.jackson.core:jackson-core` 3.1.2 (insieme a `tools.jackson.jr`) è invece utilizzata da Hazelcast esclusivamente per l'elaborazione di documenti JSON memorizzati nelle strutture dati del cluster:
  - creazione dei metadati dei valori di tipo `HazelcastJsonValue` inseriti in una mappa (`JsonMetadataInitializer`, attivo solo per i valori serializzati come JSON);
  - valutazione di query e predicati su attributi di valori JSON (`JsonGetter`, `JsonDataGetter` e relativi adapter di navigazione) e partizionamento per attributi JSON (`AttributePartitioningStrategy`);
  - serializzazione JSON del motore Jet (`com.hazelcast.jet.json`), disabilitato per default e non utilizzato.

  Il parser asincrono di Jackson (oggetto di GHSA-r7wm-3cxj-wff9) non è utilizzato da alcuna classe di Hazelcast.

GovWay utilizza Hazelcast unicamente per i contatori del rate limiting: le strutture dati contengono esclusivamente chiavi e valori Java di GovWay (`IDUnivocoGroupByPolicy`, `DatiCollezionati` e contatori `Long`), non vengono mai memorizzati valori `HazelcastJsonValue`, non vengono eseguite query o predicati sulle mappe, non viene utilizzato il partizionamento per attributi e il motore Jet non viene abilitato. I codepath che utilizzano `tools.jackson.core:jackson-core` non sono quindi raggiungibili tramite le funzionalità di GovWay né tramite le interfacce esposte dal gateway.

Tali codepath potrebbero essere attivati solamente da chi è in grado di collegarsi direttamente alle porte del cluster Hazelcast come member o client, inserendo valori JSON nelle mappe o eseguendo query. Nella Community Edition di Hazelcast non è prevista l'autenticazione dei member e dei client: le porte del cluster devono essere raggiungibili esclusivamente dai nodi GovWay che ne fanno parte e un soggetto in grado di accedervi potrebbe già alterare direttamente i contatori. Tale scenario non rientra pertanto nella superficie di attacco di GovWay e le segnalazioni costituiscono falsi positivi legati alla scansione «ricorsiva» dei jar effettuata dagli scanner.

Configuration Files:

- Trivy: trivy.txt
- Grype: grype.yaml
- OWASP Dependency-Check: false-positive.xml

### 3.1.5 CVE-2025-48976

Data: 2025-07-09

Severity: High

CVSS Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A)

Riferimenti: - https://nvd.nist.gov/vuln/detail/CVE-2025-48976 - https://www.openwall.com/lists/oss-security/2025/06/16/4

Libreria: org.apache.commons:commons-fileupload2-jakarta 2.0.0-M1

**Descrizione**

Allocation of resources for multipart headers with insufficient limits enabled a DoS vulnerability in Apache Commons FileUpload. This issue affects Apache Commons FileUpload: from 1.0 before 1.6; from 2.0.0-M1 before 2.0.0-M4. Users are recommended to upgrade to versions 1.6 or 2.0.0-M4, which fix the issue.

**Falso Positivo per GovWay**

La vulnerabilità "CVE-2025-48976" è presente nelle versioni di Apache Commons FileUpload precedenti alla 2.0.0-M4. Il dependency-check la segnala sul modulo "commons-fileupload2-jakarta-2.0.0-M1.jar" poiché gli associa il CPE "cpe:2.3:a:apache:commons_fileupload:2.0.0:m1" utilizzando la versione del modulo.

Il modulo "commons-fileupload2-jakarta" contiene però unicamente l'adattatore verso le Servlet Jakarta; il parsing delle richieste multipart oggetto della vulnerabilità risiede nel modulo "commons-fileupload2-core", utilizzato in GovWay alla versione 2.0.0-M5 che risolve la vulnerabilità. Si tratta quindi di un falso positivo.

Configuration File: false-positive.xml

### 3.1.6 CVE-2016-2175, CVE-2018-8036, CVE-2018-11797

Data: 2025-03-27

Severity: High

CVSS Score: 7.8 (CVSS:3.0/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

Riferimenti: - https://nvd.nist.gov/vuln/detail/CVE-2016-2175 - https://nvd.nist.gov/vuln/detail/CVE-2018-8036 - https://nvd.nist.gov/vuln/detail/CVE-2018-11797

Libreria: com.github.dhorions:boxable

**Descrizione**

CVE-2016-2175: Apache PDFBox before 1.8.12 and 2.x before 2.0.1 does not properly initialize the XML parsers, which allows context-dependent attackers to conduct XML External Entity (XXE) attacks via a crafted PDF.

CVE-2018-8036: In Apache PDFBox 1.8.0 to 1.8.14 and 2.0.0RC1 to 2.0.10, a carefully crafted (or fuzzed) file can trigger an infinite loop which leads to an out of memory exception in Apache PDFBox's AFMParser.

CVE-2018-11797: In Apache PDFBox 1.8.0 to 1.8.15 and 2.0.0RC1 to 2.0.11, a carefully crafted PDF file can trigger an extremely long running computation when parsing the page tree.

**Falso Positivo per GovWay**

Le tre vulnerabilità vengono segnalate sulla libreria "boxable-1.8.2.jar" ma riguardano esclusivamente versioni obsolete di Apache PDFBox (1.x e 2.x precedenti alla 2.0.12). Il dependency-check produce un falso positivo poiché interpreta erroneamente il numero di versione di Boxable (1.8.2) come versione di PDFBox, effettuando un match sul CPE "cpe:2.3:a:apache:pdfbox:1.8.2" che corrisponde alla versione vulnerabile di PDFBox 1.8.x.

In GovWay la libreria Boxable è utilizzata unicamente per la generazione di tabelle all'interno di documenti PDF (classe "org.openspcoop2.web.monitor.core.report.Templates") e le sue dipendenze transitive verso PDFBox sono completamente escluse nel POM ("exclusion :"). La versione di Apache PDFBox effettivamente utilizzata in GovWay è la 3.x, dichiarata come dipendenza diretta, che non rientra nei range vulnerabili di nessuna delle tre CVE:

- CVE-2016-2175: colpisce PDFBox < 1.8.12 e 2.x < 2.0.1
- CVE-2018-8036: colpisce PDFBox 1.8.0–1.8.14 e 2.0.0RC1–2.0.10
- CVE-2018-11797: colpisce PDFBox 1.8.0–1.8.15 e 2.0.0RC1–2.0.11

Configuration File: false-positive.xml

### 3.1.7 Generazione classi

Esclude i jar inclusi nel file pom.xml poiché vengono utilizzati solamente durante lo sviluppo per generare alcune classi e non a runtime dal Gateway.

Configuration File: false-positive.xml

## 3.2 Falsi Positivi v3.3.x


- *CVE-2026-49875, CVE-2026-50623, CVE-2026-50627, CVE-2026-50628, CVE-2026-50629, CVE-2026-50630, CVE-2026-50631, CVE-2026-50632, CVE-2026-50633, CVE-2026-50634, CVE-2026-50645*
- *GHSA-72hv-8253-57qq, GHSA-r7wm-3cxj-wff9*
- *CVE-2025-10492*
- *CVE-2025-41234*
- *CVE-2025-22228*
- *CVE-2018-1258*
- *CVE-2024-38820 CVE-2025-22233*
- *CVE-2023-4759*
- *CVE-2022-[38752,41854,1471,3064] CVE-2021-4235*
- *CVE-2016-1000027*
- *Console Back Office*
- *Generazione classi*


### 3.2.1 CVE-2026-49875, CVE-2026-50623, CVE-2026-50627, CVE-2026-50628, CVE-2026-50629, CVE-2026-50630, CVE-2026-50631, CVE-2026-50632, CVE-2026-50633, CVE-2026-50634, CVE-2026-50645

Data: 2026-10-19

Severity: Critical / High / Medium

CVSS Score:

- CVE-2026-49875: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-50628: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-50627: 9.1 (CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H)
- CVE-2026-50632: 8.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-50633: 8.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)
- CVE-2026-50645: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
- CVE-2026-50631: 7.4 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)
- CVE-2026-50630: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)
- CVE-2026-50634: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)
- CVE-2026-50629: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)
- CVE-2026-50623: 4.8 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N)

Riferimenti:

- https://cxf.apache.org/security-advisories.html
- https://nvd.nist.gov/vuln/detail/CVE-2026-49875 (GHSA-xw5h-cmh3-8j6j)
- https://nvd.nist.gov/vuln/detail/CVE-2026-50623
- https://nvd.nist.gov/vuln/detail/CVE-2026-50627
- https://nvd.nist.gov/vuln/detail/CVE-2026-50628
- https://nvd.nist.gov/vuln/detail/CVE-2026-50629
- https://nvd.nist.gov/vuln/detail/CVE-2026-50630
- https://nvd.nist.gov/vuln/detail/CVE-2026-50631
- https://nvd.nist.gov/vuln/detail/CVE-2026-50632
- https://nvd.nist.gov/vuln/detail/CVE-2026-50633
- https://nvd.nist.gov/vuln/detail/CVE-2026-50634 (GHSA-33j8-j763-4fv5)
- https://nvd.nist.gov/vuln/detail/CVE-2026-50645

Libreria: org.apache.cxf (versioni affette: < 3.6.12, 4.0.0 - 4.1.6 e 4.2.0 - 4.2.1)

**Descrizione**

1. [CVE-2026-49875] CWE-611: Improper Restriction of XML External Entity Reference

Apache CXF's EndpointReferenceUtils and W3CMultiSchemaFactory classes construct a SAXParserFactory without the necessary JAXP hardening configurations, enabling out-of-band (OOB) external entity resolution. Users are recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fix this issue.

2. [CVE-2026-50628] CWE-358: Improperly Implemented Security Check for Standard

A logic error in OAuthRequestFilter rejects legitimate requests originating from the bound IP address, while blindly allowing requests from any other IP address. Enabling this security feature inadvertently creates an inverse security check. Users are recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fixes this issue.

3. [CVE-2026-50627] CWE-303: Incorrect Implementation of Authentication Algorithm

The JwtAccessTokenValidator class in Apache CXF fails to validate the "aud" (Audience) claims of incoming JWT access tokens. This allows a JWT issued for one Resource Server to be successfully replayed against a completely different Resource Server, leading to Token Confusion/Routing attacks. Users are recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fixes this issue.

4. [CVE-2026-50632] CWE-502: Deserialization of Untrusted Data

A further incomplete fix for a previous advisory CVE-2026-44417 (Untrusted JMS configuration can lead to RCE) for Apache CXF has been identified, which can allow code execution capabilities, if untrusted users are allowed to configure JMS for Apache CXF. Users are recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fixes this issue.

5. [CVE-2026-50633] CWE-502: Deserialization of Untrusted Data

A JNDI Injection vulnerability has been discovered in Apache CXF's JCA integration module, which can allow for code execution, if an attacker is able to manipulate the JCA deployment descriptor (ra.xml) or runtime activation parameters. Users are recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fixes this issue.

6. [CVE-2026-50645] CWE-400: Uncontrolled Resource Consumption

There is no restriction on the amount of attachment headers that a message can contain when being deserialized by Apache CXF, which can lead to uncontrolled resource consumption or a denial of service attack. Users are

recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fix this issue by imposing a maximum default of 500 attachments per message.

7. [CVE-2026-50631] CWE-367: Time-of-check Time-of-use (TOCTOU) Race Condition

A race condition in AbstractOAuthDataProvider allows concurrent requests using the same Refresh Token to bypass single-use semantics and generate multiple valid Access Tokens, when "recycleRefreshTokens" is set to false. A leaked refresh token can be replayed concurrently by multiple attackers or threads. Users are recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fixes this issue.

8. [CVE-2026-50630] CWE-113: Improper Neutralization of CRLF Sequences in HTTP Headers ("HTTP Request/Response Splitting")

A CRLF injection vulnerability exists in the OAuth2 AuthorizationUtils class. When constructing the WWW-Authenticate response header, the "realm" parameter is concatenated without sanitizing Carriage Return (CR) and Line Feed (LF) characters. If an attacker can control the realm value, they can inject arbitrary HTTP headers or split the HTTP response entirely. Users are recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fixes this issue.

9. [CVE-2026-50634] CWE-347: Improper Verification of Cryptographic Signature

A vulnerability in Apache CXF's JwsJsonContainerRequestFilter can be exploited to cause CXF to process metadata that was not authenticated by the accepted signature. This can bypass the application's assumption that accepted *Content-Type* or protected HTTP-header metadata came from a verified signature entry, and may steer downstream JAX-RS entity parsing or signed-header consistency checks. Users are recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fix this issue.

10. [CVE-2026-50629] CWE-93: Improper Neutralization of CRLF Sequences ("CRLF Injection")

The "clientId" parameter from incoming HTTP requests is directly concatenated into OAuth2 server log warning messages without sanitizing control characters. This allows an attacker to inject arbitrary content, including fake log entries, into the server's log files. Users are recommended to upgrade to versions 4.2.2 or 4.1.7 or 3.6.12, which fixes this issue.

11. [CVE-2026-50623] CWE-287: Improper Authentication

An authentication bypass vulnerability exists in the OAuth2 TokenIntrospectionService in Apache CXF. Due to a missing "throw" keyword in the security context check, the introspection endpoint (/services/oauth2/introspect) can be accessed by any unauthenticated network attacker. However note that this is a safeguard only in the case that someone forgot to enable authentication on the service. Users are recommended to upgrade to version 4.2.2 or 4.1.7 or 3.6.12, which fixes this issue.

**Falso Positivo per GovWay**

GovWay 3.3.x utilizza Apache CXF in una versione successiva alla 3.6.12, che contiene il fix per tutte le vulnerabilità: come riportato negli advisory ufficiali di Apache CXF, le vulnerabilità sono corrette nelle versioni 4.2.2, 4.1.7 e **3.6.12**.

Le segnalazioni derivano dai range di versioni pubblicati nelle banche dati:

- l'NVD associa le vulnerabilità alla CPE di prodotto `cpe:2.3:a:apache:cxf` con i soli range `< 4.1.7` e `4.2.0 - 4.2.2`, senza distinguere la linea 3.6.x; OWASP dependency-check le rileva quindi a carico degli artefatti `cxf-core` (compresa la versione modificata `cxf-core-<versione>-gov4j-<n>`) e `cxf-rt-transports-http-jetty`;
- gli advisory GitHub GHSA-xw5h-cmh3-8j6j (CVE-2026-49875) e GHSA-33j8-j763-4fv5 (CVE-2026-50634) indicano come versioni corrette solamente la 4.1.7 e la 4.2.2; OSV-Scanner li rileva quindi a carico degli artefatti `cxf-core` e `cxf-rt-rs-security-jose-jaxrs`.

La soppressione OWASP è limitata alle versioni di Apache CXF 3.6.x a partire dalla 3.6.12.

Le valutazioni sull'applicabilità delle singole vulnerabilità alle versioni precedenti di GovWay sono riportate nei

rispettivi avvisi di sicurezza (es. *CVE-2026-50631, CVE-2026-50623, CVE-2026-50630, CVE-2026-50629*, *CVE-2026-50632, CVE-2026-50633*, *CVE-2026-50634*, *CVE-2026-50645*).

Configuration Files:

- OWASP dependency-check: cxf.xml
- OSV-Scanner: cxf.toml

### 3.2.2 GHSA-72hv-8253-57qq, GHSA-r7wm-3cxj-wff9

Data: 2026-08-10

Severity: Medium / High

Riferimenti:

- https://github.com/advisories/GHSA-72hv-8253-57qq
- https://github.com/advisories/GHSA-r7wm-3cxj-wff9

Librerie: - com.fasterxml.jackson.core:jackson-core (embedded shaded in com.hazelcast:hazelcast)

**Descrizione**

- *GHSA-72hv-8253-57qq*: jackson-core: Number Length Constraint Bypass in Async Parser Leads to Potential DoS Condition. La vulnerabilità interessa il parser asincrono `NonBlockingJsonParser` di Jackson, che non rispetta i limiti di lunghezza configurati per i numeri, esponendo potenzialmente l'applicazione a Denial of Service. Sono affette le versioni di `jackson-core` precedenti alla 2.18.6 e alla 2.21.1.
- *GHSA-r7wm-3cxj-wff9*: jackson-core: Async parser maxNumberLength bypass via chunked digit accumulation (incomplete fix for GHSA-72hv-8253-57qq). The fix released in jackson-core 2.18.6 and 2.21.1 for GHSA-72hv-8253-57qq is incomplete: it did not call validateIntegerLength on the path where the parser runs out of input while still inside MINOR_NUMBER_INTEGER_DIGITS. As a result, an attacker who streams JSON to a non-blocking parser in many small chunks, without ever sending a terminator byte, can keep the parser inside that state indefinitely: the text buffer grows on every chunk and the maxNumberLength limit (1000 by default) is never enforced, the accumulator being gated only by maxStringLength (20 MiB default). Sono affette le versioni di `jackson-core` precedenti alla 2.18.8 e alla 2.21.4.

**Falso Positivo per GovWay**

GovWay utilizza `com.fasterxml.jackson.core:jackson-core` alla versione 2.18.9, già contenente il fix per entrambe le vulnerabilità.

Gli scanner Trivy e Grype rilevano tuttavia entrambe le vulnerabilità anche in `hazelcast-5.3.8.jar`, che è un fat-jar contenente al proprio interno una copia di `jackson-core 2.15.2` rilocata in `com/hazelcast/shaded/com/fasterxml/jackson/...` (visibile anche dal `META-INF/maven/com.fasterxml.jackson.core/jackson-core/pom.properties` interno al jar). L'inclusione è effetto del `maven-shade-plugin` utilizzato in fase di build di Hazelcast, che per default copia integralmente il contenuto della dipendenza shadata, comprese le classi non referenziate dal codice di Hazelcast.

In particolare, è stata verificata l'effettiva presenza fisica delle classi vulnerabili relative al parser asincrono (`com/hazelcast/shaded/com/fasterxml/jackson/core/json/async/NonBlockingJsonParser.class`, `NonBlockingJsonParserBase.class` e le interfacce di feeding in `com/hazelcast/shaded/com/fasterxml/jackson/core/async/`); è stato però altresì verificato, tramite ispezione del bytecode di tutti i `.class` di Hazelcast non shaded (cioè dell'effettivo codice `com.hazelcast.*` distinto da `com.hazelcast.shaded.*`), che nessuna classe Hazelcast invoca o referenzia tali classi async. La serializzazione JSON di Hazelcast utilizza inoltre il parser DOM proprio in `com.hazelcast.internal.json`, che non condivide il codepath vulnerabile. Anche il codice di GovWay non importa né invoca direttamente le classi shaded.

Le classi vulnerabili sono quindi presenti nell'archivio come bytecode «morto», non raggiungibile da alcun codepath a runtime: il vettore di attacco descritto dagli advisory non è esercitabile nel deploy di GovWay e le segnalazioni costituiscono falsi positivi legati al meccanismo di scansione «ricorsiva» dei jar embedded effettuato dagli scanner.

Configuration Files:

- Trivy: trivy.txt
- Grype: grype.yaml

### 3.2.3 CVE-2025-10492

Data: 2025-10-05

Severity: High

CVSS Score: 8.7 (CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-10492
- https://ossindex.sonatype.org/vulnerability/CVE-2025-10492
- https://community.jaspersoft.com/advisories/jaspersoft-security-advisory-september-16-2025-jaspersoft-library-cve-2025-10492

Libreria: net.sf.jasperreports:jasperreports < 7.0.3

**Descrizione**

[CVE-2025-10492] CWE-502: Deserialization of Untrusted Data

A Java deserialisation vulnerability has been discovered in Jaspersoft Library. Improper handling of externally supplied data may allow attackers to execute arbitrary code remotely on systems that use the affected library

**Falso Positivo per GovWay**

Per generare i report nel progetto:

- vengono usati solo dati interni (non influenzabili dagli utenti);
- i template dei report sono tutti fidati (nessuno può caricarli/modificarli);
- non vengono esposti endpoint o funzioni che accettino oggetti/stream serializzati provenienti dall'esterno.

In questi scenari la CVE non è raggiungibile in pratica.

Configuration File: false-positive.toml

### 3.2.4 CVE-2025-41234

Data: 2025-06-19

Severity: Medium

CVSS Score: 6.5 (CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-41234
- https://ossindex.sonatype.org/vulnerability/CVE-2025-41234
- https://spring.io/security/cve-2025-41234

Libreria: org.springframework:spring-web >= 6.0.x

**Descrizione**

In Spring Framework, versions 6.0.x as of 6.0.5, versions 6.1.x and 6.2.x, an application is vulnerable to a reflected file download (RFD) attack when it sets a "Content-Disposition" header with a non-ASCII charset, where the filename attribute is derived from user-supplied input.

Specifically, an application is vulnerable when all the following are true:

- The header is prepared with org.springframework.http.ContentDisposition.
- The filename is set via ContentDisposition.Builder#filename(String, Charset).
- The value for the filename is derived from user-supplied input.
- The application does not sanitize the user-supplied input.
- The downloaded content of the response is injected with malicious commands by the attacker (see RFD paper reference for details).

An application is not vulnerable if any of the following is true:

- The application does not set a "Content-Disposition" response header.
- The header is not prepared with org.springframework.http.ContentDisposition.
- The filename is set via one of:
- ContentDisposition.Builder#filename(String), or
- ContentDisposition.Builder#filename(String, ASCII)
- The filename is not derived from user-supplied input.
- The filename is derived from user-supplied input but sanitized by the application.
- The attacker cannot inject malicious content in the downloaded content of the response.

Affected Spring Products and Versions

Spring Framework:

- 6.2.0 - 6.2.7
- 6.1.0 - 6.1.20
- 6.0.5 - 6.0.28
- Older, unsupported versions are not affected

**Falso Positivo per GovWay**

Nel progetto viene utilizzata la versione 5.3.39 e come indicato nella descrizione stessa della vulnerabilità su spring.io le versioni più vecchie della 6.0.5 non sono affette della vulnerabilità.

Configuration File: false-positive.xml

### 3.2.5 CVE-2025-22228

Data: 2025-04-03

Severity: High

CVSS Score: 7.4 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2025-22228

- https://ossindex.sonatype.org/vulnerability/CVE-2025-22228
- https://spring.io/security/cve-2025-22228

Libreria: org.springframework.security:spring-security-crypto <= 5.8.17

**Descrizione**

CWE-287: Improper Authentication

BCryptPasswordEncoder.matches(CharSequence,String) will incorrectly return true for passwords larger than 72 characters as long as the first 72 characters are the same.

**Falso Positivo per GovWay**

Nel progetto viene utilizzata una versione ricompilata del jar:

- spring-security-crypto-5.8.16-gov4j-1.jar

La tag version "5.8.16 è stata modificata per riportare il contenuto delle modifiche evidenziate nel commit 46f0dc6 sul progetto github spring-projects/spring-security.

All'interno dell'archivio jar è possibile trovare il file diff (crypto.patch) applicato sui sorgenti del tag "5.8.16" oltre ai sorgenti ".java" della classe modificata.

Configuration File: false-positive.toml

### 3.2.6 CVE-2018-1258

Data: 2025-04-03

Severity: High

CVSS Score: 8.8 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2018-1258
- https://ossindex.sonatype.org/vulnerability/CVE-2018-1258

Libreria: org.springframework.security:spring-security-crypto <= 5.8.17

**Descrizione**

CWE-863: Incorrect Authorization

Spring Framework version 5.0.5 when used in combination with any versions of Spring Security contains an authorization bypass when using method security. An unauthorized malicious user can gain unauthorized access to methods that should be restricted.

**Falso Positivo per GovWay**

Nel progetto viene utilizzato spring 5.3.x e spring-security 5.8.x entrambi con versioni superiori alla 5.0.5 indicata.

Configuration File: false-positive.xml

### 3.2.7 CVE-2024-38820 CVE-2025-22233

Data: 2024-10-29

Severity: Medium

CVSS Score: 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2024-38820

- https://ossindex.sonatype.org/vulnerability/CVE-2024-38820
- https://spring.io/security/cve-2024-38820

Libreria: org.springframework:* < 5.3.41

**Descrizione**

The fix for CVE-2022-22968 made disallowedFields patterns in DataBinder case insensitive.

However, String.toLowerCase() has some Locale dependent exceptions that could potentially result in fields not protected as expected.

**Falso Positivo per GovWay**

Nel progetto vengono utilizzate delle versioni ricompilate dei seguenti jar:

- spring-beans-5.3.39-gov4j-2.jar
- spring-context-5.3.39-gov4j-2.jar
- spring-context-support-5.3.39-gov4j-2.jar
- spring-core-5.3.39-gov4j-2.jar
- spring-expression-5.3.39-gov4j-2.jar
- spring-web-5.3.39-gov4j-2.jar

La tag version "v5.3.39" è stata modificata per riportare il contenuto delle modifiche evidenziate nel commit 23656ae sul progetto github spring-projects/spring-framework. Il commit 23656ae contiene il fix *"Use Locale.ROOT consistently for toLower/toUpperCase"* riferito nel advisory-database di github come risoluzione per CVE-2024-38820.

Inoltre sono state riportate le modifiche evidenziate nel commit edfcc6f sul progetto github spring-projects/spring-framework relative alla classe "org.springframework.validation.DataBinder".

All'interno degli archivi jar è possibile trovare i file patch che sono stati applicati sui sorgenti del tag "v5.3.39" oltre ai sorgenti ".java" delle classi modificate.

Configuration File: false-positive.xml

### 3.2.8 CVE-2023-4759

Data: 2023-09-20

Severity: High

CVSS Score: 8.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2023-4759

Libreria: org.eclipse.jgit:org.eclipse.jgit <= 6.6.0.202305301015-r

**Descrizione**

Arbitrary File Overwrite in Eclipse JGit <= 6.6.0 In Eclipse JGit, all versions <= 6.6.0.202305301015-r, a symbolic link present in a specially crafted git repository can be used to write a file to locations outside the working tree when this repository is cloned with JGit to a case-insensitive filesystem, or when a checkout from a clone of such a repository is performed on a case-insensitive filesystem. This can happen on checkout (DirCacheCheckout), merge (ResolveMerger via its WorkingTreeUpdater), pull (PullCommand using merge), and when applying a patch (PatchApplier). This can be exploited for remote code execution (RCE), for instance if the file written outside the working tree is a git filter that gets executed on a subsequent git command. The issue occurs only on case-insensitive filesystems, like the default filesystems on Windows and macOS. The user performing the clone or checkout must have the rights to create symbolic links for the problem to occur, and symbolic links must be enabled in the git configuration. Setting git configuration option core.symlinks = false before checking out avoids the problem. The issue was fixed in Eclipse JGit version 6.6.1.202309021850-r and 6.7.0.202309050840-r, available via Maven Central https://repo1.maven.org/maven2/org/

eclipse/jgit/ and repo.eclipse.org https://repo.eclipse.org/content/repositories/jgit-releases/ . The JGit maintainers would like to thank RyotaK for finding and reporting this issue.

**Falso Positivo per GovWay**

La versione utilizzata non contiene la vulnerabilità come indicato nella descrizione stessa della vulnerabilità CVE-2023-4759:

> The issue was fixed in Eclipse JGit version 6.6.1.202309021850-r and 6.7.0.202309050840-r.

La segnalazione che si tratta di un falso positivo viene discussa anche nell'issue 5943.

Configuration File: false-positive.xml

### 3.2.9 CVE-2022-[38752,41854,1471,3064] CVE-2021-4235

Data: 2022-10-10

Severity: High/Medium

CVSS Score: 7.5, 6.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H)

Riferimenti:

- https://nvd.nist.gov/vuln/detail/CVE-2022-38752
- https://nvd.nist.gov/vuln/detail/CVE-2022-41854
- https://nvd.nist.gov/vuln/detail/CVE-2022-1471
- https://nvd.nist.gov/vuln/detail/CVE-2022-3064
- https://nvd.nist.gov/vuln/detail/CVE-2021-4235

Libreria: org.yaml:snakeyaml 1.33

**Descrizione**

- CVE-2022-38752: Using snakeYAML to parse untrusted YAML files may be vulnerable to Denial of Service attacks (DOS). If the parser is running on user supplied input, an attacker may supply content that causes the parser to crash by stack-overflow.
- CVE-2022-41854: Those using Snakeyaml to parse untrusted YAML files may be vulnerable to Denial of Service attacks (DOS). If the parser is running on user supplied input, an attacker may supply content that causes the parser to crash by stack overflow. This effect may support a denial of service attack.
- CVE-2022-1471: SnakeYaml's Constructor() class does not restrict types which can be instantiated during deserialization. Deserializing yaml content provided by an attacker can lead to remote code execution. We recommend using SnakeYaml's SafeConsturctor when parsing untrusted content to restrict deserialization.
- CVE-2022-3064: Parsing malicious or large YAML documents can consume excessive amounts of CPU or memory.
- CVE-2021-4235: Due to unbounded alias chasing, a maliciously crafted YAML file can cause the system to consume significant system resources. If parsing user input, this may be used as a denial of service vector.

**Falso Positivo per GovWay**

Le vulnerabilità non sono sfruttabili su GovWay per effettuare attacchi poiché la libreria viene utilizzata solamente per la gestione delle interfacce yaml caricate sulla console dagli amministratori e non viene utilizzata per input forniti dinamicamente nelle richieste gestite dai componenti di runtime.

Configuration File: false-positive.xml

### 3.2.10 CVE-2016-1000027

Data: 2022-08-10

Severity: Critical

CVSS Score: 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

Riferimenti: https://nvd.nist.gov/vuln/detail/CVE-2016-1000027

Libreria: org.springframework:spring-web <= 5.3.16

**Descrizione**

Pivotal Spring Framework through 5.3.16 suffers from a potential remote code execution (RCE) issue if used for Java deserialization of untrusted data. Depending on how the library is implemented within a product, this issue may or not occur, and authentication may be required. NOTE: the vendor's position is that untrusted data is not an intended use case. The product's behavior will not be changed because some users rely on deserialization of trusted data.

**Falso Positivo per GovWay**

La versione della libreria utilizzata in GovWay è superiore alla "5.3.16" quindi la segnalazione è considerabile un falso positivo.

Dalle discussioni degli issues 4849 e 4558 del plugin OWASP Dependency-Check si possono comprendere i motivi della segnalazione: nelle versioni precedenti alla 6.x spring ha solamente deprecato l'utilizzo degli oggetti vulnerabili. Nel progetto GovWay comunque la classe oggetto della vulnerabilità (remoting-httpinvoker) non viene utilizzata.

Configuration File: false-positive.xml

### 3.2.11 Console Back Office

Esclude i jar inclusi nel file pom.xml poiché utilizzati dalle console di gestione e monitoraggio adibite a funzioni di backoffice che non devono essere esposte al pubblico.

Configuration File: false-positive.xml

### 3.2.12 Generazione classi

Esclude i jar inclusi nel file pom.xml poiché vengono utilizzati solamente durante lo sviluppo per generare alcune classi e non a runtime dal Gateway.

Configuration File: false-positive.xml